

555.1

Detection Engineering and SIEM Architecture

Licensed To: Arvind Pariti <paritiarvind@gmail_com> April 13, 2026



PLEASE READ THE TERMS AND CONDITIONS OF THIS COURSEWARE LICENSE AGREEMENT ("CLA") CAREFULLY BEFORE USING ANY OF THE COURSEWARE (DEFINED BELOW) ASSOCIATED WITH THE SANS INSTITUTE COURSE. THIS IS A LEGAL AND ENFORCEABLE CONTRACT BETWEEN YOU (THE "USER") AND THE ESCAL INSTITUTE OF ADVANCED TECHNOLOGIES, INC. /DBA SANS INSTITUTE ("SANS INSTITUTE") FOR THE COURSEWARE. BY ACCESSING THE COURSEWARE, USER AGREES TO BE BOUND BY THE TERMS OF THIS CLA.

With this CLA, SANS Institute hereby grants User a personal, non-exclusive license to use the Courseware subject to the terms of this CLA. Courseware means all printed materials, including course books and lab workbooks, slides or notes, as well as any digital or other media, audio and video recordings, virtual machines, software, technology, or data sets distributed by SANS Institute to User for use in the SANS Institute course associated with the Courseware. User agrees that the CLA is the complete and exclusive statement of agreement between SANS Institute and User and that this CLA supersedes any oral or written proposal, agreement or other communication relating to the subject matter of this CLA.

BY ACCESSING THE COURSEWARE, USER AGREES TO BE BOUND BY THE TERMS OF THIS CLA. USER FURTHER AGREES THAT ANY BREACH OF THE TERMS OF THIS CLA MAY CAUSE IRREPARABLE HARM AND SIGNIFICANT INJURY TO SANS INSTITUTE, AND THAT SANS INSTITUTE MAY ENFORCE THESE PROVISIONS BY INJUNCTION (WITHOUT THE NECESSITY OF POSTING BOND), SPECIFIC PERFORMANCE, OR OTHER EQUITABLE RELIEF.

If User does not agree to the terms of this CLA, User should not access the Courseware. User may return the Courseware to SANS Institute for a refund, if applicable.

User may not copy, reproduce, re-publish, distribute, display, modify or create derivative works based upon all or any portion of the Courseware, in any medium, whether printed, electronic or otherwise, for any purpose, without the express prior written consent of SANS Institute. User may not sell, rent, lease, trade, share, or otherwise transfer the Courseware in any way, shape, or form to any person or entity without the express written consent of SANS Institute. Additionally, User may not upload, submit, or otherwise transmit Courseware to any artificial intelligence system, platform, or service for any purpose, regardless of whether the intended use is commercial, educational, or personal, without the express written consent of SANS Institute. User agrees that the failure to abide by this provision would cause irreparable harm to SANS Institute that is impossible to quantify. User therefore agrees to a base liquidated damages amount of \$5000.00 USD per item of Courseware infringed upon or fraction thereof. In addition, the base liquidated damages amount shall be doubled for any Courseware less than a year old as a reasonable estimation of the anticipated or actual harm caused by User's breach of the CLA. Both parties acknowledge and agree that the stipulated amount of liquidated damages is not intended as a penalty, but as a reasonable estimate of damages suffered by SANS Institute due to User's breach of the CLA.

If any provision of this CLA is declared unenforceable in any jurisdiction, then such provision shall be deemed to be severable from this CLA and shall not affect the remainder thereof. A written amendment or addendum to this CLA that is executed by SANS Institute and User may accompany this Courseware.

SANS Institute may suspend and/or terminate User's access to and require immediate return of any Courseware in connection with any (i) material breaches or material violation of this CLA or general terms and conditions of use agreed to by User, (ii) technical or security issues or problems caused by User that materially impact the business operations of SANS Institute or other SANS Institute customers, or (iii) requests by law enforcement or government agencies.

SANS Institute acknowledges that any and all software and/or tools, graphics, images, tables, charts or graphs presented in this Courseware are the sole property of their respective trademark/registered/copyright owners, including:

The Apple® logo and any names of Apple products displayed or discussed in this book are registered trademarks of Apple, Inc.

PMP® and PMBOK® are registered trademarks of PMI.

SOF-ELK® is a registered trademark of Lewes Technology Consulting, LLC. Used with permission.

SIFT® is a registered trademark of Harbingers, LLC. Used with permission.

VMware Workstation Pro®, VMWare Workstation Player®, VMWare Fusion®, and VMware Fusion Pro® are registered trademarks of VMware, Inc. Used with permission.

Governing Law: This CLA shall be governed by the laws of the State of Maryland, USA.

Courseware licensed to User under this CLA may be subject to export laws and regulations of the United States of America and other jurisdictions. User warrants he or she is not listed (i) on any sanction programs list maintained by the U.S. Office of Foreign Assets Control within the U.S. Treasury Department ("OFAC"), or (ii) denied party list maintained by the U.S. Bureau of Industry and Security within the U.S. Department of Commerce ("BIS"). User agrees to not allow access to any Courseware to any person or entity in a U.S. embargoed country or in violation of a U.S. export control law or regulation. User agrees to cooperate with SANS Institute as necessary for SANS Institute to comply with export requirements and recordkeeping required by OFAC, BIS or other governmental agency.

All reference links are operational in the browser-based delivery of the electronic workbook.

Licensed To: Arvind Pariti <paritiarvind@gmail_com> April 13, 2026 SEC555_1_K02_01

Detection Engineering and SIEM Architecture

DETECTION ENGINEERING AND SIEM ANALYTICS

© 2025 SANS INSTITUTE | ALL RIGHTS RESERVED

K02_01

This area is intentionally left blank.

Course Agenda

Section 1: Detection Engineering and SIEM Architecture

Section 2: Network and Endpoint Analysis

Section 3: Asset Discovery, Baselines, and UEBA

Section 4: Cloud Logging and Monitoring

Section 5: Alerting and Detection Engineering Pipelines

Section 1: Detection Engineering and SIEM Architecture

In Section 1, we talk about the importance of logging and analysis and how they are the foundation of modern cyber defense, enabling both rapid response to threats and proactive identification of adversarial activities. We will also define the Detection Engineering lifecycle and the requirements of building a detection lab from the ground up. Log aggregation, parsing, and analysis will also be covered to ensure that all participants have a solid understanding of Detection Engineering and SIEM fundamentals. Section 1 establishes a strong baseline, ensuring students are prepared to engage with advanced concepts throughout the course.

Section 2: Network and Endpoint Analysis

Section 2 explores methods for gathering logs from services like DNS, SMTP, and HTTP servers, as well as passive techniques for extracting the same data directly from the network. We will also explore endpoint logs since they are a goldmine for detecting attacks, offering unparalleled visibility into post-compromise activities. You'll have an opportunity to explore various strategies and tools designed to simplify the collection, filtering, and handling of the vast amount of data generated by servers and workstations.

Section 3: Asset Discovery, Baselines, and UEBA

Section 3 teaches students how to identify key data sources that provide high-fidelity information and combine multiple streams of data to create a comprehensive and actionable master inventory. Beyond inventory, we'll expand into other aspects of "knowing thyself." You'll gain hands-on experience with network and system baselining, learning to monitor network flows and detect anomalies like command-and-control (C2) beaconing or unusual user activity.

Section 4: Cloud Logging and Monitoring

As organizations increasingly migrate to the cloud, achieving comprehensive visibility across platforms has never been more critical. Section 4 emphasizes the importance of cross-vendor expertise in

configuring robust cloud monitoring to protect your environment. Students will explore the various cloud log types available, with a focus on those that can be leveraged to strengthen defenses and streamline incident response.

Through hands-on guidance, you'll become familiar with the key logging tools in Microsoft Azure and AWS. You'll also analyze how attackers attempt to bypass cloud security measures, uncovering the traces they leave in logs. Finally, you'll learn how to optimize log configurations to ensure you capture critical events, leaving no gaps in your cloud monitoring strategy. This knowledge is essential to operationalize defenses and maintain a strong security posture in today's cloud-driven world.

Section 5: Alerting and Detection Engineering Pipelines

Section 5 emphasizes the power of integrating security logs from multiple sources for centralized analysis. You'll learn methods for combining and correlating data streams, adding valuable context that enables analysts to prioritize effectively. In addition, you will understand the importance of establishing and creating an automated detection engineering pipeline to streamline your operations and reduce delays when creating new detections.

Section 5 will conclude with a hands-on Capture the Flag (CTF) challenge, applying all the skills you've learned in a friendly, competitive environment! Your team will progress through multiple levels and missions designed to ensure mastery of the modern cyber defense techniques promoted all week long. From building a logging architecture, augmenting logs, analyzing network logs and system logs, and developing dashboards to find attacks, this challenging exercise will reinforce key principles in a fun, hands-on, team-based challenge.

Note about URLs: Sometimes this courseware cites URLs that were valid at the time originally cited, but as URLs change all the time, they may no longer be valid. While we strive to maintain the URLs, out-of-date URLs still have value. They show that a statement is based on scholarship. They can give hints about how to find source material, even if it is no longer at the original URL, and they can be used to find material using web content caches.

Table of Contents

Course Agenda	2
SIEM Introduction	5
Lab 1.0: Lab Setup	22
Detection Engineering Life Cycle and SIEM Planning	23
Lab 1.1: DeTT&CT & Data Source Gap Analysis	49
Creating a Detection Lab	50
Lab 1.2: Luring the Attacker with a Honeypot	75
Log Collection and Enrichment	76
Lab 1.3: Introduction to the SIEM Components	112
Log Aggregation, Parsing, and Analysis	113
Lab 1.4: Using AbuseIPDB for Data Enrichment	139
Contacts and Resources	140

This area is intentionally left blank.

Course Roadmap

Section 1: Detection Engineering and SIEM Architecture

Section 2: Network and Endpoint Analysis

Section 3: Asset Discovery, Baselines, and UEBA

Section 4: Cloud Logging and Monitoring

Section 5: Alerting and Detection Engineering Pipelines



- SIEM Introduction
 - ☐ Lab 1.0: Lab Setup
- Detection Engineering Life Cycle and SIEM Planning
 - ☐ Lab 1.1: DeTT&CT & Data Source Gap Analysis
- Creating a Detection Lab
 - ☐ Lab 1.2: Luring the Attacker with a Honeypot
- Log Collection and Enrichment
 - ☐ Lab 1.3: Introduction to the SIEM Components
- Log Aggregation, Parsing, and Analysis
 - ☐ Lab 1.4: Using AbuseIPDB for Data Enrichment

This area is intentionally left blank.

Module Objectives



The student will gain an understanding of the importance of having a SIEM in their environment, in addition to why a Detection Engineering function can offer great insight and grow a detective mindset.

This area is intentionally left blank.

Assumptions/Disclaimer

You are actively involved with logging and analysis.

- Already manage or maintain a SIEM solution
- Looking to purchase/implement a SIEM solution or monitoring function

Open-source vs. commercial tooling is a never-ending battle.

Choose what you need to get the job done. In fact, through the course of your career, you will probably end up using open-source and commercial tools.

There's no specific SIEM in mind or vendor preference for what we discuss.

- You could be using any vendor out there. In fact, you can be using vendor X today and then a year later vendor Y and two years down the line, vendor Z
- The concepts we discuss in class are not meant to be tool or vendor specific

Before we start discussing further, there are a few items to point out. These are:

- **There's an assumption that you are actively involved with logging and analysis.**
The course has been developed with this in mind. If you have never touched a SIEM tool before or don't know anything about monitoring, you can still greatly benefit, and that's perfectly fine. But it will require more work on your side.
- **Open-source vs. commercial tooling is a never-ending battle.**
Some companies and individuals simply love the freedom and flexibility of open-source tools. Some don't. That's down to personal choice. Do note, though, that there are a lot of mentions to freely available tools throughout the course, so the cost restriction can be lifted from your shoulders. You can use these as references, or to supplement your current capability, or even replace the current tools you have.
- **There is no specific SIEM or vendor preference for what we discuss.**
Tools are a means to an end. Think of a car. If you know how to drive, does it really matter if you take your driving test in a car made by Mercedes, while you normally drive a Prius? No, it really doesn't. This is a crucial point.

Everything we discuss is applicable to various tools. Course labs are developed to give you a practical sense of working with some indicative tools, which are used in real-life environments, solving real-life problems. How you do that in your personal job depends solely on you. You can choose any vendor you like.

The path will be carved; you can walk it however you desire.

Famous Last Words from the Trenches

"We really don't think we need a SIEM."

"Who needs a SIEM when you have a SOC?"

"We're not paying for that."

"A SIEM is just an obscene expense."

"We are cloud-only. A SIEM is not for us."

"We only need this for compliance and sometimes storing logs."



Different organizations tend to have varied notions of security. Some are very risk-averse, some not so much.

There are companies that employ full stacks of analysts, threat intelligence operators, and forensic specialists, and then there are others that simply don't.

True story coming up, from one of the author's perspective clients. Brace for impact :)

The prospective client reached out, stating they had a need for a single SOC (Security Operations Center) analyst to augment their operational floor.

After a few initial discussions, the Head of Security admitted that they only had a single SOC Analyst working for them, who had just resigned, so they didn't really need augmentation, but rather to fill a gap.

The environment was PCI-DSS (Payment Card Industry Data Security Standard) accredited, which meant that it required constant monitoring of cardholder data to prevent, detect, and respond to security incidents. Yet, they had a single person performing all of that—at least, that's what they stated.

What's the key takeaway from the early onset?

We need visibility, we need insight, and we need the appropriate way of implementing it. It all depends on the needs of the various corporations, but as you can undoubtedly understand, the above scenario should never be a reality. And yet, here we are ...

Average Dwell Time

Dwell time = How long are attackers there, before we detect them?

Mandiant M-Trends 2024 stated this was reduced to **10 days**.¹ Yet, in M-trends 2025, it was increased to 11 days.² That's the first time in 15 years an increase is noticed.

Verizon states **21 days** (DBIR).³

Splunk states **21-34** days in their State of Security report.⁴

Other vendors have varying opinions ranging up to **277 days** (according to IBM's Cost of a Data Breach report, 2024).⁵

Question: What if it took 3 days? Would that suffice for your business?

Before you answer, think of attacker speed, intelligence, and capability, and in general ask one more question: "What could they possibly do to my environment within that time of X days?"

One of the most interesting metrics in security is **attacker dwell time** (sometimes also referred to as mean time to detect). That's a metric that expresses how long an attacker has been present (dwelling) in an environment, prior to them being detected. Depending on what reports you read, that varies greatly. The goal is to reduce it as much as possible, especially as time and technology evolve.

If you go over some of the below references, where the dwell time seems to be substantially low, you might be overjoyed and think, "Well, only 10 days is amazing, isn't it?" The real question is, "Is that good enough for your business?"

If you are a big bank and the attacker has breached your critical servers, even being there for 10 hours may mean they are stealing data and causing havoc, which you may never be able to fully recover from.

How about the regulatory damage, resulting in potential fines?

How about the reputational damage when your clients find out?

Are those things you can recover from, even if the attacker was there **"only"** for two days or three hours?

1. <https://sec555.com/nujat>
2. <https://sec555.com/lms06>
3. <https://sec555.com/gu4z8>
4. <https://sec555.com/nf0je>
5. <https://sec555.com/kgz23>

Emphasis on Monitoring and Detection

Gartner's SOC model guide states that a SOC should have four main objectives:

- Threat identification
- Exposure and validation
- **Monitoring and detection**
- Response

Splunk advises to:

- Provide security training for operational staff
- Obtain necessary detection tools to assist in response automation
- Promote SOAR and security analytics

Gartner's SOC model guide (published in 2023) states that a SOC should have four main objectives:¹

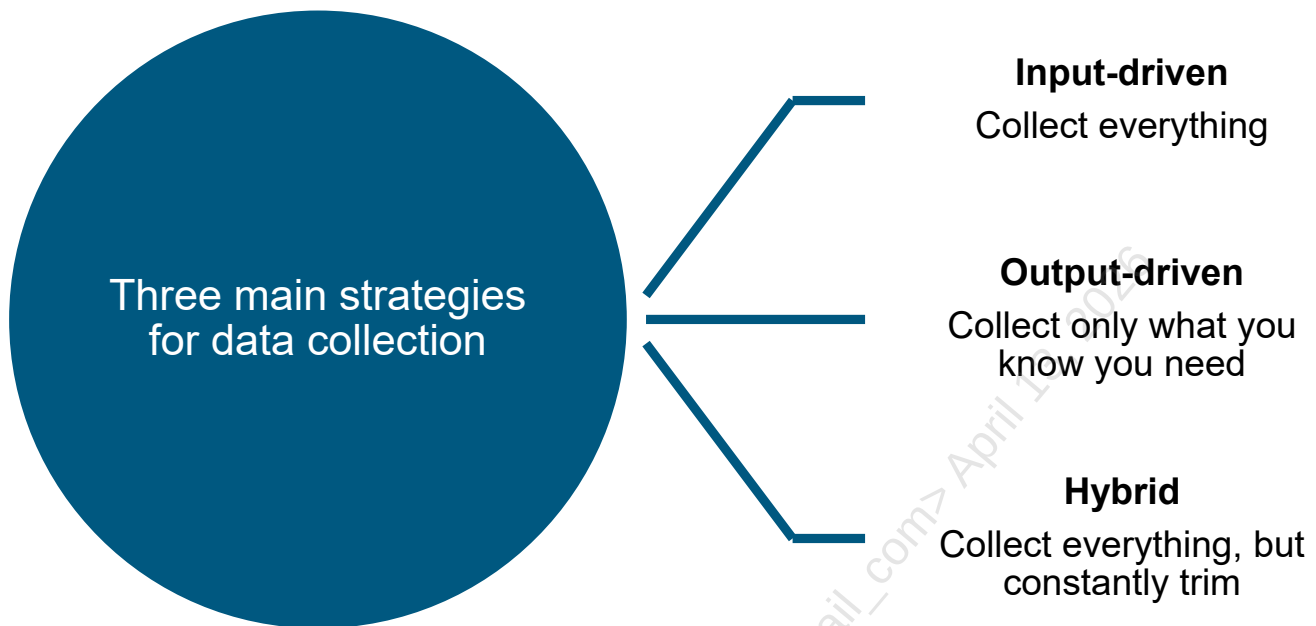
1. Threat identification
2. Exposure and validation
3. **Monitoring and detection**
4. Response

One of the four objectives is **monitoring and detection**. You need to be able to see the attackers coming, so you can stop them in their tracks. Escalating to the incident response team should be something that you don't need to do all the time. The SOC should be able to perform incident handling for the majority of the incidents. In fact, one could argue that a full-blown response should rarely be required, because if you do a lot of solid detection development, configure your tools according to best practices, and keep maturing, then you would need to escalate incidents to the IR team less and less—or at least, the serious incidents that keep you awake at night.

Splunk advises to develop detections and automate as much as possible.² As we will also discuss, automation is an integral part of detection engineering. No matter how many analysts or detection engineers you have, they will never be enough, especially when dealing with large environments and advanced attacks.

1. <https://sec555.com/is926>
2. <https://sec555.com/amej5>

Data Collection Strategies



When planning log collection, one needs first to decide what type of strategy to employ. Gartner has defined the terms **input-driven** and **output-driven**.¹

- **Input-driven:** Focuses on collecting everything from a device.
The principle behind this is that you may need something later that you did not know you needed. If you do not collect it, then obviously you will not be able to use it. For example, with this strategy, if you were collecting the Security event logs from Windows, you would collect all events and wouldn't focus on any specific event IDs.
- **Output-driven:** With this strategy, you only collect logs that you have identified a need for. In contrast to input-driven strategy, you would not collect the entire Security event log from Windows. Instead, you would focus only on key event IDs, such as the one associated with failed login attempts or the logs being cleared. Anything else would be dropped.
- **Hybrid:** Note that it is not mentioned by Gartner but instead is used here to describe a strategy involving the combination of both input-driven and output-driven methodologies.
With this method, **you collect everything and then immediately start removing events that trigger often but provide little or no value**. With the above-mentioned example, you would start collecting the entire Windows Security event log. Then you would look at the event IDs that trigger the most and start excluding the ones that you do not need. You continue to collect everything and repeat the cycle of identifying and filtering out low-value events until you're done.

1. <https://sec555.com/co2tz>

Input-Driven Strategy

Collecting everything

- Allows for historical analysis of all data, which means you establish patterns and trends

Pros

- You have it for sure
- Compliance tick box

Cons

- Hard to search through
- Slow and expensive

The input-driven strategy is great because you have all logs. However, they come at a cost both in money and in performance. It is common to see organizations follow the input-driven strategy. That is most likely due to one or more of the following reasons:

- **Business requirements:** Sometimes, there is a mandate from the business that all events be collected and stored for a specific period of time. If this is the case, then you should follow business requirements.
- **Compliance requirement:** Oftentimes, compliance is misunderstood to mean you must collect everything. In rare instances, this may be true. But that's not usually the case.
- **Vendor sales:** The more events you process, the more money vendors make. This is especially true for products licensed by volume. This, coupled with the fear tactic of worst-case scenarios of what would happen if you did not collect XYZ and needed it, is truly devastating.
- **Hoarding mindset:** This is the mindset that you cannot risk not having a log because you might need it. Therefore, I will collect everything and often store it for a long period of time, as well. In most cases, that's not a financially viable solution. For example, think about cloud logging. How can you do that and still have an affordable option? The amount of money you would need would outweigh any possible benefit, in most cases.

If you are not under a strict business or compliance requirement, you should consider the output-driven or hybrid strategies. This holds especially true if the SIEM performance is being affected due to the volume of logs, and you have no budget to scale your SIEM.

Output-Driven Strategy

Focusing on what you know you need

- Makes deployment and analysis easier

Pros

- Least expensive approach
- Great SIEM performance
- Easier implementation

Cons

- You are likely to miss something you did not know you needed

In a perfect SIEM world, you would only collect logs you needed. The SIEM would process and alert on these and life as we know it would be perfect. The output-driven strategy is considered the highest performing and least expensive approach, as it requires the least amount of money to run. However, the hidden cost of output-driven collection is the cost of trying to stay current and attempting to collect things that are needed. Your engineers and incident responders need to be very skilled to make sound choices about what log sources and associated events need to be kept vs. the ones that you will ignore. A responsibility not to be taken lightly.

While arguably nowhere near the direct and upfront cost of the input-driven strategy, the resources and training to make sure an organization knows what should be collected do not come free.

This strategy also runs the risk of not identifying an attack because the logs were never collected.

It requires in-depth knowledge of all systems you have available, while also making careful and very selective decisions about what data to preserve. Often enough, people are very intimidated by that approach and choose to go with the previous approach (input-driven).

On one hand, this is very attractive to leadership teams, due to the reduced cost.

On the other hand, the same audience would not take it kindly when you go back to them several months later and state that an attack was missed because that log source or several of its events were not being collected all this time. Sadly, you can't take that back. If an incident took place and you didn't see it because you never collected the required logs, that's a huge dent and a miss you won't easily recover from.

Hybrid Strategy

Collect everything

- After you have it, trim the noise

Pros

- You have historical data, even if you are not sure you need it
- Significantly cheaper to maintain than input-driven

Cons

- Requires ongoing maintenance and tuning
- Cost can still be considerable

The hybrid strategy is a great approach for you to consider. It tries to combine the advantages of both the input-driven and output-driven approaches. To lower costs, high-triggering events that provide little or no value are removed. However, since these events are considered acceptable to remove, you do not run the risk of accidentally missing a critical event because you are putting them under the microscope and are reviewing them before fully dismissing any events.

Now, make no mistake. This also requires a lot of experience, sound knowledge of systems and tools, and careful decision making. However, you stand a much better fighting chance, and you are better positioned to balance out cost with system performance and business needs, without missing out on visibility.

You will easily find that it's not uncommon to remove 80 to 90% of events by identifying the top X events (by event type) and removing those that do not provide value. What does this do?

- Lowers the ongoing cost of the SIEM.
- Increases tool performance.
- Decreases the amount of time it takes to perform manual investigations.

Sometimes, SOC analysts (especially inexperienced ones) perform what is known as greedy searches. What is that? Let's look at an example.

Assume an analyst tries to locate a file hash in a web proxy log, although they won't ever find it because that isn't stored in that log source. However, in their effort to do so, they can perform a search across every indexed log source in the environment (also known as a * search). The logic is that if they can't specify what log source or time frame to look at, **they will look at all log sources for a very wide time frame.**

Depending on the tool and its design, this can have tremendous performance hits. Imagine 5-6 people doing this at the same time. Not good.

Log Volume Estimation (EPD vs. EPS)

The best way to size is to collect logs over a period of time using a sample of your environment.

May require a proof of concept (POC) deployment



Alternatively, scripts could be run to gather log information.

PowerShell can collect statistics from Windows hosts.

Python/Bash can do the same for Linux.



Network devices often require sending logs to a logging service, such as a syslog server, to make an estimation.

When centrally collecting logs, it is important that the log aggregation hardware and software are capable of handling the number of incoming logs. The number of network connections these devices must handle is extremely high. As a result, if you do not size your log aggregation solution properly, you will end up dropping logs.

The preferred, and more accurate way to collect logs, is to set up a proof of concept (POC) where you collect logs from a percentage of your environment. This does two things:

- Provides an estimate of how many events per second (EPS) each device type generates.
- Discovers peak time periods for log generation.

However, running a POC can be time-consuming, and it requires quite a few resources to be allocated against it.

An alternative method is to try and estimate the number of events generated per day by key device types such as Windows and Linux systems. This can be done using scripts that connect to systems and identify how many logs per day they are generating. This can be conducted across the entire environment and provide an accurate number of events per day (EPD). This method tends to work well for operating system environments that support scripting, like Windows and Linux, but doesn't work well for network devices, like switches and firewalls.

For network devices, it is possible that you already have a reporting interface that can provide this information. Otherwise, you will need to fall back to a POC or develop some more advanced scripts that possibly issue commands over SSH and collect the results.

EPD is a fairly wide number, so in most cases we use events per second (EPS), since it is more granular and allows you to gain a better estimation of how much log volume you expect to have.

Events per Second (EPS)

EPS is a key metric when sizing log aggregation systems.

- Hardware/software must be able to scale to your EPS.

To go from events per day (EPD) to events per second, divide by 86,400 (number of seconds in a day).

1 billion EPD/86,400 = 11,574 EPS.

However, sizing for EPS is not enough.

- Length of log affects parsing and storage.
- It is normal to have peaks during log ingestion.



Log aggregators are generally sized based on the overall total number of events they can handle per second. It is important to size using the current number of EPS but also to account for peaks, as well as organic growth.

It is crucial to identify if the log aggregation solution you are using is scalable, so it can support your environment as you grow.

If the only sizing you are able to do is to run scripts and find out how many events are generated per day, you can take that number and divide it by 86,400 to get a rough estimate of your EPS. 86,400 is the number of seconds per day (24 hours * 60 minutes/hour * 60 seconds/minute).

EPS is a great starting point, but it is not enough. The size of a log can vary dramatically between different log sources and organizational units. Plus, it is normal to have a large fluctuation in the number of events coming in at a given moment.

If you're using an external provider, it would be beneficial for you to include a clause in your contract allowing you to renegotiate the EPS at least once a year. That means, if your environment changes, then you would still be able to scale up or down, without taking a hit.

The author managed to save a client a considerable slice of budget because they had initially overestimated their EPS count, but they never reached that. Upon the yearly marker arriving, a renegotiation was possible with their cooperating external party storing logs for them, thus saving quite a lot of money by scaling down, consuming less EPS for the year to follow. Had that not happened, they would end up paying the same amount each year for a 3-year period, without ever reaching that EPS consumption.

Peak Events per Second

If you size according to EPS, you are guaranteed to fail. Why?

- EPS fluctuates throughout the day.
- For example, events generated after hours are significantly less for a business running 5 days a week over 8 hours/day.

Log aggregators must be able to handle peaks.

- What happens during an attack?
- Number of events can easily multiply by 50.
- Does this mean you need to plan for 50 times your EPS?

As previously mentioned, it is important to size your log aggregation solution based on EPS, but to buffer for growth, as well as peaks in events.

Let's assume for a second you ran a POC (proof of concept) on a Saturday, in the middle of July, and came up with an EPS of **50,000**. So, you padded the number and purchased a log aggregation solution that can handle 75,000 EPS. If Saturday is normally your organization's slow day, then you will be in trouble. If you have monthly or quarterly processing that spikes activity, your 75,000 EPS log aggregation solution may drop logs at the end of every month or quarter.

If you sized EPS using scripts and came up with a rough estimate of EPS, then understand that you likely do not accurately know your peak EPS. For example, if a Windows system has 100,000 events per day, then an estimated EPS would be about 1.16. That is:

$100,000 \text{ events} / 86,400 \text{ seconds} = 1.16$ (86,400 being the number of seconds in a day).

However, it is likely that 80% of those events came during business hours, such as Monday to Friday, 09:00 a.m. to 17:00 p.m. In this case, you would have 80,000 events over 8 hours, which is an EPS of 2.78. That's: $80,000 / 28,800 = 2.78$ (28,800 comes from 8 hours * 60 minutes in an hour * 60 seconds in a minute).

This EPS is more than double that of the previous EPS calculation. The moral of this is you can't just perform a POC and plan on padding your log aggregation EPS by doubling (or tripling) your estimated EPS. During peak times, the EPS can easily skyrocket to 50 times more.

Do note that there are numerous EPS calculators that some of the SIEM vendors provide to aid you in calculating your average EPS. Those don't take the peak EPS into account, again exposing you to wrong conclusions.

EPS Recommendations

To be safe, you must calculate using one of three methods:

- Implement a targeted proof of concept (**recommended**)
- Utilize scripts to pull back actual EPS
- Plan to over-purchase

Inaccurate estimates or under purchasing, lead to:

- Slow storage
- Dropped logs
- Unhappy management
- Inoperable SOC

The truth of the matter is you really need to have knowledge of how many events you are likely to ingest, or you need to plan on over-purchasing, due to the risk of being wrong.

Have you ever spoken to someone who wished they had bought less SIEM hardware and software?

How about someone who has not bought enough SIEM hardware and software?

The latter is prominent and results in analyst frustration, political barriers, and a general disposition against whatever SIEM solution is in use. Both have their challenges; again, security is a balancing act. If you don't do your homework, you might end up spending too much or not investing enough.

If a SIEM starts taking on more than it can handle, it begins to fail, and then everyone gets mad at either the SIEM for failing or at the security folks for not planning accordingly.

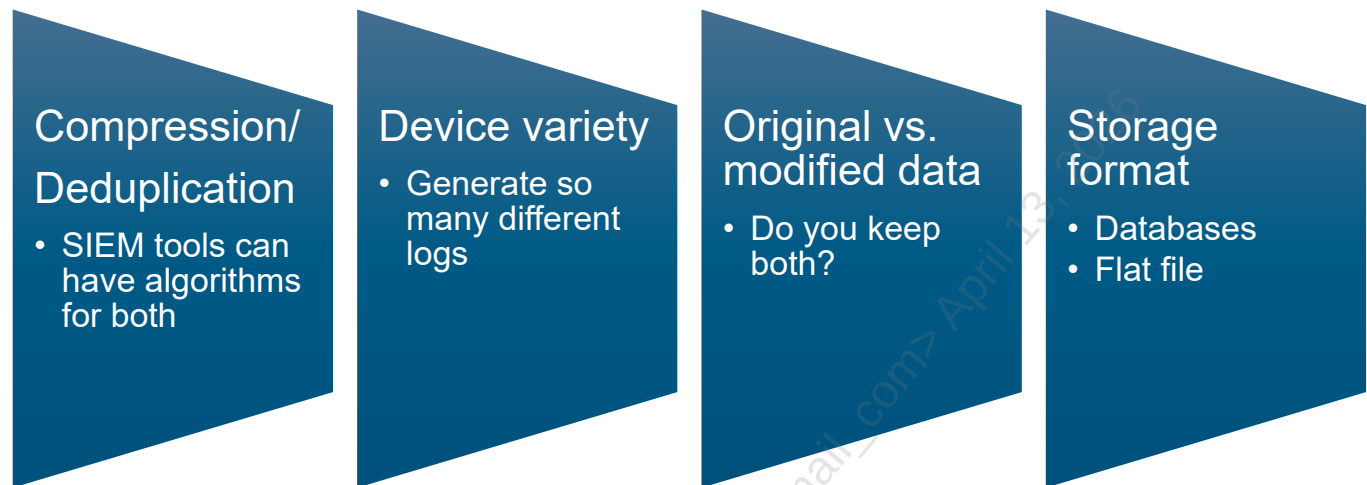
Please keep in mind this may not be your fault. It is possible you exercised due diligence and had everything set up right, and then a business unit decides they are going to send insane amounts of logs down the SIEM's way, even though it was not budgeted.

The problem here is that logging is not free. Should additional sources be added, they need to be calculated and discussed in terms of money. "Yes, we can take these additional logs in for you, but it's going to cost an extra \$\$\$ this year and \$\$\$\$ over the next three years. Do you approve this amount?"

Remember the golden rule. **When in doubt, lab it out.** Running a POC and allowing your tool to exist in the environment and then assessing the actual results beats anything else, as it provides the most accurate deductions.

Storage Requirements

- Best method to calculate storage requirements = collect events in your environment.
- Many factors make this difficult.



Now that you know how to calculate EPS, it is time to calculate storage requirements. This ends up being more difficult than EPS because more factors come into play.

For accurate sizing, a POC is often required. Gathering information using scripts is not as helpful. For example, while you may be able to script out and gather the size of Windows logs on disk, the size of the logs inside any given SIEM is guaranteed not to match.

Why?

1. **Compression/Deduplication:** Logs may be compressed or stored in a special format the SIEM utilizes. SIEM tools also use certain deduplication algorithms to avoid keeping duplicate records and wasting resources and space.
2. **Device variety:** Depending on the variety of devices you have in your environment, you will need to account for more storage.
3. **Original vs. modified data:** The size of the logs on a given system would not factor in the storage from modifying logs and whether or not the original log is kept.
4. **Storage format:** The end storage format makes a huge difference when storing logs. Are you using a database, a flat file, or something else?

Hot vs. Warm Data

Data retention is another challenge when calculating storage requirements.

- Varies dramatically due to compliance and internal policies (e.g., HIPAA states to keep HIPAA-related policies, procedures, and logs for at least 6 years).
- Many organizations have a 30-day retention policy (or much more) for HIPAA-related items.

Plan for fast (hot) and slow (cold) storage.

- Rule of thumb = have key events on fast disks for at least 7–30 days.
- Ideally, make that 30+ days.

Question: If the mean time to detection is 24 days, how long do you think retention should be?

Before sizing out disks, it is important to decide on a suitable data retention policy. How long should each event source be kept?

For this decision to be made, remember that you need to take into account the internal organizational appetite regarding business practices, tackling performance issues, and overall business intention. But you also need to take into account what regulatory frameworks require of you. HIPAA (Health Insurance Portability and Accountability Act) demands that covered entities keep records of any HIPAA-related policy, procedure, or log for at least six years from the date of creation or from the date they were in effect last (whichever is later).

Equally important is deciding if the event source is going to be frequently searched. This is necessary to know, so you can decide on how long it should be kept on fast disks and when it can be moved to cold disks.

For example, you may have a company policy dictating that login events must be kept for 10 years. However, you only use the data for real-time alerts and reports for the first 90 days. As a result, these types of events need to be able to fit on hot disks for 90 days and afterward be moved to warm disks for the remainder of that period.

Hot disks are often SSDs (Solid State Drives). Slow disks are often SATA (Serial AT Attachment) but could also include archival media such as magnetic tapes.

While not commonly used, it should be noted that some SIEM solutions allow you to take something stored on cold disks and move it temporarily or permanently to hot disks. This is useful for speeding up investigations and manual analysis.

But beware of any restrictions imposed when collaborating with third parties or storing data in the cloud.

Summary

Having a SIEM allows you to collect, contextualize events, and investigate in detail. It also enables you to perform historical lookups, which may be useful to uncover patterns in data. But one of the key challenges is deciding what to log.

Perform a careful evaluation of your environment and try to accurately estimate your EPS, which will empower you to make the right tooling decisions. Also, remember to take customer contracts and compliance requirements into consideration as you're planning your solution.

This area is intentionally left blank.

Lab Setup

Refer to the lab workbook for instructions.

This area is intentionally left blank.

Course Roadmap

Section 1: Detection Engineering and SIEM Architecture

Section 2: Network and Endpoint Analysis

Section 3: Asset Discovery, Baselines, and UEBA

Section 4: Cloud Logging and Monitoring

Section 5: Alerting and Detection Engineering Pipelines



- SIEM Introduction
 - ▢ Lab 1.0: Lab Setup
- Detection Engineering Life Cycle and SIEM Planning
 - ▢ Lab 1.1: DeTT&CT & Data Source Gap Analysis
- Creating a Detection Lab
 - ▢ Lab 1.2: Luring the Attacker with a Honeypot
- Log Collection and Enrichment
 - ▢ Lab 1.3: Introduction to the SIEM Components
- Log Aggregation, Parsing, and Analysis
 - ▢ Lab 1.4: Using AbuseIPDB for Data Enrichment

This area is intentionally left blank.

Module Objectives



The student will gain an understanding of the detection engineering life cycle and the importance of logistical work going into purchasing a SIEM.

This area is intentionally left blank.

MITRE ATT&CK Framework

Reconnaissance 10 techniques	Resource Development 8 techniques	Initial Access 10 techniques	Execution 14 techniques	Persistence 20 techniques	Privilege Escalation 14 techniques	Defense Evasion 44 techniques	Credential Access 17 techniques	Discovery 32 techniques	Lateral Movement 9 techniques	Collection 17 techniques	Command and Control 18 techniques	Exfiltration 9 techniques	Impact 14 techniques
Active Scanning (3) Gather Victim Host Information (4) Gather Victim Identity Information (3) Gather Victim Network Information (4) Gather Victim Org Information (4) Phishing for Information (4) Search Closed Sources (2) Search Open Technical Databases (5) Search Open Websites/Domains (3) Search Victim-Owned Websites	Acquire Access Acquire Infrastructure (8) Compromise Accounts (3) Compromise Infrastructure (4) Develop Capabilities (4) Establish Accounts (3) Obtain Capabilities (7) Stage Capabilities (4)	Content Injection Drive-by Compromise Exploit Public-Facing Application External Remote Services Hardware Additions Phishing (4) Replication Through Removable Media Supply Chain Compromise (3) Trusted Relationship Valid Accounts (4)	Cloud Administration Command Command and Scripting Interpreter (11) Container Administration Command Deploy Container Exploitation for Client Execution Inter-Process Communication (8) Native API Scheduled Task/Job (5) Serverless Execution Shared Modules Software Deployment Tools System Services (2) User Execution (3) Windows Management Instrumentation	Account Manipulation (7) BITS Jobs Boot or Logon Autostart Execution (14) Boot or Logon Initialization Scripts (5) Browser Extensions Compromise Host Software Binary Create Account (2) Create or Modify System Process (8) Event Triggered Execution (17) Escape to Host External Remote Services Hijack Execution Flow (13) Hijack Task/Job (5) Implant Internal Image Modify Authentication Process (8) Office Application Startup (5) Power Settings Pre-OS Boot (3) Scheduled Task/Job (5) Server Software Component (1) Traffic Signaling (2) Valid Accounts (4)	Abuse Elevation Control Mechanism (8) Access Token Manipulation (5) Account Manipulation (7) Boot or Logon Autostart Execution (14) Boot or Logon Initialization Scripts (5) Create or Modify System Process (8) Domain or Tenant Policy Modification (2) Event Triggered Execution (17) Event Triggered Execution (17) Exploitation for Privilege Escalation Hijack Execution Flow (13) Impair Defenses (11) Indicator Removal (10) Indirect Command Execution Masquerading (10) Modify Authentication Process (8) Modify Cloud Compute Infrastructure (3) Modify Cloud Resource Hierarchy Modify Registry	Abuse Elevation Control Mechanism (8) Access Token Manipulation (5) BITS Jobs Build Image on Host Debugger Evasion Deobfuscate/Decode Files or Information Deploy Container Direct Volume Access Domain or Tenant Policy Modification (2) Execution Guardrails (2) Exploitation for Defense Evasion File and Directory Permissions Modification (2) Hide Artifacts (12) Hijack Execution Flow (13) Impair Defenses (11) Indicator Removal (10) Indirect Command Execution Masquerading (10) Modify Authentication Process (8) Modify Cloud Compute Infrastructure (3) Modify Cloud Resource Hierarchy Modify Registry	Adversary-in-the-Middle (4) Brute Force (4) Credentialsteal from Password Stores (8) Exploitation for Credential Access Forge Web Credentials (2) Input Capture (2) Multi-Factor Authentication Interception Multi-Factor Authentication Request Generation Network Sniffing OS Credential Dumping (8) Steal or Forge Kerberos Tickets (3) Steal Web Session Cookie Unsecured Credentials (8)	Account Discovery (4) Application Window Discovery Browser Information Discovery Cloud Infrastructure Discovery Cloud Service Dashboard Cloud Storage Discovery Cloud Storage Object Discovery Container and Resource Discovery Debugger Evasion Device Driver Discovery Domain Trust Discovery File and Directory Discovery Group Policy Discovery Log Enumeration Network Service Discovery Network Share Discovery Network Sniffing Password Policy Discovery Peripheral Device Discovery Permission Groups Discovery (3) Process Discovery Query Registry Remote System Discovery	Exploitation of Remote Services Internal Spearphishing Lateral Tool Transfer Remote Service Session Hijacking (2) Remote Services (8) Replication Through Removable Media Software Deployment Tools Taint Shared Content Use Alternate Authentication Material (4)	Adversary-in-the-Middle (4) Archive Collected Data (3) Audio Capture Automated Collection Browser Session Hijacking Clipboard Data Data from Cloud Storage Data from Configuration Repository (2) Data from Information Repositories (3) Data from Local System Data from Network Shared Drive Data from Removable Media Data Staged (2) Email Collection (3) Input Capture (4) Screen Capture Video Capture	Application Layer Protocol (3) Communication Through Removable Media Content Injection Data Encoding (2) Data Obfuscation (2) Dynamic Resolution (3) Encrypted Channel (2) Fallback Channels Hide Infrastructure Hijack Tool Transfer Multi-Stage Channels Non-Application Layer Protocol Non-Standard Port Protocol Tunneling Proxy (4) Remote Access Software Traffic Signaling (2) Web Service (3)	Automated Exfiltration (1) Data Transfer Size Limits Exfiltration Over Alternative Protocol (3) Exfiltration Over C2 Channel Exfiltration Over Other Network Medium (1) Exfiltration Over Physical Medium (1) Exfiltration Over Web Service (4) Scheduled Transfer Transfer Data to Cloud Account	Account Access Removal Data Destruction (1) Data Encrypted for Impact Data Manipulation (4) Defacement (2) Disk Wipe (2) Endpoint Denial of Service (4) Financial Theft Firmware Corruption Inhibit System Recovery Network Denial of Service (2) Resource Hijacking (4) Service Stop System Shutdown/Reboot

For every detection engineer, SOC analyst, or security professional out there, MITRE's ATT&CK framework¹ provides a great starting point to understanding how attackers work and dive into detail into any TTPs (Tactics, Techniques, and Procedures) they may be using.

The top line contains known tactics attackers use to breach environments. Each tactic is then broken down into different techniques, and those subsequently contain known procedures that attackers use.

As an example, take the **persistence tactic**, which currently contains 20 techniques under it.² Let's say you had a look at those and were interested in **technique 1547**, which relates to **Boot or Logon Autostart Execution**. Within that, you still have 14 sub-techniques to explore.³

Again, let's assume you are interested in understanding how the attacker can achieve persistence by modifying **registry keys and startup folder items**. That's the first sub-technique on the list.⁴ If you browse to the related page, MITRE has a wealth of information about that, in addition to a huge list of procedures mentioned that attackers have been known to utilize for achieving persistence via this approach. Those include modifying specific registry hives with unique values, addition of mentioned scripts, and modification of the startup folder. The same approach can be followed for all the items on the list.

1. <https://sec555.com/bvws4>
2. <https://sec555.com/km2vx>
3. <https://sec555.com/axrlv>
4. <https://sec555.com/my28d>

Why Is Detection Engineering Required?

With the right detection rules, you can find attackers before it's too late.

Even if rules aren't perfect, you can still reduce the dwell time considerably.

You need specially trained personnel to configure and perform tool tuning.

Detection engineering can equip your SOC analysts, incident responders, and operational teams with the ammunition they need to hunt down attackers and reduce risk.

Even if SOC operators could be great detection engineers, do they have the time to develop and test rules, on top of their actual day job?

Modern attackers use complex tools and techniques. That requires research, training, and constantly remaining up-to-date. In short, it takes a dedicated team to do it properly.

Having a suitable detection engineering program can reduce the overall cost of responding to threats, as well as their associated impact.

A detection engineer's primary objective is to create appropriate content for monitoring tools and solutions, such that it enables the environment to identify any attacks or signs of potential attacks as early on as possible.

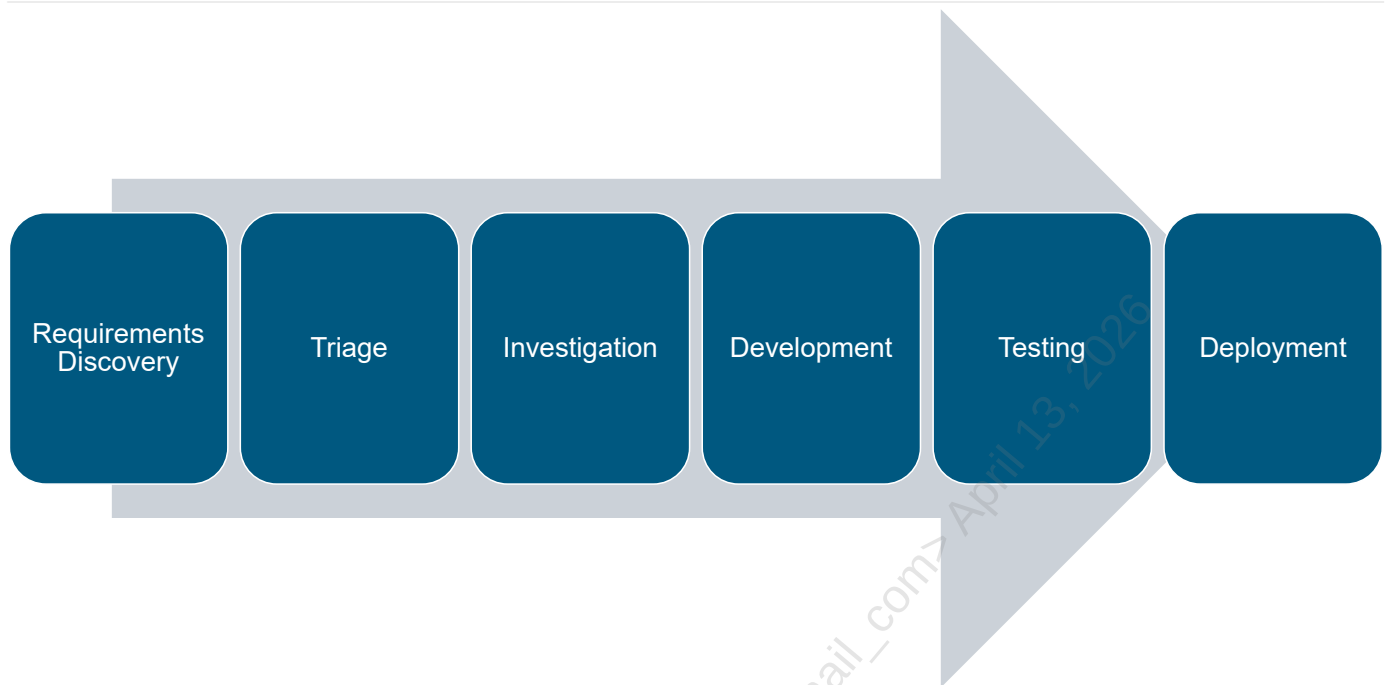
Does that mean there's going to be a rule for everything? Probably not. But that's what we're striving for.

This is an ongoing process, and the function requires a lot of maturity to be able to offer detections for most serious attacks and even start creating content which has a proactive mindset. The work entails:

- Researching new attacks.
- Creating and maintaining a detection lab.
- Testing log sources for appropriate logging.
- Ensuring there's enough information in the log data to create detections.
- Creating rules in test environments and testing them to ensure they are firing properly, without inundating the SOC team with alerts.
- Maintaining the current content, deleting what's not useful and creating new detections.
- Cope with advanced attacks, which can be very difficult to detect, and may require a series of detection rules.
- Using an automated detection development pipeline.

As you can understand, these objectives take serious time and effort, which is why it's very unlikely for this to be successful, if dedicated personnel aren't used. Investing in proper tools, infrastructure, and, above all, people, can make the difference between early attacker identification vs. delayed detections or no detection at all.

Detection Engineering Life Cycle



The Detection Engineering Life Cycle is commonly comprised of six phases:¹

1. Requirements discovery
2. Triage
3. Investigation
4. Development
5. Testing
6. Deployment

Let's break these down into detail to identify what needs to take place in each phase.

1. *Practical Threat Detection Engineering: A Hands-on Guide to Planning, Developing, and Validating Detection Capabilities* by Megan Roddie, Jason Deyalsingh, Gary J. Katz

Requirements Discovery: Candidates for Input



Requirements can be posed by a variety of teams within the environment. Let's look at some representative examples:

- **SOC:** The SOC is probably the most classical example of a team that will provide requests for rules to be created to aid them in obtaining alerts, expressing attacker activity, and signs of intrusion. Being the immediate consumers of the detection rules that are created, they are also a prime candidate for collaboration, to improve detections and tune content to their needs.
- **Threat Hunting:** The function that assumes attackers are already present and does their best to identify and eradicate them. During that effort, there will be immense room for posing requirements for creating or improving detections.
- **Threat Intelligence:** Threat intelligence analysts may be using internal, external, or both categories of tools to provide actionable intelligence to other operational teams. Their input often needs to be translated into alerts and detection content to identify malicious activity.
- **Incident Response:** While responding to incidents, there's often an opportunity to identify gaps in defenses. A common question is, "How did they get in, without us knowing?" That's usually because there was no detection content present to alert us to attacker activity. It is only after the IR team responds to an incident that we get an understanding of what we are lacking.
- **Penetration Testing:** This can involve internal, external assessments, and purple or red teaming activities. Purple teaming, in particular, is all about improving the blue team's detections. But any of these assessment types can identify holes in our tools, which we can later fill with beautiful detections.
- **Malware Analysis:** Depending on the type of environment, you may find that malware analysts pose a great source of requirements. They can provide feedback about malicious samples they analyze, how those operate, and what to do so they can be identified early on.

What Criteria Should Detections Meet?

Coverage	• Activity scope (e.g., specific attack technique/procedure)
Durability	• How long does the detection live for?
Complexity	• What does it take to comprehend how this attack works and to implement a rule to detect it?
Confidence	• How confident can we be this will result in a solid finding?
How noisy	• If a rule generates too many findings, you may want to reconsider having it implemented
Actionable content	• When an alert fires, what is the analyst supposed to do?
Attacker cost	• Does this attack require significant attacker investment?

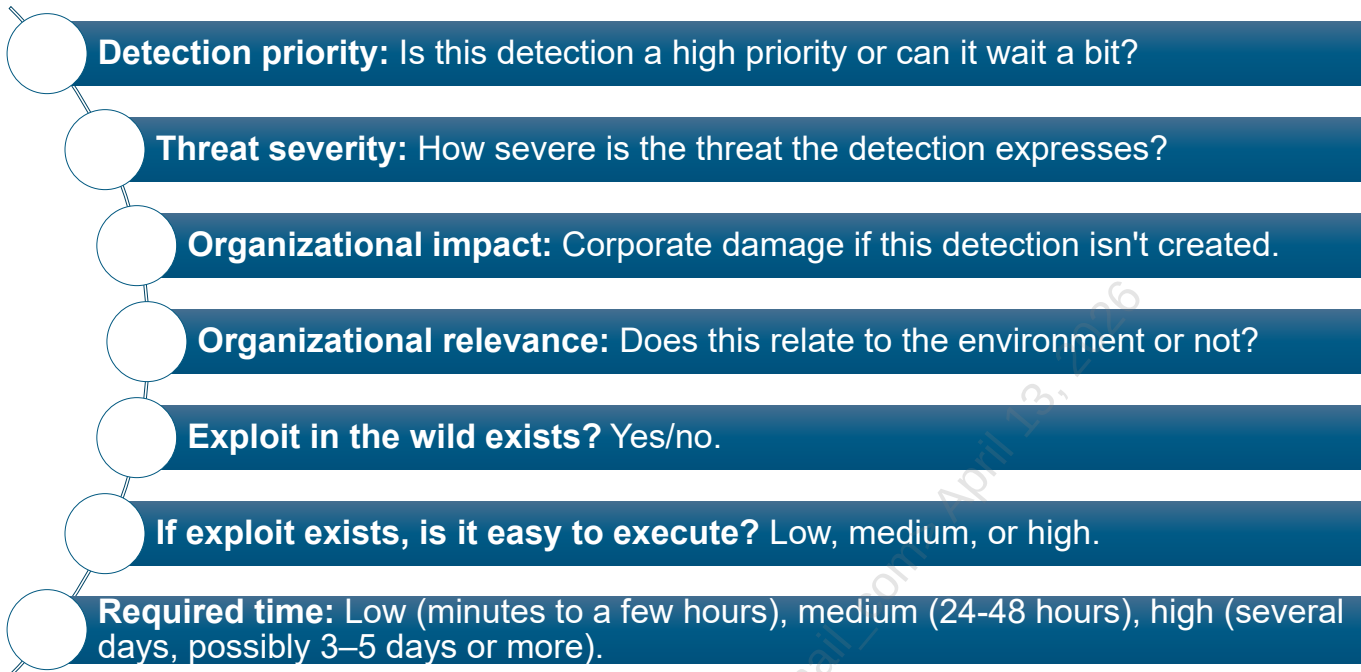
Detections need to be efficient, able to identify malicious activity, and not generate too many false positive events that reduce their quality. In more detail, they need to fill the below criteria:¹

- **Coverage:** What is this detection about? What specific attacker techniques or procedures does it cover?
- **Durability:** How long is this detection expected to be effective for? One week? Three months? Five years?
- **Complexity:** How composite is the detection? Will it require five engineers, three months to create and test it?
- **Confidence:** How sure are you that the alerts being generated by a detection are actually indicative of hostile activity? In short, are they true positives or not?
- **How noisy is it?** Usually, noise is created because a detection has a considerable number of false positives. In those cases, tuning will be required to reduce noise.
- **Actionable content:** Does a security analyst know what to do after this detection triggers?
- **Attacker cost:** At what lengths does the attacker need to go so they can leverage a given exploit? This isn't easy to estimate, but sometimes we can make educated guesses. For instance, if it relates to computing power or immense technical knowledge, or physical presence at an environment, etc.

You should strive to meet as many of these criteria as possible to eliminate noise and enhance detection content.

1. *Practical Threat Detection Engineering: A Hands-on Guide to Planning, Developing, and Validating Detection Capabilities* by Megan Roddie, Jason Deyalsingh, Gary J. Katz

Triage



You have every intention in the world to create as many quality detection rules as possible. But does that mean you create a rule for every requirement that you get? Probably not, as that wouldn't be manageable from a cost and resource perspective. You need to set specific criteria for you to triage incoming requests and identify which ones are turned into detections:

1. **Detection priority (low, medium, or high):** How much does this detection need to be prioritized for your environment? Does it need to happen today or can it wait for a week?
2. **Threat severity (low, medium, or high):** How severe is the threat this detection relates to? Meaning, what happens if this threat isn't detected? For example, would you really classify detecting a potentially unwanted application as high severity? Probably not. That would be low.
3. **Organizational impact (low, medium, or high):** What's the damage to the company if this detection isn't created? For example, if this relates to remote code execution on one of your critical servers, it would be high impact.
4. **Organizational relevance (low, medium, or high):** Sometimes we get threat intelligence information about new threats and exploits and we are eager to develop detections. Would a Drupal-related detection be useful to you if you're not running Drupal? Not really.
5. **Exploit in the wild exists (yes/no)?** Take into account if there's an active exploit, possibly making it more compelling to think about creating a detection for a given hostile activity.
6. **If exploit exists, is it easy to execute (low, medium, or high)?** How easy is it for the attacker to take advantage of an existing exploit, to breach your environment, or access data? For example, if this is a military base and the attacker needs physical system presence to execute code, it means it's not going to be easy to execute this attack.
7. **Required time (low, medium, or high):** Sometimes it can be very straightforward to develop and deploy a detection, especially if it relates to well-established attacker activity. In those cases, there's a high chance a rule may already exist, which you can test and deploy with relative ease. But then there are other times when attacker activity is extremely sophisticated, or the attack is so

© SANS Institute 2025

complicated that you need a rule to pull logs and events from multiple log sources. In those cases, developing and rolling out use cases can be much more time-consuming. You need to account for that fact when you consider creating a detection.

Investigation

Before proceeding to the actual detection rule development, you need to review the **log source data you are getting**.

Examples

You need an alert to be fired each time a critical file is modified on a host/server, but you lack endpoint visibility.

You need to be alerted when a file is opened for editing, but a review of the current settings shows no auditing in place for that activity.

You need to alert upon a field not currently present in a log source. You may need to write a new parser or find another way.

You need to understand if there's any AUP policy breach by navigating to banned websites, but you have no suitable source (e.g., web proxy logs).

☹ ☹ ☹
<Enter here any logging struggle you ever faced>
 ☹ ☹ ☹

During an investigation, you will focus on identifying what is required to make the detection successful. For instance, what type of log sources do you need to detect the activity in question? Furthermore, what specific types of data from those sources?

Let's assume you are already getting default log data from all your Windows machines. Well, if a detection needed Sysmon data, that wouldn't be available by default. You need to explicitly add it.

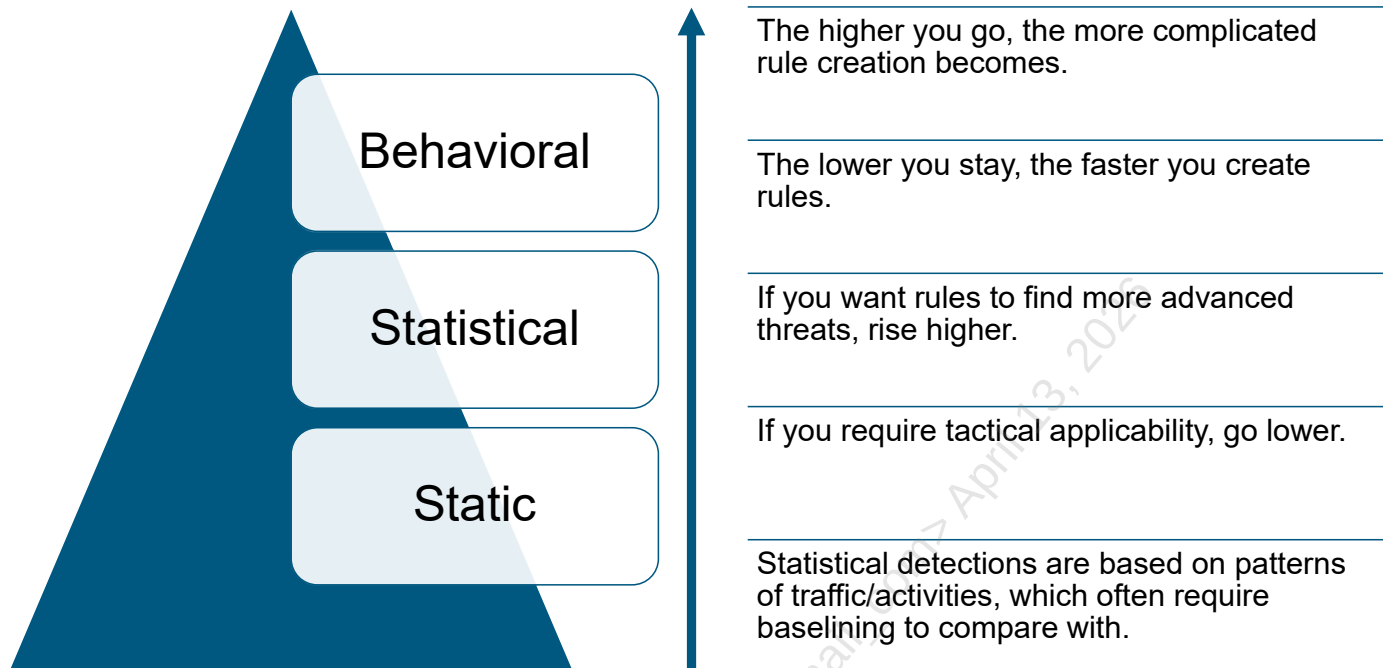
You will also need to understand what types of organizational assets are in scope for this activity, so you can narrow that detection accordingly. If this detection only relates to the organizational database servers, then you can trim it down to those.

How about if this relates to networking equipment, like company routers? Well, in that case, you might find that you need to work with the Network Operations team to gain an understanding of the current networking device configuration and ensure you are getting relevant data for you to create the detection you need.

Don't be afraid to collaborate with other security teams and engage additional entities to understand sources and data in more detail. Are you a web developer? Probably not. If you were trying to create a web application related detection, wouldn't you want to speak to the people developing it, so you understand its operation properly before proceeding any further?

The goal of this phase is to enable you to proceed to developing a detection, only after you ensure your ducks are in a row.

Investigation: Indicator Types



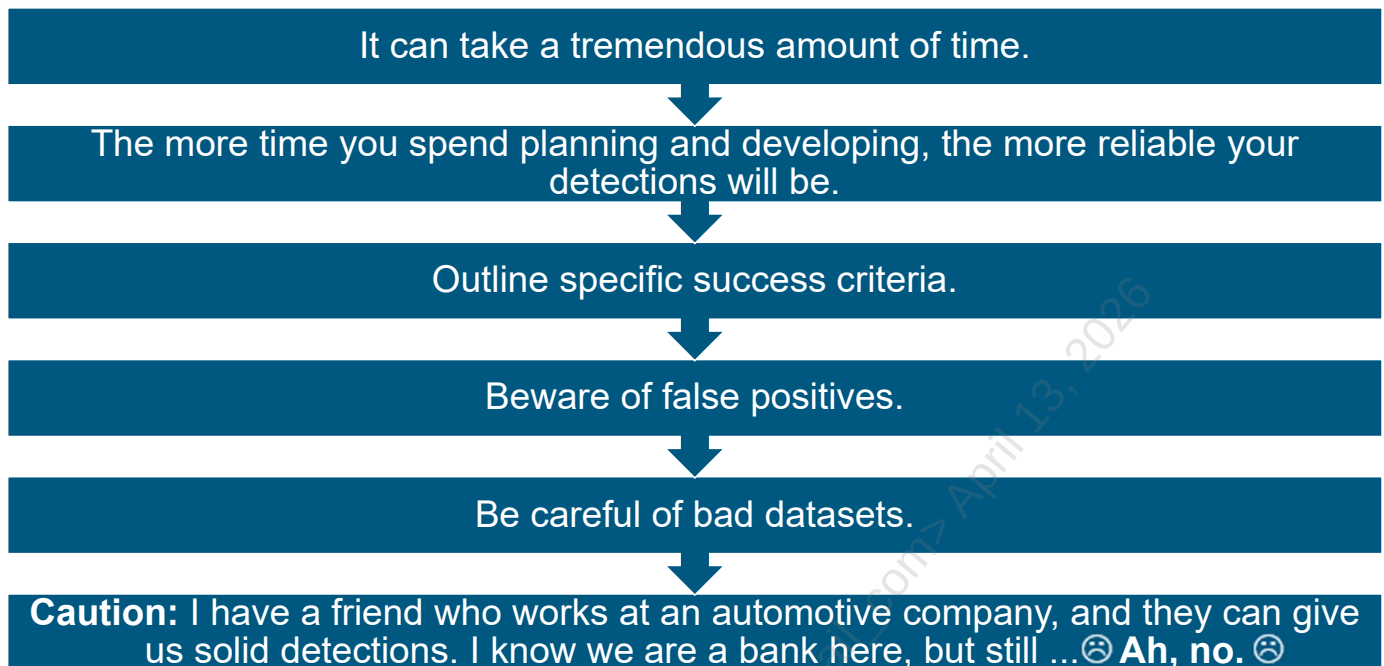
When creating detections, you will use three main indicator types:

1. **Static:** Relates to a specific item that remains static and unaltered. **Examples: File hash, IP address, registry key, URL, email address, or anything similar.** The benefit is that you can quickly create detections for static objects. The downside is that these can change easily, and that will make your detections ineffective.
2. **Statistical:** Relates to some type of metric or statistical representation. For example, assume you have NetFlow data available from your network devices. That can allow you to determine if there are high amounts of traffic to a certain IP address of interest. That, in turn, may indicate possible command and control activity or data being actively exfiltrated.
3. **Behavioral:** These tend to be some of the most valuable detections, but they can be very hard to implement due to their complexity. For example, assume you wanted to create a behavioral rule to find rootkit activity. That might entail things such as checking your logs for unusual system calls (which you need to list in your detection rule), check for system processes of interest (which also need to be listed), check the registry key for certain modifications (you need to list what hives and what modifications), etc. As you can see, this can easily become very complicated.

Remember, security is a balancing act. Static detections may have shorter lifespans, but that doesn't mean they can't work, especially if you require a tactical countermeasure.

Behavioral detections can be quite good, and if tailored properly, can exhibit low amounts of false positive alerts, but they do usually require a lot of time and effort to be created and deployed.

Development



Now that you have everything you need, it's time for development to take place. As mentioned previously, the time to develop detection rules varies but shouldn't be underestimated. You should also think about hitting some roadblocks. For example, you need to parse some fields from a log that aren't available. This should ideally have been identified earlier (during the investigation phase), but it wasn't. Things happen.

But the key takeaway is to spend adequate time planning and executing the earlier phases, so when you reach development, you are ready to just take all of that work you did earlier and put it in a detection rule context.

To develop proper detections, you need to ensure they are in scope and fit for purpose for your datasets. This is why it can be very challenging, down to sheer irresponsible, to use rules taken from other environments. This is a frequent issue with MSSPs. They have a common ruleset they use across their client base. Rules fire for numerous clients and incidents get created and escalated, only to find that 90% of the total clients were frustrated, as this alert gives no value, but in a small percentage (10%), it actually provides good input.

A good detection rule expresses the logic of the environment it is created to work at. No matter how easy it may look, you should generally avoid loading random rules or overinflating your tools with content that you haven't rigorously inspected for suitability first.

Also, when developing new rules, always ask collaborating teams (like the SOC) for additional input. SOC analysts (especially senior ones) can give you great feedback.

Testing

Be careful of your test data. E.g., you just wrote a detection rule for detecting Visa card numbers and you're using this test dataset:

- 3241 5423 4566 7890 -> It's 16 digits but starts with a 3.
- 4578 3546 4878 91454 -> Starts with a 4, but it's 17 digits.

Visa card numbers start with a 4 and are mostly 16 digits.

If testing fails, you will commonly need to go back to development or possibly even to an earlier phase.

Elastic has created a repository of detection rules that can be tested using a Python module and can then be ingested in Kibana.

Datadog has created Threateset for threat detection testing.

Testing is only effective when you have the proper data to use. As an example, you're trying to create a detection rule to identify any Visa cards being exfiltrated from your environment. The number convention for Visa cards states they **start with number 4 and have 16 numbers** (note that some very old ones may have 13, although it's highly unlikely to find them anymore).

You tested your rule for any hits using the following two test data strings and had no alerts:

- **3241 5423 4566 7890**
- **4578 3546 4878 91454**

However, if you look closely, the first string (3241 5423 4566 7890) yields no alert because the leading digit is a 3. So, this isn't considered to be a matching condition.

The second scenario has a card starting with a 4 (which is great) but has 17 digits, not 16, which again generates no alert.

Your rule may be working perfectly fine, but if you don't have the appropriate test data, then you just won't know it.

Elastic has created a repository of detection rules for Elastic SIEM, which can be used for detection use case development, testing, validation, and release.¹

Datadog also has one available for performing end-to-end threat detection.²

When you are testing, look for non-operating rules, potential for considerable false positives, or a chance that the detection can somehow be evaded by the attacker.

1. <https://sec555.com/8xwg7>

2. <https://sec555.com/soa0z>

Deployment

Ready to hit the "go" button and unleash to production. But you can still improve rules by using numerous detection maturity levels.

Experimental: The least ready state. Monitor rule output closely for errors, issues, false positives, and general misfiring and adjust accordingly.

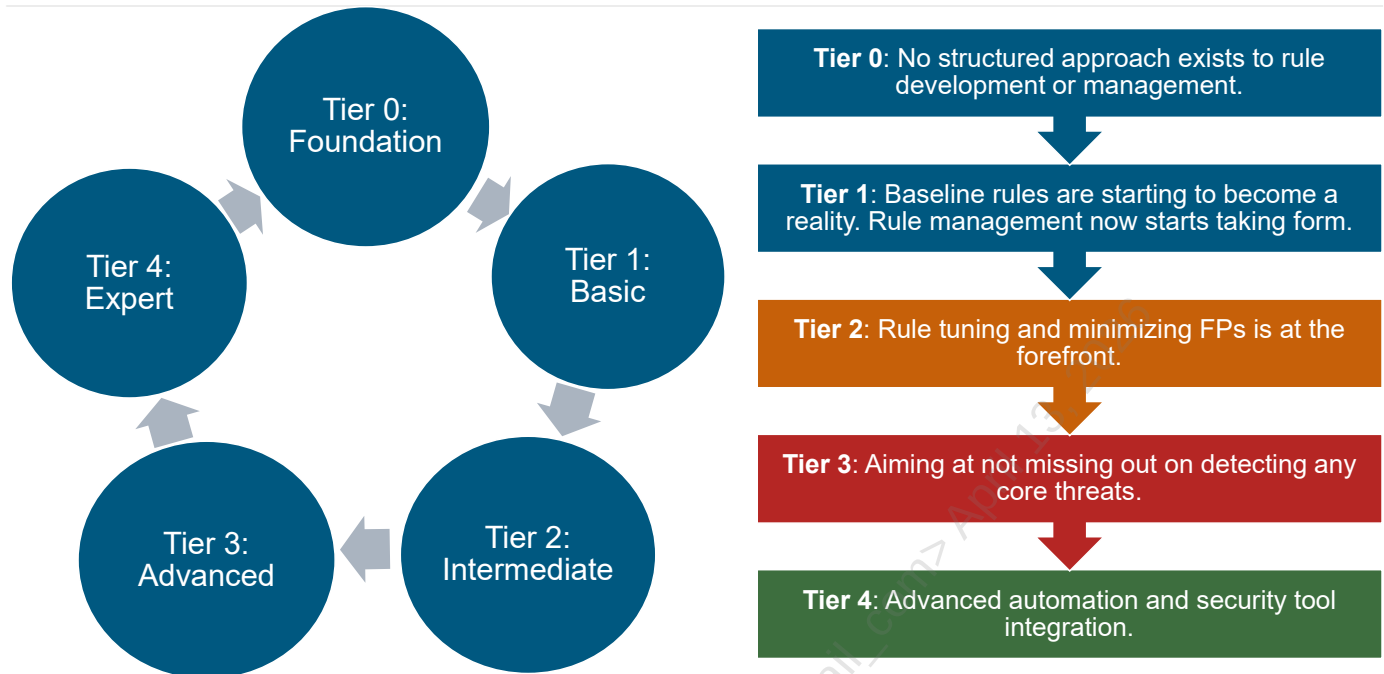
Test: You passed the experimental phase, and more people are now ready to use your rule. However, you still need to check for false positives and reliability.

Production: To the best of your knowledge, this works as expected. You still want to get feedback from your operational teams, but you should be good by now.

When deploying rules, it's very useful to define certain descriptions or tags, so everyone can understand how solid the rules are. Ideally, you want to have at least three:

1. **Experimental:** Obviously, for the rule to reach deployment, you just went through a test phase earlier. But that doesn't mean the rule has been present in a production or even pre-production environment and rigorously tested there (e.g., for a year) with actual production conditions and data. The author would commonly flag brand new rules as experimental and put content in the production environment to monitor efficacy. If there's a pre-production environment, that would be ideal as it can be used with zero concerns.
2. **Test:** After the person creating the rule is confident the experimental phase is done, they would now tag it as a test rule. Again, if there's a pre-production environment, then this rule can be adopted there to flesh out any additional tuning it may require. If not, and it ends up in production, then analysts know it's a test rule so they can treat it accordingly, meaning take the findings with a pinch of salt.
3. **Production:** After the previous phases are concluded, the rule is ready to be fully used. It's now tagged as a production rule, and it can be freely used by the operational team. It's important to highlight, however, that you still need to be collecting metrics and reporting from these rules. Just because rules are working doesn't mean they never require tuning or updating. This is a continuous effort, and you always have to instill this principle in the operational teams. Each time they think there's potential for improvement, they have to raise it so it can be pursued.

Maturity Assessment



Elastic's **DEBMM (Detection Engineering Behavior Maturity Model)**¹ is presented on this page and has been created to complement other industry frameworks, like:

1. **HMM (Hunting Maturity Model)**:² DEBMM adds value by making threat hunting be actively considered, while performing rule development.
2. **CSF (Cyber Security Framework)**:³ DEBMM aligns with the CSF principles, using the NIST maturity levels. It adds to the Detect function by providing an option that enhances the maturity of the developed ruleset.
3. **MITRE ATT&CK framework** (mentioned earlier): DEBMM, the creation of rules and continuous tuning, aligning with MITRE TTPs.
4. **ISO/IEC 27001**:⁴ DEBMM adds to the Detect and Respond control domains by supporting continuous content improvement as per the ISO ISMS (Information Security Management System).
5. **SIM3 v2 (Security Incident Management Maturity Model)**:⁵ DEBMM adds structure to incident management rule content, and enhances procedure documentation and constant improvement.
6. **Detection Engineering Maturity Matrix**:⁶ DEBMM focuses on detection engineering behavioral criteria and process improvement.

DEBMM is comprised of five levels:

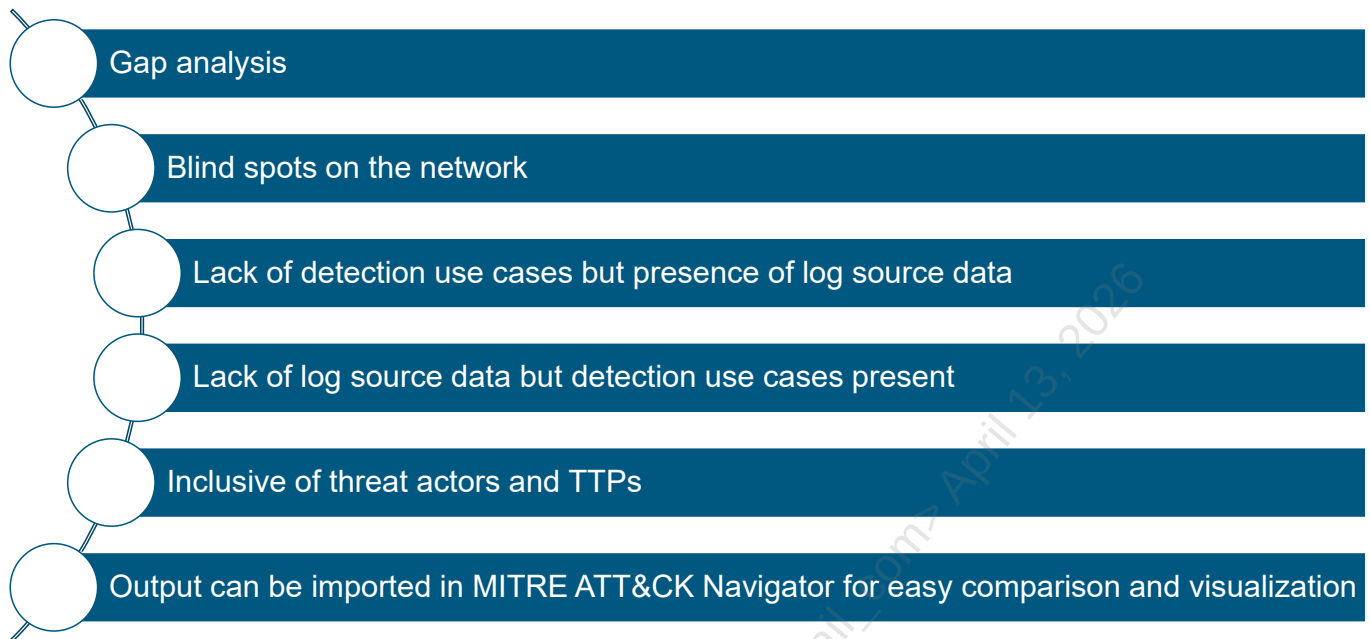
- **Tier 0: Foundation:** There is no structured approach to developing rules or managing development. Only ad-hoc rule development exists, with basic documentation, interaction with the business, and staff training plans.
- **Tier 1: Basic:** Baseline rules are starting to become a reality, and rule management now starts taking form (including version control, documenting rules, and performing frequent reviews of the attack surface). Staff training also starts taking form, although at a basic level.
- **Tier 2: Intermediate:** The focal point is on frequent rule tuning, to minimize false positives, while finding detection gaps. In-depth testing and validation are also now performed, and staff training and development have become a structured item. **This expresses your minimum viable state.**

- **Tier 3: Advanced:** In-depth assessment of the environment, to ensure core threats are not missed while also covering advanced TTPs and performing in-depth training for analysts and security personnel.
- **Tier 4: Expert:** A distinguishing item here is advanced automation and integration with numerous security tools, existing in the environment. Regular updates and cooperation with external entities are present, security staff at all levels now start receiving comprehensive and custom-tailored training. A proactive detection mindset exists, without waiting for attackers to breach the environment and then create rules.

Each tier outlines specific criteria that need to be met before advancing to the next one. Those relate to rule creation and management, log source health and quality, stakeholder interaction, and many more. The more progress is made to reach the expert tier, the more investment is required in time, resources, effort, skill, and activities that need to be performed.

1. <https://sec555.com/2tnhp>
2. <https://sec555.com/tn2md>
3. <https://sec555.com/573ng>
4. <https://sec555.com/u95af>
5. <https://sec555.com/fzl5h>
6. <https://sec555.com/mwv3l>

Case Study: MITRE DeTT&CT



MITRE DeTT&CT is a great tool that can be used by security operation teams:

- Used to assess their detection coverage across the environment
- Output format is JSON, and it can work very well with Sigma, ATT&CK Navigator, and Caldera
- Supports CI/CD integration
- Identifies detection gaps
- Allows prioritization of new detection content or update of existing

Choosing an MSSP

Define Scope and Objectives

Draft
RFP

Evaluation

Selection

Onboarding

You might wonder why go into more detail about choosing an MSSP. Well, detection engineering is usually heavily engaged (or at least it should be) with any effort to choose an external entity, which will be using their content or possibly creating content side-by-side with them. To get the ball rolling, follow these phases:

1. **Define scope and objectives**
2. **Draft an RFP (Request for Proposal)**
3. **MSSP evaluation**
4. **Selection**
5. **Onboarding**

Let's dive into these in detail.

Choosing an MSSP: Define Scope and Objectives

Identify organizational needs

Determine what services you need

- SIEM design/setup/deployment/maintenance?
- Content creation/evaluation/both/none?
- Threat hunting/SOC analysis/more?

Pinpoint your log retention policies

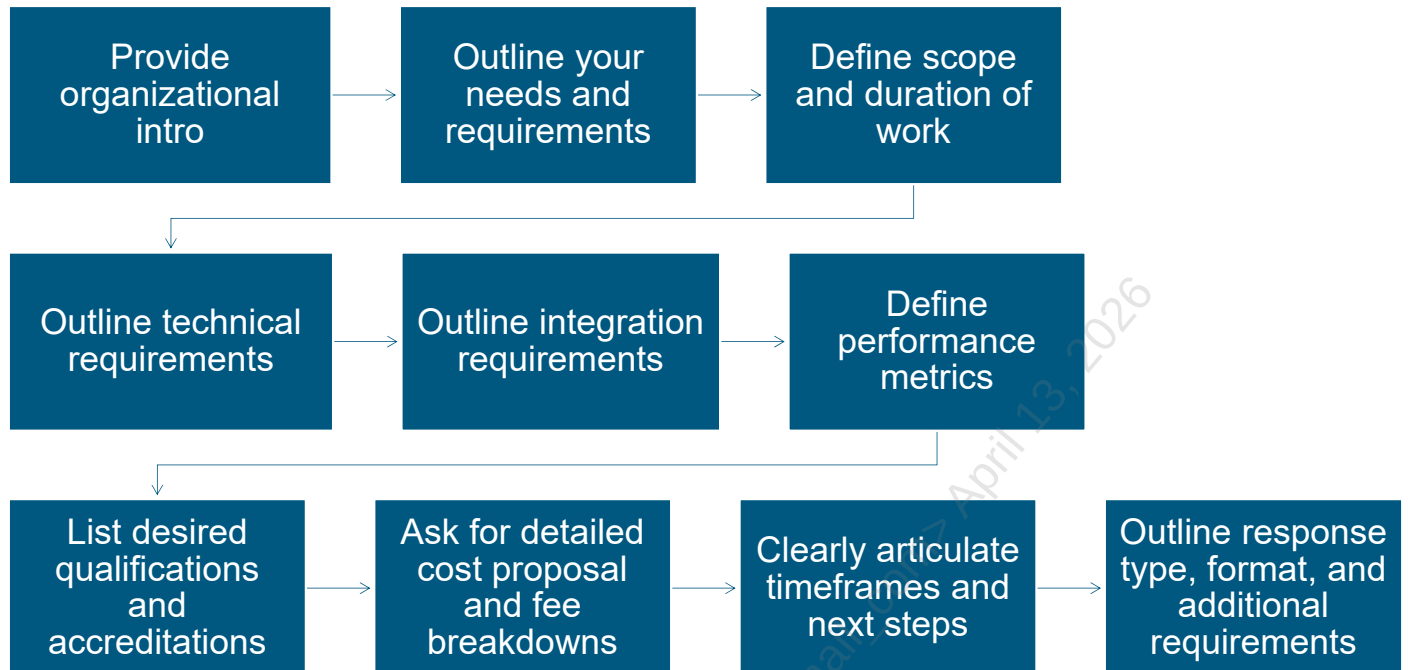
Identify compliance requirements

- External regulators
- Company and client requirements

Negotiate and set specific SLAs that will need to be strictly adhered to

1. **What does your company really need?** Do you need an external MSSP to enhance your internal function, or do you need someone that you can outsource the function(s) to, and your team just provides management and oversight?
2. **What level of services do you require?** For example, do you need the MSSP to provide SIEM architectural design, setup, and deployment, create detections that you evaluate, or handle the overall process? Do you require additional services from them, like threat hunting, malware analysis, incident response, digital forensics, etc?
3. **What are your log retention policies?** In an era of heavy privacy and compliance regulations, this is a very crucial item. If you don't have specific retention policies, it would be a great idea to start working toward them and provide that information to your MSSP. You also need to understand how those retention timeframes will be adhered to.
4. **What are your compliance requirements?** In a small company, it's very easy to identify that because you would ask John or Sarah, who are responsible for these in the two locations where the company has presence. But what about a global corporation, present in 50 locations around the world, with more than 50,000 or 250,000 employees?
Also, don't forget your client compliance requirements. Maybe some of your clients require you to be ISO27001 accredited in order to engage in business. Well, if you're not, you either become compliant and accredited or miss out on client engagements.
5. **Set appropriate SLAs:** This is one of the most critical items on the list. Providers will always push back on SLAs. Say you want your initial response time for critical incidents to be 10 minutes, which means you need to know about a critical incident within 10 minutes of it being identified. They say it can be no less than 20 minutes. What do you do? Push back as much as you need to get the job done. Ultimately, it's about how comfortable you feel about the SLAs you agree upon, and be very careful because these then become contractual obligations that both parties agree to.

Choosing an MSSP: Drafting an RFP



Finding a successful MSSP to partner with depends on how strong your RFP (Request for Proposal) document is. What are the key items to consider?

1. **Provide an organizational introduction so the provider understands your business:** When you give the prospective provider more information, they can provide a more accurate and custom-tailored solution. In general, the more detail you feel comfortable about providing, you should do so. You can't blame them for being overly generic and vague if you don't really give them anything, can you?
2. **Outline your needs and requirements:** Explain in detail what you expect the provider to be able to do for you. Again, be very descriptive and ensure they have full understanding. For instance, if you expect them to do behavioral analysis or apply big data analytics techniques to a large dataset you have in your organization which is in an AWS data lake, then you really need to outline that so they can articulate if it's doable or not, and how they would implement it for you.
3. **Define scope and duration of work:** Provide a full list of what you expect the scope of the project to be, so the provider can explain if they can meet it, and also any timeframes for implementation. Also, explain how long you need the engagement to last (e.g., one-year contract, five years, etc).
4. **Outline technical requirements:** Be very specific about technical aspects, and if need be, make the providers sign an NDA (Non-Disclosure Agreement) so you are certain that your information will never be disclosed without authorization. Technical requirements not being met or being very vague, leaving room to interpretation, are common failure points in projects.
5. **Outline integration requirements:** Anything you need them to do, put it on the line. For example, say you need them to migrate your current SIEM solution to a new one and you need to keep all your use cases. Can they do that? How?
6. **Define performance metrics:** This should be a catch-all for any metrics you desire. Examples include initial response, average time to resolve incidents, average time to escalate resolution to next layer of analyst, responding to incidents based on criticality, and many more.
7. **List desired qualifications and accreditations:** For example, maybe you need all their analysts to be

GIAC GCIH certified while their detection engineers are GIAC GCDA certified. Perhaps you require their SOC to also be compliant with certain standards.

8. **Ask for detailed cost proposal and fee breakdowns:** This is all about knowing what the bottom line is. Sometimes, costs can be deliberately buried behind smoke and mirrors, making it too late for you to back out of a contract. **True story from the trenches, experienced by the author:**

On a sunny morning, we needed to obtain logs for a client, going back six months. They had an external MSSP who was handling their SIEM tool and all that went with it. The contract stated one year of a retention period. **But.** The fine print stated two months hot data (so, immediately available) and ten months of cold data (meaning it had to be pulled back from archival). Why was that a problem? Each pull the client did could only go back two months. They only had two pulls per month. So, how can you go back six months, if you only have two pulls (with two months of data per pull)? It's then mid-month—what do you do? Wait until the end, you say? Well, the provider only gave them one week of access to the dataset before putting it back in cold storage. Come on, that's fun, right?

9. **Clearly articulate timeframes and next steps:** Be very specific about timeframes. For example: RFP submission date, date to provide an RFP response from your side, deadline for vendors to submit questions, response to vendor questions from your side, final submission deadline, date of final decision to be made and announced.
10. **Outline response type, format, and additional requirements:** For example, who should the RFP response be sent to if you need it in PDF? If they need to provide any additional documentation, how should their response be structured? Do you require any copies of consultant CVs? In general, this is a section for you to voice out what you need the vendors to provide to make a sound decision.

Choosing an MSSP: Evaluation: Questions to Ask (1)

How long have you been doing this for?

What services do you provide?

Can we do a one-month Proof of Concept?

Can you provide client referrals?

Why should we choose you?

What experience and credentials do your analysts have?

Can you share your metrics (e.g., initial response, mean time to resolve, etc.)?

Does your SOC have any compliance accreditations?

Have you suffered any breached in the last five years?

What threat intelligence sources do you use?

The following two pages contain several questions you should consider asking any prospective MSSP. This list could be 3 pages long or 10. It all depends on:

- What type of organization are you (small-medium-large)?
- What sector do you have activities within (some sectors are heavily regulated, like banking, which commonly means you have more questions and boxes to tick)?
- What is your risk appetite?
- What's your current maturity level?
- What is your current security capability?
- What are your aspirations, goals, objectives, and key milestones?

Let's look at a few example questions from the list.

1. **"Why should we choose you?"** You are giving the vendor an opportunity to differentiate itself from anyone else in the market. If they can't answer this in a satisfactory manner, you need to think twice about doing business with them.
2. **"What experience and credentials do your analysts have?"** This will give you an understanding as to what type of experience their operators have, but will also drill down on the desire of the prospective MSSP to invest in personnel and give them the skills they require to get the job done. This is a very loaded question, although it might not seem like it.
3. **"What threat intelligence sources do you use?"** You're trying to work out if they just get the occasional free OSINT (open-source intelligence) or if they have an actual threat intelligence program they use, so you can benefit from it.

Choosing an MSSP: Evaluation: Questions to Ask (2)

Explain how you perform alert tuning.

Describe how your analysts investigate and escalate incidents.

Do I need a SIEM already or not?

How do you collect logs from my environment?

What happens if log sources fail to report?

What happens if an incident takes place out of hours/on public holiday?

How do you cope with limited environmental knowledge during investigations?

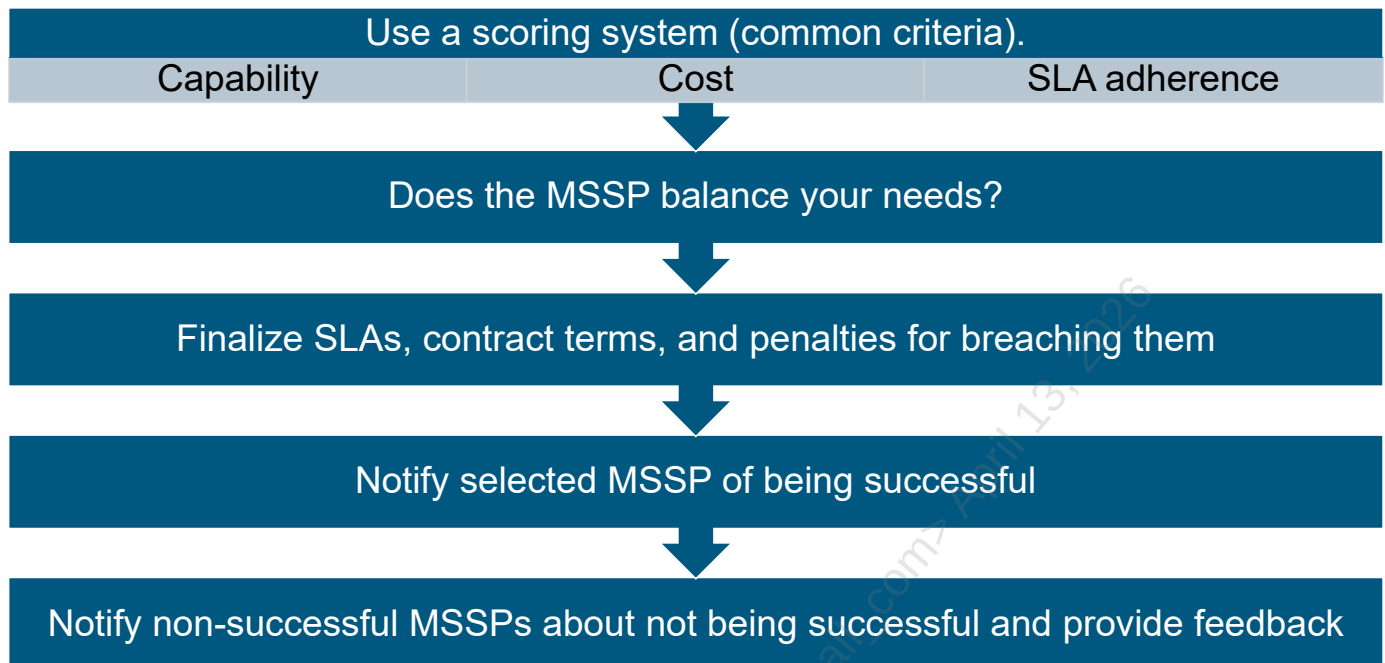
Do you use an official framework, like the MITRE ATT&CK model?

Can you provide sample escalation communications and incident reports?

Where does data reside? How does it get destroyed after retention period lapses?

4. **"Explain how you perform alert tuning."** This is one of the author's favourite questions. Doing this for two decades, makes you hear a lot of answers. The way your MSSP tunes their alerts can be very impacting. Once, when managing a SOC team, calls kept coming in about ICMP traffic internal to the environment. Another time it was externally facing devices being scanned. The point: Rules should be tweaked very much to reflect what you need for your environment.
5. **"How do you collect logs from my environment?"** This will give you an understanding of what level of access your provider requires and what lengths you need to go to for this to happen. In general, remember that *the principle of least privilege saves lives*. Give them minimal access, if possible. But don't sweep the rug under their feet; meaning, don't block their access to the extent of them not being able to validate alerts, so they become the first line help desk.
6. **"Do you use an official framework, like the MITRE ATT&CK model?"** You are reviewing two things here:
 - **The provider's maturity level.** If they have been around the block, they would most likely have been using an official model for intrusion analysis purposes.
 - **The ability to bind with your tools.** Assuming you also use one of these models in your environment, it would be ideal for your provider to be using it, so you speak the same language. How awesome would it be for both of you to be using, for example, MITRE's ATT&CK model, and each time they escalate an incident to you, it has a direct mapping in your environment? It can save you a lot of time. If that's not the case, prepare to embark on a journey of mapping incidents across different frameworks, and quite possibly different tools.

Choosing an MSSP: Selection



It's time to make your final selection. Some criteria of note can include the candidate MSSP's capability to perform what you need and how much that costs you. If you combine that with them meeting the SLAs you outlined previously, it can make a great combination for success.

Of course, usually not every box is ticked, and we have to make some compromises. It's all about balancing things out. But don't compromise too much to the point where you're not getting what you need. At the end of the day, you're still the paying client. If none of the candidates meet the bar, then reject them all and restart the process.

Is that time-consuming? Yes, it can be.

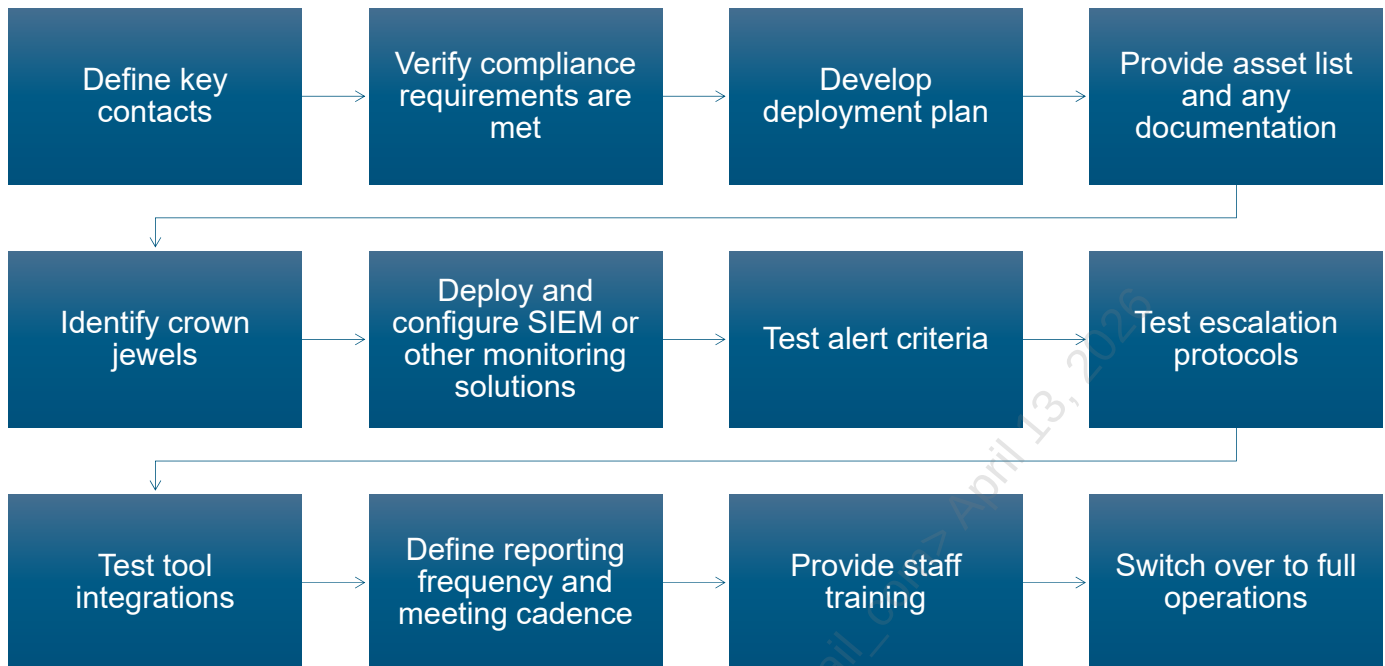
But wouldn't you rather invest time now to do it properly than invest much more later, still doing it again, and possibly miss out on a critical incident in the meantime?

When all is said and done, let the successful candidate know they have been selected, and all the other ones know they weren't.

It's advisable to provide them with solid feedback about why that is. You never know when things change, and you need to re-engage with someone because they have a better tool, awesome analysts, better processes, or a combination of the above. Having a great experience all around is important. Don't make them feel you wasted their time and now they have no idea why they didn't succeed.

This is like interviewing for a position. You remember further back in your career, when you were applying for jobs, possibly doing four stages of interviews, only to hear nothing at the end? Or maybe you were more fortunate to get the generic boiler plate email response stating that there were other candidates that were better. Not a great experience, is it?

Choosing an MSSP: Onboarding



1. **Define key contacts:** Usually, members of the SOC team, like the SOC lead, manager, and senior analysts, are good candidates for this.
2. **Verify compliance requirements are met:** What happens if you have a compliance requirement to monitor your environment 24×7×365, but you're only doing that during the working week, so you're actually doing 24×5×365? Oops.
3. **Develop deployment plan:** You would usually perform a phased deployment with critical devices being enrolled first and then others following in different phases.
4. **Provide asset list and any documentation:** The more detail you can provide the MSSP, the better, faster, and easier the implementation becomes.
5. **Identify crown jewels:** What are the most important items in your environment? Is it critical servers carrying client data? Perhaps the R&D (Research and Development) cluster, because you are a big pharmaceutical?
6. **Deploy and configure SIEM or other monitoring solutions:** After all the above have been provided, it's time to start working on the monitoring solution deployment. Most commonly these days, this would be a SIEM tool of choice.
7. **Test alert criteria:** After the solution is deployed, does it provide proper and solid alerts?
8. **Test escalation protocols:** When a critical security incident is identified, who gets a call from the MSSP? What if it's Christmas?
9. **Test tool integrations:** Any possible integration with your environment should now be tested. Examples include vulnerability scanners, incident response, and ticketing tools.
10. **Define reporting frequency and meeting cadence:** Common intervals are weekly, monthly, quarterly, and annually.
11. **Provide staff training:** Employees of all levels should be trained to meet operational needs. I.e. , certain levels of analysts could attend specific SANS courses, aiding in their roles.
12. **Switch over to full operations:** The service is now ready to fully go live.

Summary

Having a separate Detection Engineering function in the environment can ensure you stay ahead of modern attackers. Having a pre-defined detection content life cycle will allow you to streamline operations and promote healthy rule creation.

If you need immediate results, focus on static rules. If you want increased quality, aim for behavioral. Aim to grow your detection maturity at tier 3 (not missing out on any core threat being detected) as soon as possible to facilitate early attack detection and risk remediation.

This area is intentionally left blank.

DeTT&CT & Data Source Gap Analysis

Refer to the lab workbook for instructions.

This area is intentionally left blank.

Course Roadmap

Section 1: Detection Engineering and SIEM Architecture

Section 2: Network and Endpoint Analysis

Section 3: Asset Discovery, Baselines, and UEBA

Section 4: Cloud Logging and Monitoring

Section 5: Alerting and Detection Engineering Pipelines

- SIEM Introduction
 - ☐ Lab 1.0: Lab Setup
- Detection Engineering Life Cycle and SIEM Planning
 - ☐ Lab 1.1: DeTT&CT & Data Source Gap Analysis
- Creating a Detection Lab
 - ☐ Lab 1.2: Luring the Attacker with a Honeypot
- Log Collection and Enrichment
 - ☐ Lab 1.3: Introduction to the SIEM Components
- Log Aggregation, Parsing, and Analysis
 - ☐ Lab 1.4: Using AbuseIPDB for Data Enrichment

This area is intentionally left blank.

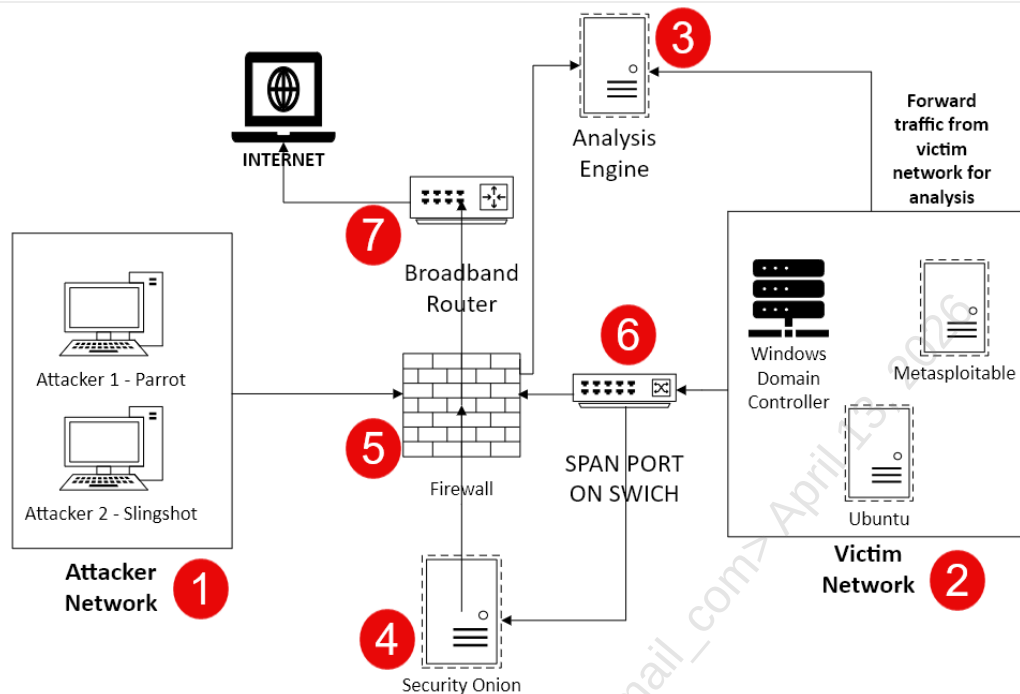
Module Objectives



The student will obtain an understanding of what critical elements should be included in a detection engineering lab (from home-brewed to corporate grade).

This area is intentionally left blank.

A Simple Lab



A lab fitting your purposes doesn't need to be expensive. Let's start small. The topology presented here would be a sample of a homebrewed lab which can easily be used in a corporate environment by increasing the number of devices you have. What do you need?

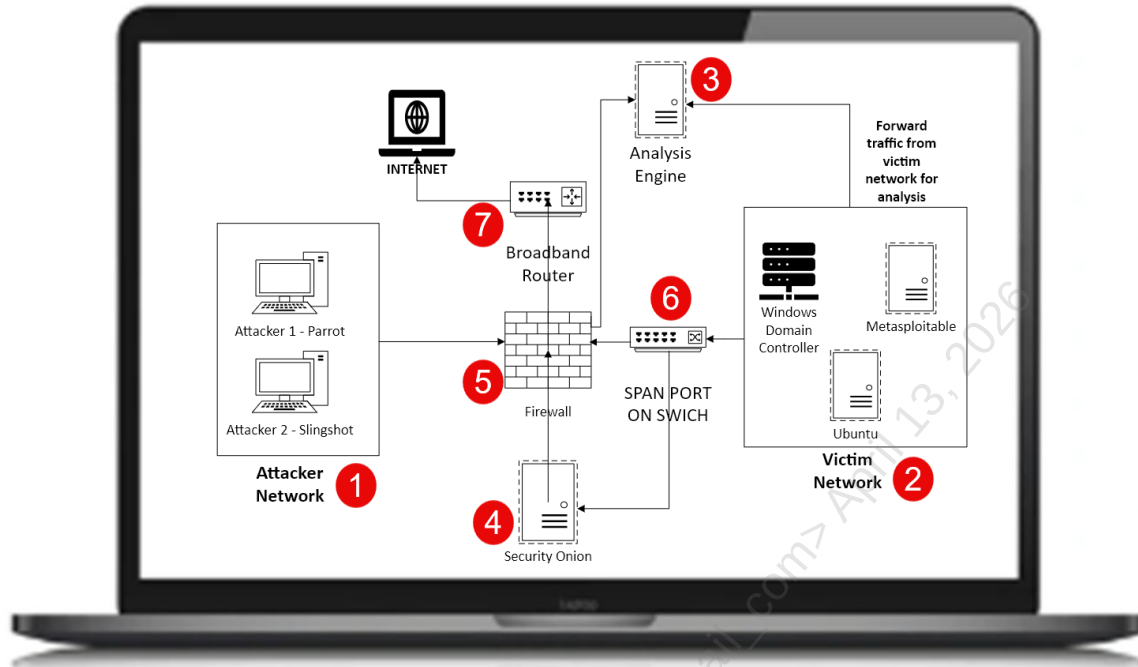
1. **Attacker network:** This can be one or more machines, running one or more operating systems (like **Parrot**¹ or **Slingshot**²). Think about real life and try to simulate as many of these as possible, even mobile devices or tablets, especially if you are testing web applications.
2. **Victim network:** Again, you could be looking at a minimal setup where you throw in one or more Windows domain controllers, and you enrich a bit and start adding vulnerable machines by design (like a **Metasploitable 2** or **Metasploitable 3** machine³), or other specifically crafted images (like an older image of a **Windows 2016 server**) and more. Note that you can download Windows server⁴ and client⁵ evaluation versions for free, as long as you adhere to their terms and conditions.
3. **Analysis engine:** Think something along the lines of **ELK**⁶ (mentioned in more detail later), **Wazuh**,⁷ **Splunk**,⁸ **OSSEC**,⁹ or a similar tool. The goal here is to obtain log data from your victim network, which you will forward to that machine, in addition to traffic from other devices, like your firewall, proxy, IPS, or anything else you want to add into the mix. In the above example, a simplified version is shown (with only the victim network and the firewall feeding into the engine), but you can start scaling up as much as you like.
4. **Security Onion:**¹⁰ This is like an all-in-one solution. It contains signature-based detections via Suricata, file extraction and metadata via Zeek and Suricata, full packet capture via Stenographer, features osquery to perform live queries, and can be centrally managed using Elastic Fleet, if you require host visibility.
5. **Firewall:** If you prefer not to invest in a commercial solution, you can always get something like a **Pfsense**¹¹ firewall, which is open-source and will do the trick just fine. You just need to set up some basic rules and have firewall logs available, which you can then interrogate.
6. **Switch:** You can get a simple device, provided it has a SPAN port, which you can use to mirror traffic to Security Onion. Ideally, add VLAN support to allow you to perform a more robust configuration.

7. **Router:** As with the switch, you don't necessarily need something fancy. As long as it can perform basic routing and provide a solid administrative interface, you are all set. Now that's assuming you don't require the composite option of a corporate level kit, like what a Cisco router may provide.

When you are looking for hardware, always remember that you don't have to buy everything brand new. You can always buy used equipment in surprisingly good condition from locations such as eBay.¹²

1. <https://sec555.com/4ej6u>
2. <https://sec555.com/1r4to>
3. <https://sec555.com/37kvp>
4. <https://sec555.com/odf3v>
5. <https://sec555.com/ru0a9>
6. <https://sec555.com/m4ks6>
7. <https://sec555.com/zcquel>
8. <https://sec555.com/wtj6m>
9. <https://sec555.com/un1q2>
10. <https://sec555.com/3krda>
11. <https://sec555.com/hrwoa>
12. <https://sec555.com/s6umr>

How About Going Virtual?



You bet you can go virtual. You can take all those components from the previous page and place them on virtualized infrastructure. First, choose your hypervisor engine: a few common examples are VMware (VSphere or Workstation Pro, unless you use ESXi, which is the enterprise-level option),¹ Oracle VirtualBox,² and Proxmox.³

The easiest way to move forward, after you select your hypervisor, is to then start downloading .ISO images for the pre-mentioned products and building up the necessary VMs. But the challenge here is that you will require some considerable horsepower, meaning that the actual hardware that will be used to run all these virtual machines needs to be robust. For example, think gaming level and upwards to get the picture.

Give it as much CPU (cores and processors), RAM, disk space, and overall high specification as you can financially tolerate to get great results. And again, remember, if you have financial restrictions in mind, you can use equipment that is sold as used, as long as it's in good condition to get the job done.

You can also mix and match, meaning split a few of these virtual machines on one physical hardware and a few on another, just to split the load. But that's all dependent on how many virtual machines you have and how demanding your monitoring is.

You might choose to get some actual servers or really powerful laptops/desktops, or even go with a solution like a NUC (Next Unit of Computing), which can be very small and yet fairly powerful. It's just about what you see as the best fit for your lab.

1. <https://sec555.com/3mc0k>
2. <https://sec555.com/uc1iy>
3. <https://sec555.com/a74fi>

Adding a Few Vulnerable Targets

TurnKey has various Linux images with pre-installed components, all packaged in a VM

Example: You want to test some Drupal vulnerabilities, so you download the Drupal virtual machine, and you're all set to target it, after deployment

You can even find really old versions. If you're spinning up a test lab, that can be very useful, especially if you're using some of these in production

VulnHub offers numerous vulnerable VMs that you can download

SecGen has a project available, allowing the creation of random vulnerable virtual machines, as part of a range or a CTF challenge or general learning and development

Do you want to convert this to a forensic acquisition lab? Just grab the .vmem file (after pausing the virtual machines) and review it with any memory forensics tool

There are numerous ways that you can add vulnerable targets to your environment, from creating your own (more time consuming) to getting a few that are already available.

- **TurnKey Linux**¹ has numerous Linux images with pre-installed components, which are already packaged in VMs. You simply download the VM and you're good to go. The point here is, if you want to get, say, logs from a certain service, you don't have to waste time configuring and deploying. You simply search for that service (e.g., Drupal) and then you download the already-packaged VM that contains it. These are not made vulnerable, but the point here is to get an understanding of how the candidate logs can be used for your detections. After that, anything can be made vulnerable. In fact, you can always download older VMs, which are bound to have vulnerable services.²
- **VulnHub**³ actually has numerous vulnerable-by-design VMs, which you can obtain and deploy at will in your environment. These can be used for extensive testing and detection creation.
- **SecGen**⁴ offers another great option where it supports the creation and spin-up of VMs, which get built up and deployed in your selected environment, but all contain random vulnerabilities.
- Convert to a forensics lab, you say? Easily doable. Power off the VM(s) and grab a copy of the .vmem file (holding the VM's memory contents) and have forensic analysts go to town with their favorite memory analysis tools.

1. <https://sec555.com/w6ra7>

2. <https://sec555.com/8qwoy>

3. <https://sec555.com/zsgti>

4. <https://sec555.com/ti5yx>

Honeypots

Create a honeypot in your detection lab, aiming to entice attackers.

- A virtual honeypot waits for *unknown* sources of access
- Attacker connects to the honeypot and gets caught

Honeypots have matured.

- Centrally manageable
- Easily log to SIEM



Connect honeypots together and make a honeynet. Now, isn't this a sweet network?

A detection-based honeypot is a piece of software that is not intended to be accessed, but when it is, it generates alerts. If you want to resemble an actual production network, you can connect multiple honeypots together and create what is known as a honeynet. You can have as many servers and services as you require in order for this to resemble a corporate network. The logic is to lure the attacker into this network, and allow them to exploit its deliberately existing vulnerabilities, to collect those great logs and funnel them in detection creation. That will save your real environment from experiencing these attacks. This may seem like a very appealing idea, but do note that you need to ensure someone's actually taking a look at the honeypot/honeynet's activity and also takes that valuable input and transforms it into actionable detections. If you don't have the resources to do that, then you should think twice about deploying these until you do.

You will find a very comprehensive list of honeypots in existence, and it all depends on what you want to achieve.¹ For example:

- **Cowrie:**² Medium interaction honeypot, which is designed to log SSH brute force attacks.
- **T-Pot:**³ Runs numerous honeypots that you can manage and uses Kibana for visualization.
- **Honeypots:**⁴ Contains 30 low to high-level honeypots in a single package for monitoring network traffic. Includes FTP, DNS, HTTP, HTTPS, SSH, Telnet, SNMP, and many more.

1. <https://sec555.com/a4dbp>
2. <https://sec555.com/plzc8>
3. <https://sec555.com/1h9nq>
4. <https://sec555.com/aibzk>

Honeypot Types

High Interaction: Research

Real systems intended to be attacked and studied

High level of interaction

- Logs everything
- Full interaction with attacker

Intended for research purposes

Low Interaction: Virtual

Software emulation, used for:

- Early detection
- Distracting attackers

Limited interaction

- With basic logging

Intended for detection purposes

Original honeypots were research honeypots (high interaction). These were intentionally vulnerable systems that were intended to be compromised. These honeypot systems were full-blown operating systems set up with additional logging. In some cases, they even went as far as to intentionally apply a benevolent rootkit so that attackers were unaware that they were on a honeypot. The main controversy around these systems is that they can be compromised and used to attack other systems. Also, they tended to be set up by defenders who could better spend their time increasing defenses internally. These research honeypots are still used today, but primarily by security vendors studying and learning how to prevent or detect new attacks and malware.

Virtual honeypots, also known as low-interaction honeypots, are software-based programs that emulate connections. For instance, an attacker could port scan a virtual honeypot, and the software would emulate real services to make it look real for the attacker. These are designed for low interaction, so attackers can't compromise the systems and attack others. The reason for some interaction rather than none is that it slows down attackers from targeting real systems, while providing early detection. These types of honeypots also require less time to configure and administer. The amount of time that would be spent on housekeeping can now be spent analyzing logs, creating detections, and generally in more constructive ways.

Using a Host-Based Firewall for Detection

A host-based firewall can be used instead of a honeypot

- Deploy a system (Windows or Linux, preferably a VM)
- Lock it down and minimize footprint
- Set up host-based firewall

Example ruleset

- Allow authorized scanners and management (no logging)
- Block common ports such as 80, 137–139, 443, 445 (**log all**)
- Default deny (no logging)

If you don't want to go to the length of configuring and deploying a honeypot in your environment, you can achieve similar detection by using a dedicated system with a host-based firewall. Follow these steps:

1. Set up a Linux system using iptables or a Windows machine using the Windows Defender firewall.
2. Configure the firewall to ignore all traffic from:
 - Authorized company vulnerability scanners.
 - Any other authorized system that scans the network.
3. Log all access attempts to common ports.
4. Don't log any hits to the default deny rule at the bottom of the ruleset.

Because of this design, any system that scans the network will cause a log to be generated, thus providing early detection.

This works well, especially if you care less about distraction and more about finding out when something unauthorized is happening. A recommendation, if doing this, is to change SSH from the default TCP port 22 to another operating port, so that traffic to TCP port 22 can be logged.

Honeytokens

Data exfiltration is a sure sign you have been compromised

- Data Loss Prevention is a great way to catch/block this
- But it can be expensive, complex, and hard to maintain

Everyone without DLP can use honeytokens

- A honeytoken is fake (a.k.a. decoy) data meant for an attacker to steal
- Honeytoken activity is then monitored

Example: Project Black Widow IV

Cliff Stoll wrote a book based on his early exploits in catching computer espionage back when detection capabilities were fairly nonexistent. He named this book *The Cuckoo's Egg*.¹ In it, he was convinced that someone was hacking into his network, and he was determined to catch them. A technique he ultimately used was to implement a fake person he named Barbara. Barbara was designed to see if anyone would try to interact with her. This type of fake data is called a honeytoken and can be used virtually anywhere.

The trick is to create fake data that is unique. John Smith may not make a good honeytoken as the name is common. Keep in mind, honeytokens are not restricted to names. It could be a fake Social Security number, an ID record in a database, or anything that is not supposed to be used or accessed.

Why use them?

1. **Early threat detection:** You can see attacker activity on fake data before they actually do something malicious, leveraging your corporate assets and information.
2. **Low false positive rates:** You're not expecting legitimate users from your environment to interact with honeytokens, meaning any activity associated with them is most likely indicative of an attacker.
3. **Minimal resource cost:** Setting up a fake file and monitoring for it costs you nothing. Definitely easy to set up and maintain.
4. **TTP insight:** Similar to a honeypot, they can offer tremendous value to attacker tactics, techniques, and procedures.
5. **Delay attackers:** Attackers may end up spending valuable time and effort making sense of your decoy data, which may keep them away from your actual valuable datasets.

1. <https://sec555.com/vmjkl>

Using Honeytokens Against OSINT

Fake users can be created publicly to combat recon

- Could be just in hidden metadata and/or key public sites

Example: Jane Macie (jmacie@sec555.com)

- On LinkedIn, Facebook, GitHub, etc.
- Likely to be picked up during OSINT
- May eventually make compromised account lists

Activity from this account is malicious and provides context

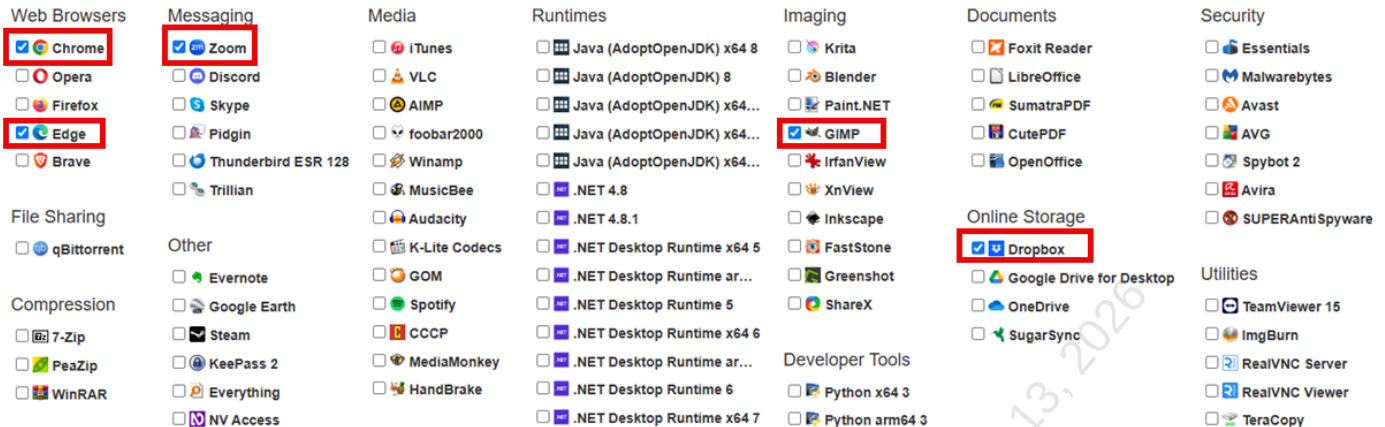
In the case of OSINT, fake users can be created on the internet. This involves creating a valid email account and then signing up for public sites using this account. If you really want to get crazy, give them a full bio and sign up for as many common sites as possible. Focus on key sites and services used with OSINT, such as PGP key sites.

One of the accounts may eventually be compromised if one of the public sites it is registered on gets breached. This would provide even higher chances of detecting adversaries trying to break in with the honeytoken account.

In this case, the fake user should never generate logs. For example, login attempts to public mail access or VPNs using this account should never be present. If they are, it is because someone performed reconnaissance and found the account and is now trying to use it to target your organization.

If you like this technique, consider setting up developer accounts and fake code on forums. This is another common attack vector, especially for web applications. Consider the same for code repositories (e.g., GitHub or other ones that you may use). Essentially, you would be making the attackers think they have legitimate credentials or code fragments that they can use against you. But they really don't.

Ninite: Installing Multiple Applications



Download and run your custom installer/updater

Get Your Ninite

Ninite works on Windows 11, 10, 8.x, 7, and equivalent Server versions.

When you're configuring your different Windows VMs (or even actual machines), you often find yourself in a situation where you need to install some basic software and you don't want to go through the hassle of installing items from scratch. Ninite¹ can solve this challenge for you. In fact, the Pro version allows you to manage multiple machines (to which you will install the Ninite agent) over a web interface.

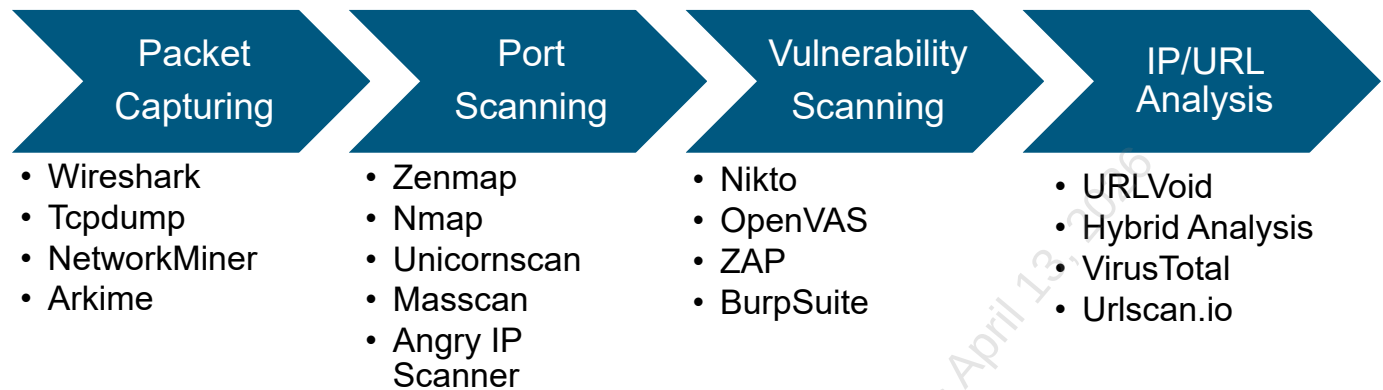
Advantages include:

- Applications start working as they are run.
- Installation takes place in the default directories (as you normally would do if you were installing an application yourself using a manual approach).
- Doesn't install any toolbars or added items.
- Installs the latest and most stable application versions, which are obtained from the official vendor sites.
- Verifies hashes/digital signatures of installers.

It can save you a great deal of time, both when setting up a new system and certainly when deploying lab VMs.

1. <https://sec555.com/wyiop>

More Tools?



Some other tools of note include:

- **Packet Capturing**
 - Wireshark (<https://sec555.com/cvw2r>)
 - Tcpdump (<https://sec555.com/fgohc>)
 - NetworkMiner (<https://sec555.com/otben>)
 - Arkime (<https://sec555.com/376ve>)
- **Port Scanning**
 - Zenmap (<https://sec555.com/2fd5o>)
 - Nmap (<https://sec555.com/gp78z>)
 - Unicornscan (<https://sec555.com/zli5h>)
 - Masscan (<https://sec555.com/zli5h>)
 - Angry IP Scanner (<https://sec555.com/l62or>)
- **Vulnerability Scanning**
 - Nikto (<https://sec555.com/hbtrn>)
 - OpenVAS (<https://sec555.com/17h3c>)
 - ZAP (<https://sec555.com/a5c1t>)
 - BurpSuite (<https://sec555.com/lm642>)
- **IP/URL Analysis**
 - URLVoid (<https://sec555.com/pw2zr>)
 - Hybrid Analysis (<https://sec555.com/gple9>)
 - VirusTotal (<https://sec555.com/0isj9>)
 - Urlscan.io (<https://sec555.com/ajy57>)

Security Onion

IDS + Zeek + packet capture

- Centrally controlled and managed by a single master
- Metadata sent to master used to pull PCAP

Pivot from SIEM data to PCAP

- Cost is low
- PCAP retrieved with Stenographer

Multiple supported architectures

Available on Azure, Amazon, and Google clouds

Security Onion¹ supports multiple distributed sensors that perform local packet capturing and storage. Network metadata and packet captures are stored on the local sensors. Queries to search metadata are issued from the master against all sensors (sensors do all the heavy lifting). This information can then be used by the master to request a carved-out packet capture from a specific sensor.

In a nutshell, it leverages the following components:

- **Suricata**, for signature-based detections.
- **Suricata/ZeeK**, for protocol metadata and file extraction.
- **Stenographer**, for full packet capture.
- **Strelka**, for file analysis.
- **Osquery**, for live queries.
- **Elastic Agent**, for endpoint data collection.
- **Elastic Fleet**, for central management.

Effectively, Security Onion is designed to distribute the load across numerous sensors. This works great on low-bandwidth, remote locations, and also scales quite efficiently. The tool has been around for a while (first released in 2009) and is quite stable. Should you need it, commercial support is available through Security Onion Solutions.

1. <https://sec555.com/miv75>

Security Onion Architecture

Import

- Simplest architecture with a single node

Evaluation

- TAP/SPAN required
- Logs sent to Elasticsearch

Standalone

- Similar to **Evaluation** but logs are sent to Logstash, and then Redis for queueing

Desktop

- Simple desktop buildup with Wireshark and NetworkMiner access

Distributed

- Manager node, one or more forward nodes (recommended for production systems)

You can use numerous architectures for the deployment of Security Onion:

- **Import:** This entails using a single import node, which allows you to import .pcap (packet captures) or .evtx (Windows logs) files. Note, **this architecture doesn't support Elastic agents**.
- **Evaluation:** To capture live traffic, you need to have a TAP or span port available. That traffic is then monitored on the sniffing interface, which means logs can now be generated. A single Elastic agent collects and dispatches them directly to Elasticsearch for parsing and indexing. *This is a great option for testing Security Onion but isn't meant for production environments (doesn't support numerous Elastic agents or Security Onion nodes).*
- **Standalone:** Like Evaluation, but this time logs aren't sent to Elastic agent but rather to **Logstash** which then dispatches them to **Redis** (which is a message broker) for queueing. There's also a second Logstash pipeline to take them from Redis and dispatch them to Elasticsearch. That's when parsing and indexing takes place. *Suitable for POCs, testing, labs and low-throughput environments.*
- **Desktop:** A basic desktop environment is built, with a web browser made available to log into an existing Security Onion deployment. Has access to **Wireshark** and **NetworkMiner**.
- **Distributed:** *This is the recommended option for corporate environments.* A manager node exists, and you can add one or more forward nodes (which are the ones running the sensor components) and one or more search nodes (running Elastic search items). This is rigged for performance and stability.

Reference:

- <https://sec555.com/5jyx2>

CAPE Sandbox

Derived from
Cuckoo v1

- Network traffic in PCAP
- Machine screenshots while malware is executing
- Performs malware unpacking
- Static and dynamic analysis supported
- Ability to bypass anti-sandbox techniques
- Suricata scans of network traffic
- YARA scans of unpacked payloads

CAPE¹ supports static and dynamic malware analysis methodologies. It's capable of performing payload extraction (e.g., injected payloads, dropped files, scripts) and provides a full report after malware analysis takes place. It uses YARA rules to scan extracted payloads and Suricata to perform deep packet inspection on network traffic.

It supports scripting analysis (e.g., PowerShell, VBA, JavaScript, batch files), network emulation (e.g., fake internet connection, traffic redirection), and has a REST API for integrating it with other systems.

Note that Lenny Zeltser, a SANS fellow and author of FOR610: Reverse-Engineering Malware: Malware Analysis Tools and Techniques, has a great list of free automated malware analysis sandboxes available.²

1. <https://sec555.com/1q0gu>
2. <https://sec555.com/zqvdy>

How About Using the Cloud?

Most cloud vendors have free accounts

Not everything will be free. There are still limitations or throttling but a lot of the features are there

Combine this with automation (e.g., Terraform, Ansible, Puppet and Chef to reduce deployment times)

A lot of infrastructure today sits on cloud and cloud vendors have numerous detection tools available

If you work as a consultant, this works nicely for spinning up something for a client that they get to keep, even after you're gone

Another way to build a lab is to use cloud services.

The advantages are:

- The lab can be very easy to spin up, especially if you use automation scripts with technologies like **Terraform, Ansible, Puppet, or Chef**. It can dramatically reduce the time to deploy down to minutes.
- It creates a reproducible framework for you to be able to re-deploy the structure in other instances, or if you only need it temporarily—for instance, if a new vulnerability comes out for a specific version of the Apache web server or any other components.
- You can easily add a test lab, try that out, and work on detections and tear it down when you are done. It only takes minutes to delete any resources you create.
- If you are using cloud vendors, then you can easily integrate with their features. For example, if you are using Microsoft Sentinel or AWS CloudWatch, you can check to see if your rules are able to work with these tools.
- You can easily reach your lab from anywhere you are, use multiple platforms as your origin devices, and also manage it quite easily.

However, **one of the biggest drawbacks when using the cloud tends to be the cost**. Associated cost of resources can dramatically increase. If the lab is small and you are only using certain things for a certain amount of time, it can be fine. But if complexity increases, and you start adding more machines, or you need the lab up and running for several days, weeks, or possibly running at all times, then this becomes a serious expense. You need to account for and budget for it to ensure it fits your needs.

Let's look at a few options.

Microsoft Option 1: E5 Enterprise Security License

Microsoft Entra ID P2

Microsoft Entra ID (formerly known as Azure Active Directory or Azure AD) provides identity and access management solutions for hybrid and multicloud environments.



Microsoft Defender XDR

Protect your organization against sophisticated attacks such as phishing and zero-day malware.



Microsoft Defender for Cloud Apps

View apps used in your organization, identify and combat cyberthreats, and monitor and control data travel in real time.



Information protection and governance

Identify risks by locating data and understanding how it's used. Help safeguard data where it lives by configuring protection and retention labels.



Microsoft Defender for Endpoint

Scale your security with a unified endpoint security platform for preventative protection, post-breach detection, automated investigation, and response.



Microsoft Defender for Identity

Use a cloud-based solution that helps protect your organization's identities from multiple types of advanced targeted cyberattacks.



Microsoft Defender for Office 365 Plan 2

Help secure your email and Microsoft Teams with advanced protection against phishing, ransomware, and other cyberthreats.



Microsoft Purview eDiscovery

Help your organization find relevant data quickly and cost-effectively.



[Learn more >](#)

Obtaining a Microsoft 365 E5 license will give you access to all the major security features (we will discuss some of these in detail in Section 4):

- Microsoft Entra ID
- Microsoft Defender XDR
- Microsoft Defender for Cloud Apps
- Information Protection and Governance
- Microsoft Defender for Endpoint
- Microsoft Defender for Identity
- Microsoft Defender for Office 365
- Microsoft Purview eDiscovery
- Microsoft Purview Risk Management

At the time of writing, a license like the above costs about \$55/month (without VAT). It's not free, but it's definitely affordable for any business out there. Plus, you get access to various security features with which you can test and integrate your content accordingly.

Reference:

- <https://sec555.com/ayuo4>

Visual Studio Professional + Microsoft 365 Developer Program

Subscriptions

Professional standard

\$99.99 user/mo*

- Visual Studio 2022 Professional
- Azure DevOps (Basic plan)
- \$50 Azure Credit per month
- Basic Dev/test software
- Training and support

Buy now

Or renew at \$66.59 user/mo*

*Paid annually

Professional monthly

\$45 user/mo

- Visual Studio 2022 Professional
- Azure DevOps (Basic plan)

Buy now

Join the Microsoft 365 Developer Program

Current Visual Studio Professional or Enterprise subscribers and members of qualifying programs can set up a free Microsoft 365 E5 developer subscription to use for development.

Join now

Read the FAQ >

Visual Studio has two Enterprise and two Professional level licenses

Professional standard, comes with Azure DevOps **plus a Microsoft E5 365 developer subscription**

You can always just get a Microsoft 365 Developer account, but you need to renew it (if eligible) every 3 months

The Microsoft E5 developer subscription comes with 25 user licenses 😊

If you are thinking of a long-term investment, then you can benefit from either of the following options:

- **Enrolling in the Microsoft 365 Developer program:**¹ This has been created so folks like developers can trial out various Microsoft features and be able to review if they are suitable for their environments. After using Microsoft's form to register, you get access, but that needs to be reviewed and renewed by them every three months. Doable, but can be a bit annoying. If you are interested, read the full FAQ² before committing.
- **Getting a Visual Studio subscription:** This is a very interesting option. *If you purchase a Visual Studio Professional or Enterprise level licence,³ it automatically makes you eligible for a Microsoft 365 E5 subscription, which allows you to use 25 user licenses.* At the moment of writing, a professional standard license costs \$99.99/month, while after the first year, the cost drops to \$67/month. This option can be very attractive because the cost is comparable to getting a single E5 license, but this time you are able to use 25 user licenses, plus you get Visual Studio at your fingertips.

1. <https://sec555.com/m3wk0>
2. <https://sec555.com/ow9pm>
3. <https://sec555.com/3xshw>

Automate Deployment

- **CloudGoat** (AWS self-hosted vulnerability lab).
- **AWSGoat** (AWS self-hosted attack and defense scenarios).
- **Sadcloud** (Terraform code used for deployment).
- **AzureGoat** (Azure self-hosted attack and defense scenarios).
- **PurpleCloud** (Azure built research lab using Python and Terraform).
- **SimuLand** (Azure built research lab using ARM templates).
- **Adaz** (Active directory lab in Azure using Terraform and Ansible).
- **GHOSTS NPC** (Non-Player Characters: Simulates user activity, such as document creation, web browsing, file downloading, etc., allowing it to mimic real user events).
- **Splunk Attack Range** (Builds Azure/AWS and local environments, performs attack simulation, and forwards data to a Splunk instance).
- **CyberRange** (Great lab that deploys resources for offensive, defensive, malware analysis, and threat hunting teams).

It's worth noting that there's a big variety of different projects that can be used to automate a cloud detection lab's deployment, mainly using Terraform and similar IaC (Infrastructure as Code) methodologies. Examples include:

- **CloudGoat** (<https://sec555.com/vipe7>)
- **AWSGoat** (<https://sec555.com/uk26r>)
- **Sadcloud** (<https://sec555.com/1xtqf>)
- **AzureGoat** (<https://sec555.com/fmvzt>)
- **PurpleCloud** (<https://sec555.com/k9wid>)
- **SimuLand** (<https://sec555.com/nyrpk>)
- **Adaz** (<https://sec555.com/c1gp2>)
- **GHOSTS** (<https://sec555.com/lztx2>)
- **Splunk Attack Range** (<https://sec555.com/g627i>)
- **CyberRange** (<https://sec555.com/zb5mw>)

Of course, you can always create your own infrastructure from scratch, but the point here is to give you options to eliminate deployment time. Some of these projects can contain many more resources than what you need, so if you choose to use one of these, you might benefit from removing some of the resources you don't require. That will lighten the load and also significantly reduce cost.

Case Study 1: PurpleCloud

Created by SANS instructor Jason Ostrom

Azure cyber range

High level points

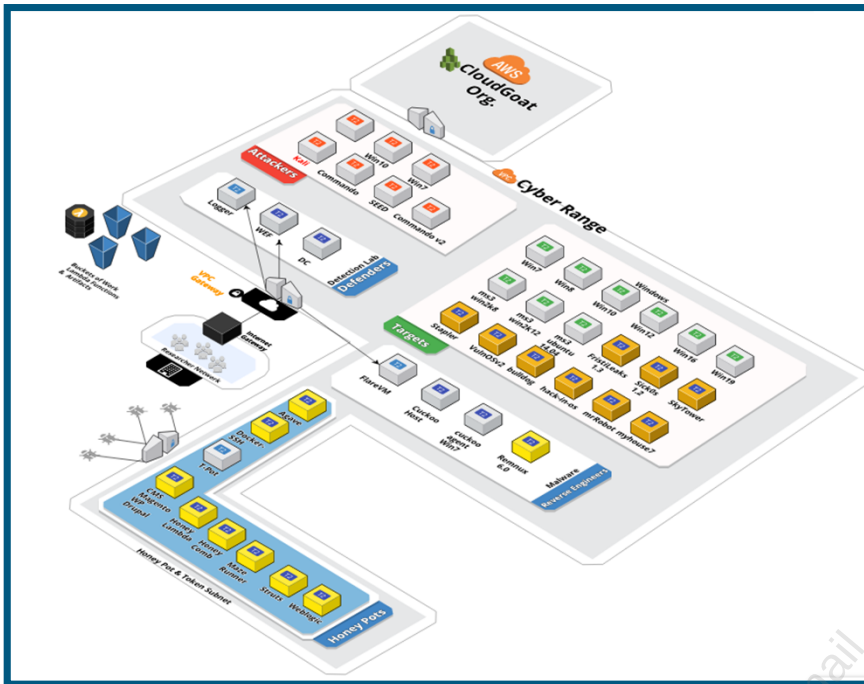
- Azure Monitor Agent included
- Uses Terraform for rapid deployment
- Entra diagnostics included
- Telemetry sent to a Log Analytics Workspace for further investigation
- All logs sent to Sentinel

PurpleCloud constitutes a Terraform code generator. It supports multiple simulation labs in Azure.

It creates the following:

- Microsoft Sentinel deployment
- Log Analytics included
- Activity, sign-in, audit, Graph activity, enriched Office 365, and audit logs are all sent to the Log Analytics Workspace
- One active directory domain controller
- One Windows 10 machine joined to the domain
- Azure Monitor Agent installed on all Windows systems
- Sysmon and Atomic Red Team installed on all systems

Case Study 2: CyberRange



Deploy in minutes, after creating an AWS account and filling in the registration form to obtain the related AMI images.

Beware of cost, if you keep these instances constantly up and running

You can always remove the ones you don't need

To get CyberRange¹ deployed, you need to have or create an AWS account and then provide the account number and your contact details to the CyberRange author so you get access to the AMI images you will be using for this lab. When it's up and running, you get:

- Attacker machines (e.g., Kali, Commando, Windows 10).
- Multiple vulnerable targets.
- A detection segment, used for detection engineers.
- A honeynet (with multiple honeypots like T-Pot, Cocker-SSH, and more).
- A reverse malware analysis segment (with Flare, Cuckoo, and REMnux all set up).

These can cater to a variety of teams in your company, such as the following:

- Detection engineers
- SOC analysts
- Malware analysts
- Forensic experts
- Threat hunters
- Incident responders

1. <https://sec555.com/ei13a>

Which Logs and Tools Do I Need?

Windows Active Directory

Windows Group Policy

NGFW

DHCP

DNS

Network Security Monitoring

SIEM tools

Web servers

Cloud workloads and logging tools
(Azure, AWS, GCP)

Web proxy

IDS/IPS

NAC

VPN

Databases

Office 365/other email logs

The logs and related tools that you require to get the job done depend on what your detection rules are going to be about. The list presented here is not all-inclusive, but it contains all the heavy hitters for most environments.

- Windows Active Directory
- Windows Group Policy
- NGFW
- DHCP
- DNS
- Network Security Monitoring
- SIEM tools
- Web servers
- Cloud workloads and logging tools (the big three: Azure, AWS, GCP)
- Web proxy
- IDS/IPS
- NAC
- VPN
- Databases
- Office 365/other email logs

Feel free to add more or remove the ones that are not relevant to you. Remember, you need to choose what is best for you. Don't just include everything for the sake of having them all there. That won't be beneficial in the long run. Try to use as many items as you have in your actual production environment to maximize the efficiency of your detections.

Additional Items

Solidify your network design and ensure you have enough to get you started

Set up detection use cases (e.g., brute force attack over SSH, cloud server password spraying, MFA fatigue, SQL injection)

Turn on additional logging. E.g., are you logging PowerShell events?

Adversary emulation

- Atomic Red Team
- MITRE Caldera

Additional integrations

- Threat Intelligence (e.g., MISP)
- Ticketing tools (e.g., TheHive)

Some last items to consider:

- **Network design:** By now, you have seen multiple options to get a lab going, either on-prem or in the cloud. Choose your network architecture of choice and carefully design it to cater to your requirements. Try to be as accurate as possible to begin with, to reduce administrative overhead and the need to tackle issues afterward.
- **Use cases:** For you to have successful detections, you need to ensure you have proper use cases set up. Those will be driven from the log sources and associated data you have available. Remember, if a use case isn't there, you will most likely miss on a detection. It benefits you to be as thorough as possible.
- **Logging configuration:** It's not enough to just have devices available; you need to ensure they are all configured and logging according to your needs. For instance, if you want to have full visibility on PowerShell execution, you need to switch script block logging.
- **Adversary emulation:** Think about the ideal approach to mimic attackers so you get activities in your logs. Yes, you can run the occasional manual exploit, but would that be beneficial in the long run? Using a tool like **Atomic Red Team**¹ or **Caldera**² is more beneficial for you as they give you immense power and reduce required time.
- **Third-party tools:** Think about what additional sources you need to integrate with to have quality detections deployed and information recorded. **MISP**³ is a great threat intelligence resource, and **TheHive**⁴ can offer incident recording and management capability.

1. <https://sec555.com/zc6ds>
2. <https://sec555.com/af72h>
3. <https://sec555.com/4ogne>
4. <https://sec555.com/yixtj>

Summary

Creating a solid detection engineering lab sets you up for success. Evaluate the options between using physical on-premises infrastructure, using virtualization or the cloud as your playground.

One of the advantages that some of the cloud options have is the ability to massively expedite and auto-provision the whole process. That reduces the possibility of issues and greatly improves deployment speeds.

This area is intentionally left blank.

Luring the Attacker with a Honeypot

Refer to the lab workbook for instructions.

This area is intentionally left blank.

Course Roadmap

Section 1: Detection Engineering and SIEM Architecture

Section 2: Network and Endpoint Analysis

Section 3: Asset Discovery, Baselines, and UEBA

Section 4: Cloud Logging and Monitoring

Section 5: Alerting and Detection Engineering Pipelines

- SIEM Introduction
 - ☐ Lab 1.0: Lab Setup
- Detection Engineering Life Cycle and SIEM Planning
 - ☐ Lab 1.1: DeTT&CT & Data Source Gap Analysis
- Creating a Detection Lab
 - ☐ Lab 1.2: Luring the Attacker with a Honeypot
- Log Collection and Enrichment
 - ☐ Lab 1.3: Introduction to the SIEM Components
- Log Aggregation, Parsing, and Analysis
 - ☐ Lab 1.4: Using AbuseIPDB for Data Enrichment

This area is intentionally left blank.

Module Objectives



The student will understand how to collect logs, what common challenges are, and why enrichment plays an important role.

This area is intentionally left blank.

Is This a Log or Not?

The following file has been generated using the PowerShell command below:

```
PS C:\Users\nikol> Get-CimInstance Win32_StartupCommand |Select-Object Name, command |
Out-File ./list.txt
```

Name	command
GoogleDriveFS	C:\Program Files\Google\Drive File Stream\101.0.3.0\GoogleDriveFS.exe --startup_mode
OneDrive	"C:\Program Files\Microsoft OneDrive\OneDrive.exe" /background
BraveSoftware Update	"C:\Users\nikol\AppData\Local\BraveSoftware\Update\1.3.361.151\BraveUpdateCore.exe"
com.squirrel.slack.slack	"C:\ProgramData\nikol\slack\slack.exe" --process-start-args --startup
Docker Desktop	C:\Program Files\Docker\Docker\Docker Desktop.exe -Autostart
OpenVPN-GUI	C:\Program Files\OpenVPN\bin\openvpn-gui.exe
EPPCCMON	"C:\Program Files (x86)\EPSON Software\Epson Printer Connection Checker\EPPCCMON.EXE"

Could this be a log?

Name	Command
GoogleDriveFS	C:\Program Files\Google\Drive File Stream\101.0.3.0\GoogleDriveFS.exe --startup_mode
OneDrive	"C:\Program Files\Microsoft OneDrive\OneDrive.exe" /background
BraveSoftware Update	"C:\Users\nikol\AppData\Local\BraveSoftware\Update\1.3.361.151\BraveUpdateCore.exe"
com.squirrel.slack.slack	"C:\ProgramData\nikol\slack\slack.exe" --process-start-args --startup
Docker Desktop	C:\Program Files\Docker\Docker\Docker Desktop.exe -Autostart
OpenVPN-GUI	C:\Program Files\OpenVPN\bin\openvpn-gui.exe
EPPCCMON	"C:\Program Files (x86)\EPSON Software\Epson Printer Connection Checker\EPPCCMON.EXE"

This doesn't have a timestamp or system name. However, this PowerShell output can be a high value log. This information can be collected using one of multiple log collection methods and shipped off. At the time of collection, the system name and time can be appended. This means you could run scripts or executables that create similar output and have the information automatically centralized, searchable, and with the ability to alert on.

Log Collection

Agent-Based

Built-in (e.g., syslog or Windows), native SIEM, or third party

Agentless

No need for installation but requires credentials

API Integration

Requires configuration

Cloud-Native

Supported from numerous cloud vendors

Others

(SNMP traps, local file collection via script, etc.)

There are numerous options for collecting logs from target systems:

- **Agent-based:** Agent-based collection can use a built-in agent that is supported by the target system. Alternatively, it can use a SIEM tool's agent or a third-party software-based approach. The biggest advantage is that there's a lot of processing that the agent can do to slice and dice the logs before those are sent further down.
- **Agentless:** The biggest advantage here is that you don't have to go to the extent of installing and configuring an agent, like in the previous method.
- **API integration:** A lot of tools support APIs that can be used to collect logs, but those require some level of configuration before logs start getting pulled through.
- **Cloud-native:** Cloud providers have their own ways of collecting logs. For example, if you are an Azure consumer, you would commonly use AMA (Azure Monitor Agent) to collect logs of interest from various cloud systems.
- **Others:** There are also other approaches, like writing scripts for collection or collecting local files from systems. These are the most case-specific and are used for specific reasons at times.

Log Agents

Log agents provide additional functionality

- Auto parsing
- Log rotation
- Log buffering
- Prioritization
- Filtering
- Integrity
- Encryption (e.g., TLS)
- Event rate controls

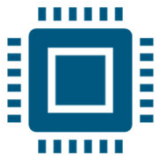
The capabilities modern log agents have are staggering. A modern agent has many of the capabilities that a log aggregator has, and in some instances, can even act as its own message broker. For example, below is a list of features of modern agents:

- **Auto parsing:** Automatic parsing of CEF, CSV, XML, KV, LEEF, JSON, GELF, W3C, Syslog, etc.
- **Data diode support:** One-way communication of log traffic (from agent to SIEM tool).
- **Pre-parsing:** Filtering of logs at the endpoint system.
- **Event rate controls:** Can limit the number of logs sent, to control bursts.
- **Log rotation:** Scheduled purges/moving to the archive of local logs.
- **Log buffering:** In the event that logs are not being accepted when sent, the agent can locally buffer in memory or on disk, up to a certain size, and then resend when communication is reestablished.
- **Multiple destinations:** Logs can be delivered to multiple destinations that can support various protocols (TCP, UDP, etc.).
- **Encryption:** Logs can be sent over encrypted channels such as TLS.
- **Log integrity:** Logs can be sent with hashes or checksums to verify the integrity of the log in transit.
- **Priority routing:** Allows certain logs to be given higher priority over other logs. These receive special treatment, such as being routed first. This can also be used in cases where, if many logs are getting generated and logs are starting to drop, priority logs are not among those to be dropped.
- **File monitoring:** File integrity monitoring of files or directories.
- **Registry monitoring:** Registry integrity monitoring of registry keys.
- **Support for accepting NetFlow** and turning it into a log or event.
- **Alerting:** Alerts can be triggered based on conditions such as seeing certain patterns or based on more advanced conditions, such as seeing 500 failed login events.
- **Remote administration:** Some agents require configuration files be pushed through asset management software. Others provide their own central management for remote administration.
- **Message conversion:** Converts a log message from one type to another. For example, the original message could be syslog and then converted into JSON.

- **Cloud API Integration:** Pulls logs from mainstream cloud providers such as Amazon and Google through API calls.
- **Windows Event Forward collection:** Some log agents have the capability to act as a Windows Event Collector server.

The performance of agents varies greatly and should be tested. The features used can also affect performance. For example, enabling encryption requires CPU for processing on both the agent as well as whatever is receiving the log.

Windows Event Forwarding (via Built-in Windows Agent)



Available for Windows XP/2003, built-in to Vista/2008+

- Centrally managed via GPO
- Patched with Windows Updates



Features

- Allows pushing or pulling logs to/from central event collector (uses Windows Remote Management)
- Encryption and compression
- Basic filtering

If you do not have the approval to deploy an agent, one thing you may want to try is Windows Event Forwarding. Basically, **Windows has its own built-in agent for handling the forwarding of Windows event logs**. WEF reads the logs from any environmental device you have and then forwards them to your designated Windows Event Collector (WEC). It uses one of two possible subscription levels:

1. **Baseline:** It enrolls all your organizational devices. Output can be sent to a SIEM and/or a long-term storage data lake.
2. **Suspect:** This option is mostly designed for host forensic purposes, and is aimed at logging more events and in greater detail. But you get to choose which devices are targeted for collection. As such, it sends logs to long-term storage directly. Microsoft recommends sending logs to long-term storage when the EPS is 50,000 or more.

The best thing is that it is **free**, as it is part of Windows. The next best thing is that operational costs are minimal, as it is centrally ***managed with group policy and is automatically patched***.

While it is not as feature-rich compared to third-party agents, it does include:

- Filtering.
- Encryption (Kerberos can be used for encryption in a Windows domain).
- Compression.
- Event throttling.
- The ability to either push logs to a central collector (easily configured by GPO) or to have a collector pull (in this case, the WEC server needs to be preconfigured with the names of the client devices that contain the events to be collected) the logs.

Reference:

- <https://sec555.com/s712u>

Standard SIEM Agents

Most SIEMs come with their own agents

- Splunk: Universal Forwarder
- ArcSight: ArcSight Connectors
- IBM (QRadar): WinCollect
- Wazuh: Wazuh Agent

Many agents have modularized feature sets

- Premium features come with a premium price

Pros

- Agent natively integrates
- Logs from agent get auto-parsed
- Advanced features may be unique to the market
- Support

Cons

- Suffer from a lack of filtering capabilities
- Costs of agents and lack of filtering are high

Any commercial SIEM typically comes with its own log collection agents.

While the agents may come at a price, there is no question that the standard agent that comes with a SIEM will integrate better with that SIEM product. They were purpose-built for each other. This integration typically means that when logs get sent from a standard agent that the SIEM product has built-in auto-parsing capabilities to extract key fields. In most cases, this parsing capability is done at the log aggregator rather than at the agent itself.

Also, there is a remote chance that a SIEM vendor may have a proprietary new feature that only that vendor has. As a result, only their standard agent supports such a feature. This is rare, and typically, new features are consumed by competitor SIEM products shortly after.

The largest drawback to many standard SIEM agents is that they lack enhanced filtering capabilities at the agent. This means that all logs are sent to an aggregator for filtering, which in turn means that your network bandwidth and devices must be large enough to handle this. It also implies the log aggregator must be sized out to handle this large amount of data.

It is not uncommon for networks to crash simply due to network pipes being saturated by logs. The answer to this problem typically involves installing a specialized agent or an aggregator at each site to filter and handle the logs locally, before sending them to the central location. This adds complexity and overhead. The argument by vendors is that they do not recommend or support filtering at the agent because of the performance implications.

Whether you feel this is true or not, it is up to you to test and find out. Knowing this, and that vendors license or size by EPS, makes things at least worth investigating.

Third-Party Agents

Many options available

- Significantly more feature-rich than many built-in agents

Common open-source examples

- Beats
- NXLog

Key areas to focus on

- Transport methods (syslog, UDP, TCP, binary, etc.)
- Filtering capabilities
- Support

Extensive feature set

- Even compared to most commercial agents

Third-party agents offer significantly more capabilities than native agents or syslog. They have more support for transporting logs, such as supporting UDP, TCP, binary compression, TLS encryption, mutual authentication, and have page after page of additional value-added feature sets.

The primary difference between open-source and commercial agents ends up being support. Many companies shy away from open-source agents since it is important to have support available if problems arise.

There is an abundance of third-party agents available. Keep in mind that some of these agents are extremely basic while others are more mature and feature-rich. If your organization decides to consider third-party agents, you should try doing a small POC to test a few or find a professional who has experience in a few, to let you know their strengths and weaknesses.

Oddly enough, the features in open-source agents tend to exceed those in commercial agents. Granted, you probably are not going to find some new proprietary advanced features, but you will find dozens of features that lower the amount of time it takes to parse, collect, filter, and transmit your logs. These time-saving options and filtering capabilities warrant at least a courtesy investigation.

Many organizations have an anti-open-source policy due to the lack of support. This is not a bad policy, as you do not want to be stuck without support. The good news is that almost every key player in open-source agents offers support contracts or enterprise agents. Two of the more common and feature-rich are **Beats** and **NXLog**.

References:

- <https://sec555.com/xbm7p>
- <https://sec555.com/2urtx>

Beats

Beats is a framework for collecting data and logs.

- Developed and maintained by Elastic

Slowly growing in plug-ins and agents but currently has the following:

- **Filebeat:** Real-time monitoring and collection of files
- **Winlogbeat:** Collects and filters Windows event logs
- **Packetbeat:** Extracts network metadata promiscuously
- **Metricbeat:** Focuses on shipping metric data
- **Heartbeat:** Used for uptime monitoring
- **Auditbeat:** Collects audit data

Beats,¹ at its core, is a framework designed by Elastic for building out agents and functionality to collect data. By being a framework, it allows for quickly building out new functionality. Six agents from Beats are:

- **Filebeat:** This agent is used to perform real-time monitoring of files.
- **Winlogbeat:** This is a Windows agent used to collect, filter, and send Windows events.
- **Packetbeat:** This agent listens promiscuously on the network and extracts information such as HTTP headers and ships them off.
- **Metricbeat:** Provides system-level CPU usage, and statistics about the file system, disk I/O, and network I/O.
- **Heartbeat:** Monitors system uptime.
- **Auditbeat:** Monitors file integrity and collects the same data as auditd.

While each of these products works extremely well, the fact that they are separate agents makes Beats a less desirable solution for some organizations. Managing one agent is difficult enough, without having to manage more components. To that end, organizations often use Elastic Fleet,² which is essentially a web-based interface that allows Elastic agents and their policies to be centrally managed.

1. <https://sec555.com/g7yez>
2. <https://sec555.com/ug0lo>

NXLog

Comes in two categories

- **Community** edition: Free and open-source
- **Basic or Premium** plans: Paid options with additional features and support

Multi-platform support

- Windows, Linux, AIX, Solaris, UX, BSD, and Android
- Configuration files consistent across platforms

Community features exceed most commercial agents

NXLog¹ is one of the best open-source agents out today. It comes in two flavors: Community edition, which is open-source, and two paid versions (basic and premium plans). The most important additions of the paid versions are that **they include support**, in addition to **96 features (basic plan) or 174 features (premium plan)**.

An interesting component of NXLog is that it has multi-platform support, but not like other agents. Usually, this means that agent support is available on Windows, Linux, and Mac. In NXLog's case, that is true, but the configuration file also has the same layout across these platforms. This makes it easy to support when being rolled out across multiple platforms.

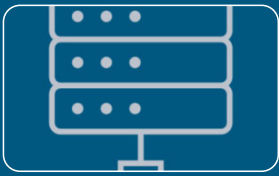
While an enterprise edition exists, the community edition tends to meet all requirements—except for support. This is because the Community edition has so many features that it tends to rival most commercial agents. It also has a vast integration list.² It supports the following log functions:

- Collection
- Parsing
- Processing
- Enrichment
- Storage
- Management

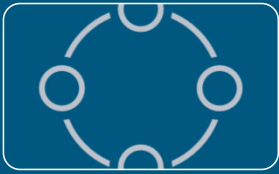
The full list of features inside the Community edition can be found in the NXLog documentation.

1. <https://sec555.com/cp8a9>
2. <https://sec555.com/q7sib>

Agentless Log Collection



Agentless involves a central server to collect logs



The server authenticates to systems over WMI or SSH

- Logs are collected in batches
- Requires admin privileges or additional rights
- Windows 2008+ can use the built-in Event Log Readers group



The main benefit is no additional software

- Do not have to maintain and upgrade agent
- Quicker to deploy and manage

In order to avoid having to install an agent on systems, some organizations prefer to set up a server to perform agentless log collection. This works by having a server remotely log in to systems often over WMI or SSH and pulling backlogs. This works well as long as the server has proper credentials for the remote systems and network firewalls, host-based firewalls, and endpoint security suites are configured to allow this activity.

Because no software needs to be installed on the system, logs that are being collected for agentless deployment allow for quicker setup and less maintenance. The main advantage is not having to deploy, update, and maintain a log agent.

Keep in mind that agentless servers cannot handle an infinite number of systems. Due to having to authenticate and pull logs, this method may require multiple agentless collectors. This is true even for medium-sized organizations.

Also, agentless collection can introduce a security risk due to constantly logging in over the network. An attacker can attempt to capture these credentials or the security token that is on the system. To minimize this risk, always use the minimum necessary permissions and rights for the service account(s) collecting logs. Always ensure, if you are opening services or ports, that you limit their access to only what is necessary. In short, maintain least privilege at all times.

Agent vs. Agentless

Agent

Pros

- Distributed filtering/parsing
- Log buffering
- No remote network logins
- Firewall friendly
- Supports data diode

Cons

- Maintaining and troubleshooting agent

Agentless

Pros

- No software installation
- Quick to set up
- Easy to maintain

Cons

- Requires inbound firewall rules
- Credentials over network
- Can miss deleted logs
- Limited capabilities

So, in the end, which is better, agent or agentless? It depends.

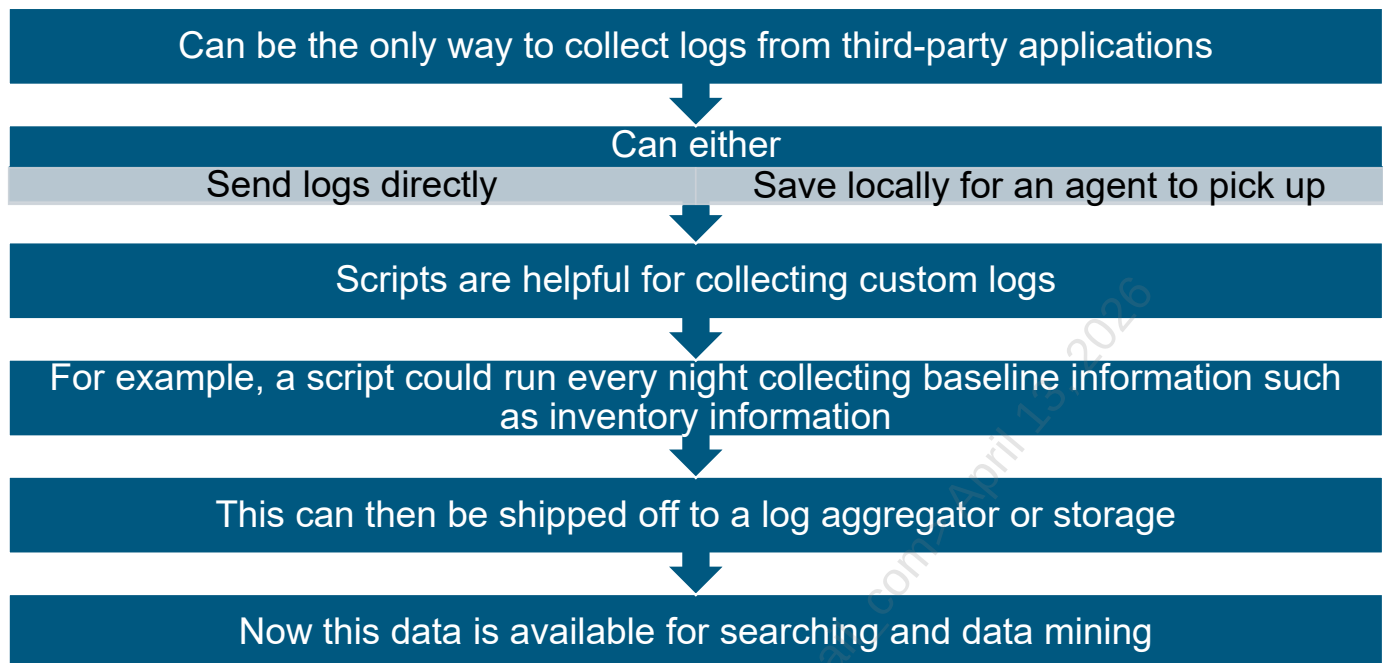
There are many things that are only possible through the use of an agent. Due to the current and growing capabilities of log agents, it is likely that the use of an agent is the superior solution. They allow you to distribute the load, don't require any heavy lifting from a firewall maintenance point of view (e.g., you won't have to constantly adjust firewall rulesets since the agent will be present on the machine), and they don't need any remote logins to take place. But then again, you do have to ensure the agent is properly configured and maintained at all times.

If you go with an agentless approach, you dispense with the challenge of installation and configuration of an agent, but you encounter other challenges, like having to create firewall rules or having a more limited feature set.

NXLog has created a document called "Agent-based versus Agentless Log Collection – Which Option is Best?"¹ that is accurate and fairly vendor-neutral, which is worth a review.

1. <https://sec555.com/97k5f>

Using Scripts



Another method of log collection that is important to consider is the use of scripts. There are some instances in which scripts are your only option for collecting logs. More importantly, scripts allow you to create custom logs that add value to your environment.

A great example of this is the continued boom in cloud-based applications and systems. If you are using them, you still have a level of responsibility for the data you put in them. Yet many do not have logs, or if they do, you do not have direct access. A large portion of these cloud providers have APIs that can pull out logs and important events. Scripts can be written to pull this data on an ongoing basis.

Scripts are incredibly useful for pulling in additional information not found in regular logs. This can include pulling in baseline information, asset inventory, running processes, hashes of files, and more. Running a script to generate this information and then shipping it off to a SIEM provides incredible power for searching and data mining.

Service Log Collection



Networking



Connections



Meeting



Events



Collaboration



Contacts



Relationship



Professional



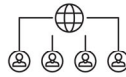
Handshake



Online Networking



Interacting



Network



Social Network



Business cards



Network Building



Socialization



Join Group



Referral



Connect People



Interest



Mentorship



Community



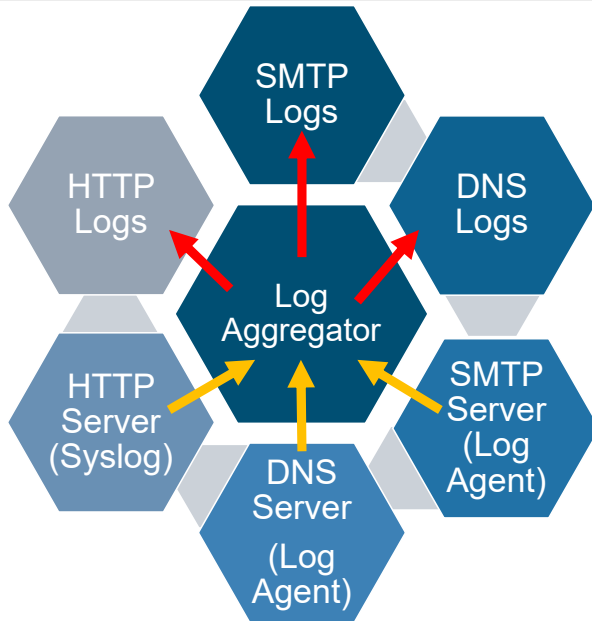
Seminar



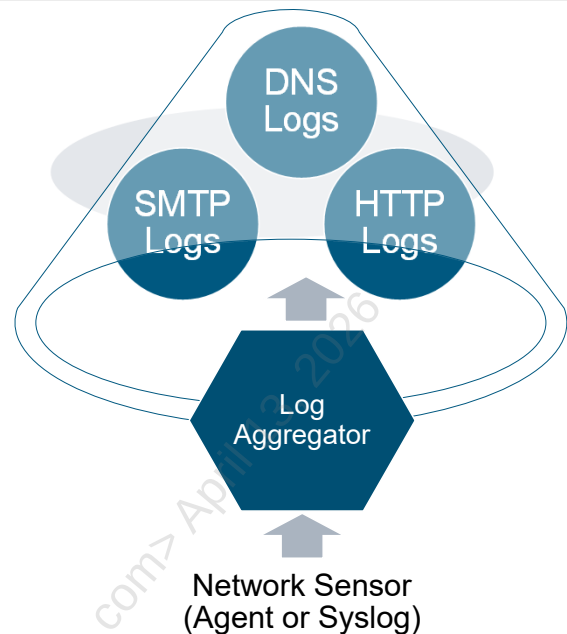
Engagement

This area is intentionally left blank.

Traditional vs. Network Event Extraction



Traditional Approach

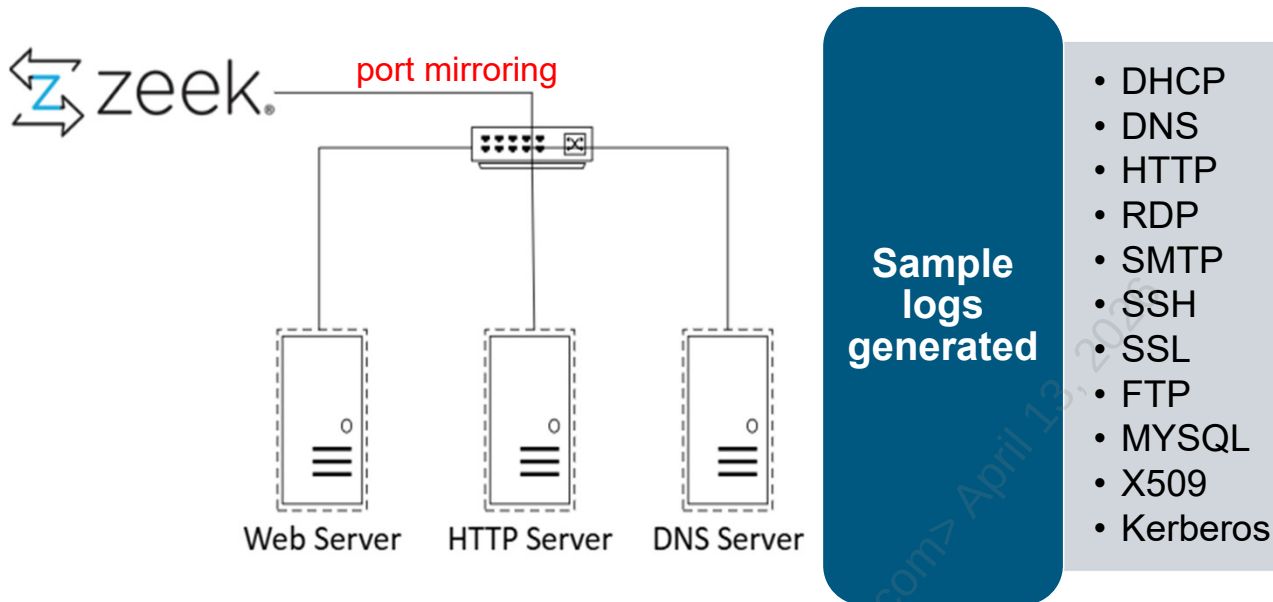


Network Extraction Approach

The common method for collecting service logs is to install agents on all of your servers or enable syslog if you are using an appliance. Log agents make logical sense as you are going straight to the source of the service. For example, you might install a log agent on a DNS server and then point it to the file location and have it ship off logs as they are generated. That's a very typical approach to take with SIEM tools, where a SIEM agent is installed on the monitored device and then is used to ship logs to the SIEM tool.

The flip side of this is that you can use a network monitoring system to look at packets and create logs as they are seen on the network. That means instead of having multiple agents on various application servers, a single network monitoring host can often see and generate all the logs from one location. The main drawback is that you first must give this system network visibility, usually using a network TAP (Test Access Point) or port mirroring.

Using Zeek



Zeek NSM (Network Security Monitor) is a great example of a network extractor. It dates back to 1995 (named Bro at the beginning), and is an open-source project developed and maintained by the International Computer Science Institute in Berkeley, California, and the National Center for Supercomputing Applications in Urbana-Champaign, Illinois. Its purpose is to listen on the network and extract metadata into logs. As you can see in the above diagram, Zeek contains numerous service logs.¹

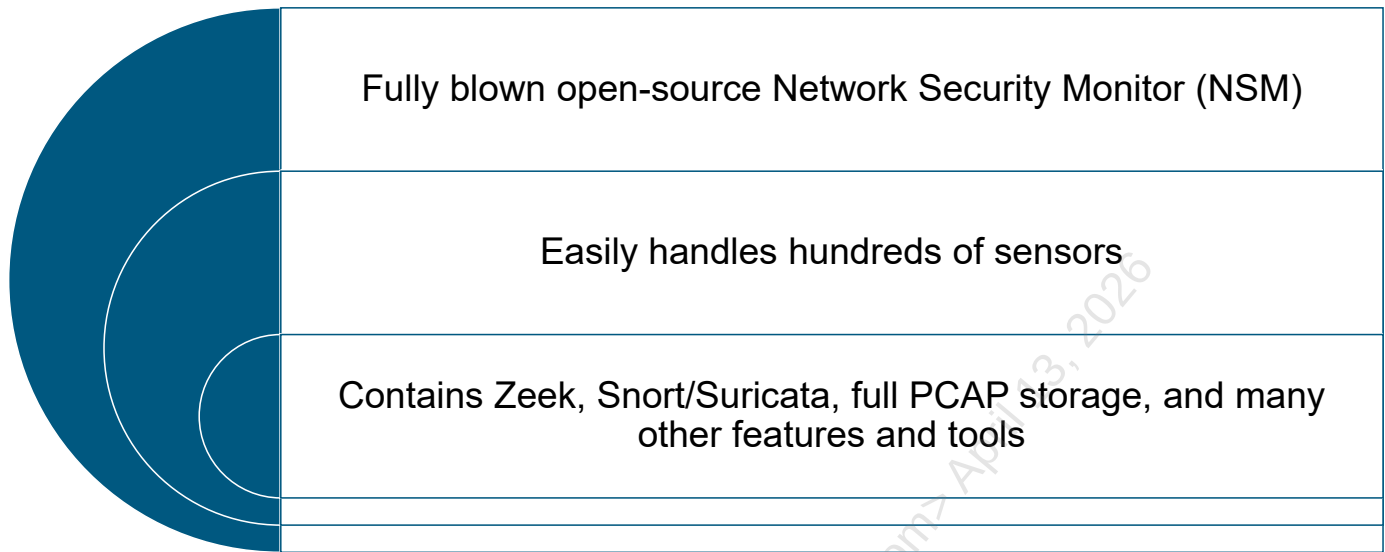
Why would you want to deploy a network extractor like Zeek?

It's one of the quickest and simplest ways to start collecting service logs. Think of it as a mix where you "just add water." In this case, a port mirror or tap is the water that needs to be added to the recipe to be complete. It simply works. You do not need to build rules or change things. Right from installation, it just works.

In this diagram, by adding a port mirror over to the Zeek sensor, you will immediately begin to have DNS, HTTP, HTTPS, and various other logs, without the need to add or configure agents to any of those servers. Anything that Zeek can see, it will generate logs for.

1. <https://sec555.com/tjveb>

Security Onion



Security Onion was introduced earlier, during our discussion about building a lab. It is one of the most well-put-together open-source distros out there.

It supports centralized management of sensors and is commonly deployed in environments with hundreds of remote sensors.

If you are looking for a quick and easy way to deploy multiple Zeek sensors that natively support central management, then you are probably looking for Security Onion. On top of that, it natively supports running either Snort or Suricata, which are open-source IDS solutions, as well as having the capability to save and rotate full PCAP storage (should you want to store PCAPs). This gives you incredible visibility. You can also purchase professional support or installation for Security Onion.

Pros vs. Cons of the Traditional Service Log Collection Approach

Pros

- Easy to comprehend
- Conceptually simple to set up
- Does not require network visibility

Cons

- Lots of systems to manage
- **Only collects from what you know of**
- Per application collection
- May require changing service settings
- Can be tough to get permission
- Inconsistent log format

Traditional does not mean ineffective. After all, **collecting logs using an agent is very easy to comprehend, deploy, and use. Also, it does not require any form of network mirroring to work.** If this method is simpler for you, then use it.

A drawback to traditional logging is that you have to deploy agents to many systems. As a result, configuration management can be difficult. Also, just because you have a log agent does not mean you can just collect logs. Changes may be required to services such as DNS before the log agent is able to pick up the log. Because of this, you may encounter some issues trying to collect certain logs using traditional agent/agentless methods.

With all that being said, **the one main difference between traditional logging and network extraction is that traditional logging is blind to unknown or not yet configured systems.** Consider this a nice-to-have setting and try not to justify your choice solely on this.

Pros vs. Cons of Service Log Collection with Network Extraction

Pros

- Generates logs for systems you do not know about
- Multiple application logs created from a single source
- Consistent log format
- No changes made to services

Cons

- Requires network visibility
- Requires additional server(s)
- Can be virtual
- Network visibility adds complexity
- Can be tough to get permission for network visibility

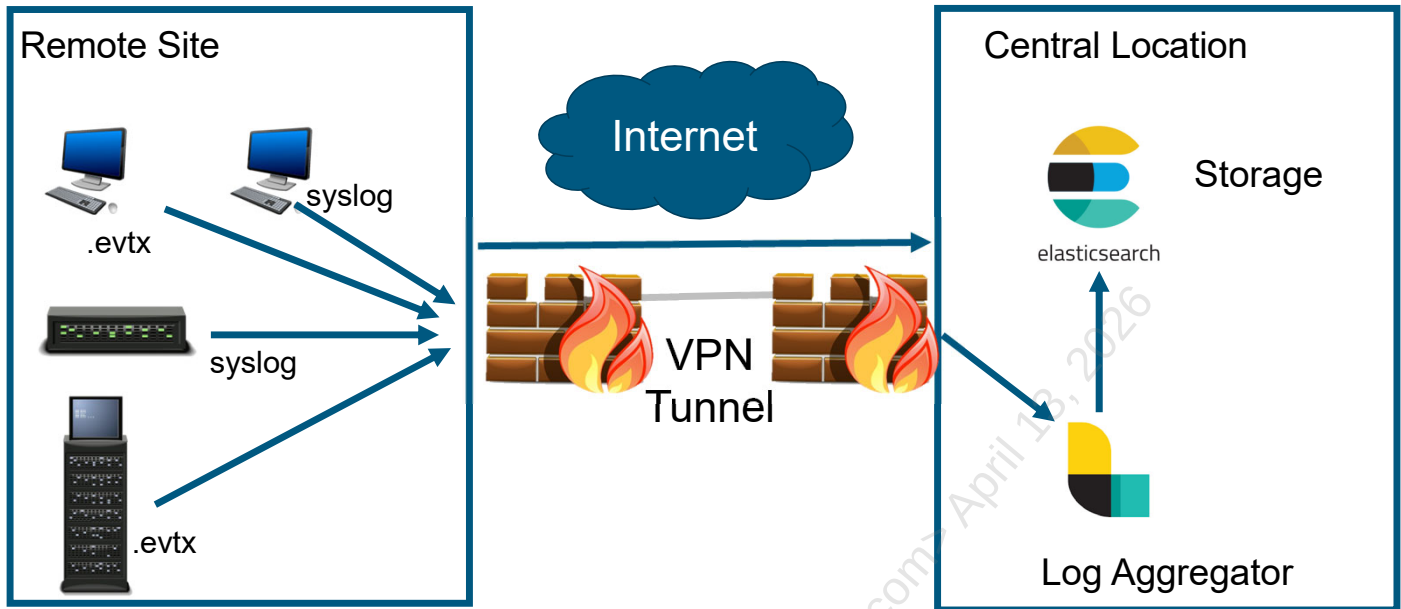
The main drawbacks to network extraction are **finding the right network location(s) to deploy a sensor and getting permission to mirror traffic to the sensor**. Sometimes, this can be a political fight. For example, imagine you are trying to do this on the network of a tier 1 bank. Now that can be a challenge, to say the least.

Keep in mind that, depending on the device doing the mirroring, you could only mirror certain traffic, such as port 53 traffic for DNS. Ideally, you can unleash the hose, but some visibility is better than none. Also, note that Security Onion and Zeek can use software filtering to not collect or analyze certain traffic, which can help alleviate concerns about getting too much visibility. It can also lighten the overall load and amount of traffic you have to then analyze.

In virtual environments, you may be able to get away with deploying Security Onion or Zeek sensors on each hypervisor. Doing so would allow you to see all traffic into or out of your virtual environment.

Once deployed, a collection of service logs can occur as long as network visibility is there. Service log collection means the sensor will generate logs of activity for unauthorized or unconfigured devices. Also, logs from a network sensor tend to follow a consistent pattern, such as tab-delimited fields with consistent names, and the logs are centrally generated.

Log Collection Using Log Agents

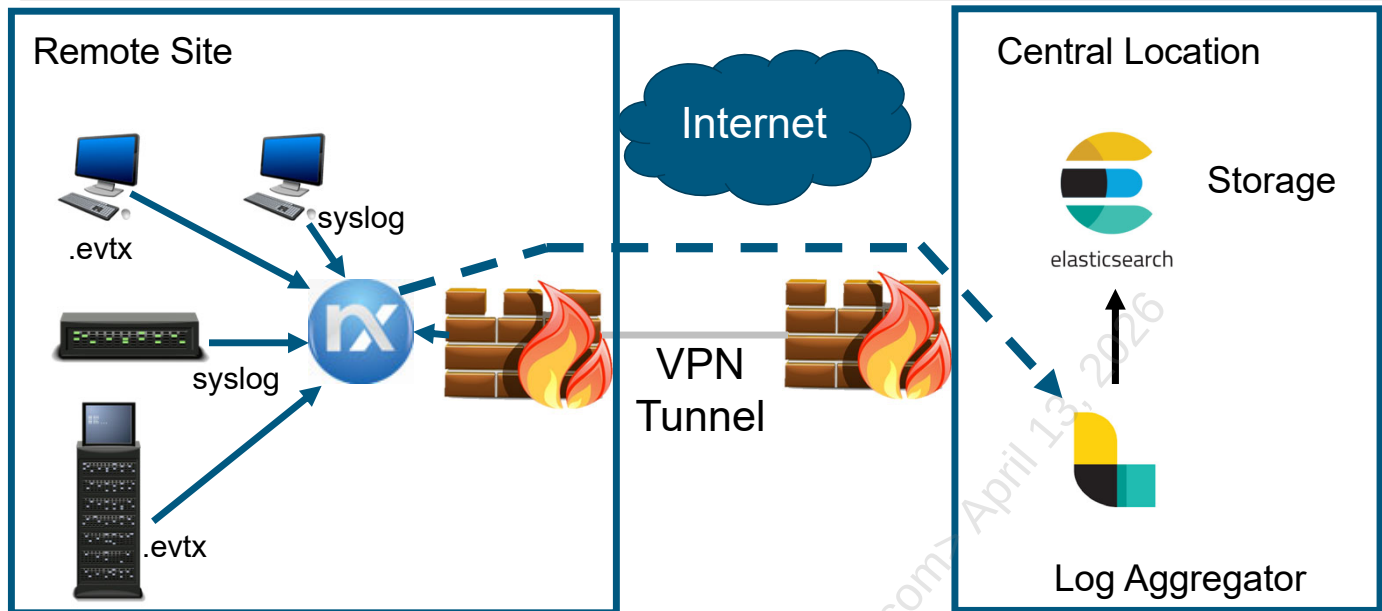


This diagram demonstrates a traditional setup for log collection using log agents. Agents on the Windows or Linux desktops and on the single server forward logs across a VPN to a log aggregator. In this slide, the remote switch and remote firewall would most likely send logs to the log aggregator over syslog UDP port 514. This is because not all devices will support log agents.

This is a traditional setup and is simplistic in nature. Simply make sure the firewalls allow traffic from the remote site over to the log aggregator, and things should work. **The main downside to this layout is that the switch and firewall use standard syslog over UDP. In the event the internet or VPN tunnel goes down, logs from the switch and firewall will be lost.** Occasionally, central management software for firewalls and switches includes a special non-syslog method for collecting logs, but unless that is the case, logs can be lost.

The advantage is that it is easy to maintain. Simply deploy agents to Windows and Linux systems and configure syslog devices to forward logs. In this design, all logs point to the same log aggregator. While this slide shows an example of Logstash and Elasticsearch being used on the right, the architecture is the same for other SIEM products.

Advanced Log Collection Scenario

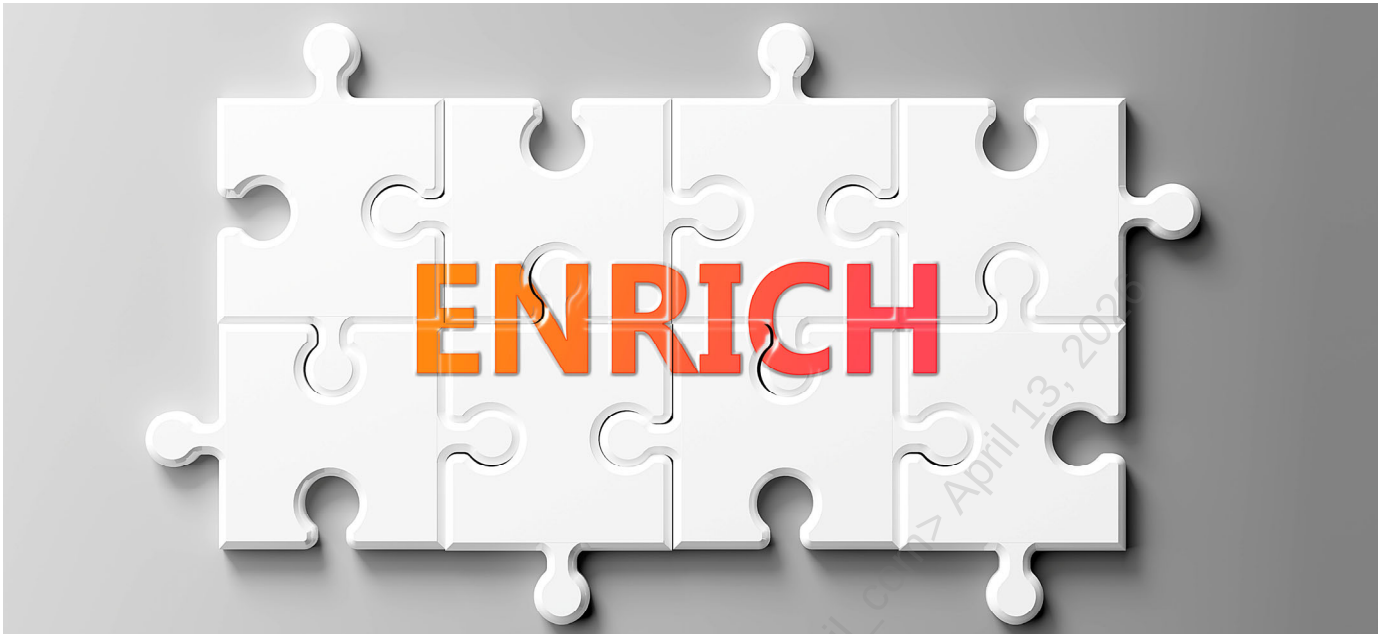


This diagram demonstrates a more advanced deployment for log collection. In this case, the remote location is using log agents to forward logs. One system at the remote location is running NXLog, and all the local assets are sending logs to it. This includes the remote switch and remote firewall. It then takes these messages and sends them on to the log aggregator. Because of this, if the internet or VPN goes down, NXLog will buffer logs until they are back online. In this case, even the syslog messages will not be lost.

This architecture also has two added benefits.

- It lowers the number of network connections the log aggregator has to handle, increasing overall performance.
- It easily allows for per-location filtering and augmentation.

Log Enrichment



This area is intentionally left blank.

Forward and Reverse DNS

Network data usually contains IP addresses or DNS names

- Ideally, both would be helpful
- Forward or reverse DNS lookups can fill the gaps

Forward lookups used to go from name to IP address

Reverse lookups used to go from IP address to name

- Use case often depends on where logs were collected
- Data is volatile as it changes over time

Lookups take time and can cause bottlenecks

Knowing IP addresses and DNS names is helpful for both filtering as well as to give context to an analyst.

Forward lookups perform DNS requests for A records and return an IP address.

Reverse lookups perform DNS requests for PTR records and return a DNS name.

If your DNS environment is not accurate, then beware. Using these lookups is for filtering and context. Incorrect responses can cause an analyst to interpret a log incorrectly, which may derail their investigation as a whole.

Cisco Umbrella Top 1 Million

- **Cisco Umbrella** provides the top 1 million sites for free
 - Can be used for tagging and quick filtering



Cisco has the **Cisco Umbrella Top 1 Million**¹ listing available, which contains the most queried domains based on passive DNS usage across the Umbrella global network. According to Cisco, that is:

- More than 100 billion requests per day.
- With 65 million unique active users.
- In more than 165 countries.

This type of list is great for filtering and context. For example, adding a tag of umbrella-to-umbrella domains allows filtering out domains quickly.

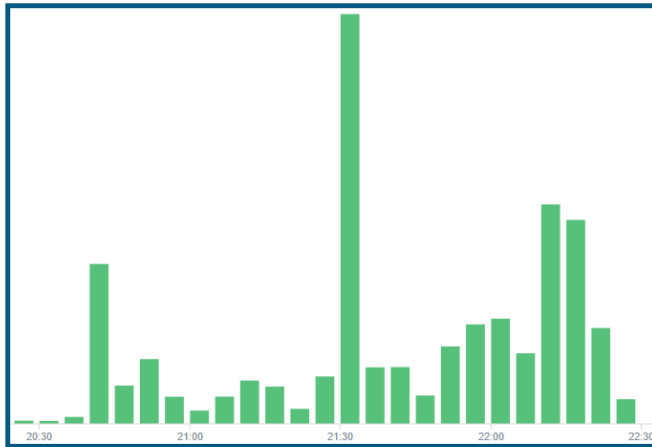
1. <https://sec555.com/0p67u>

Image reference:

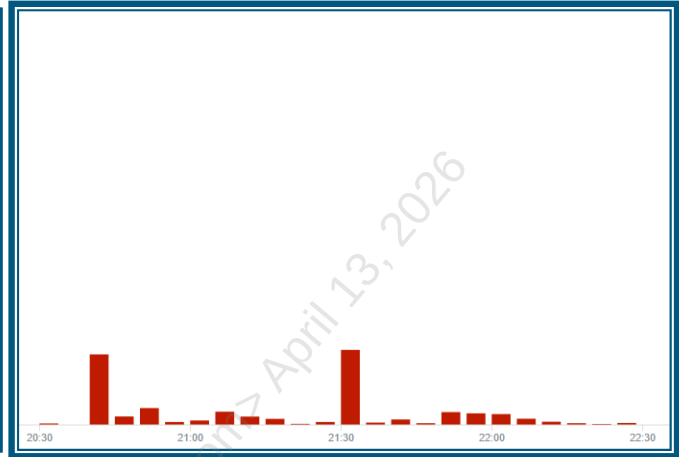
- <https://sec555.com/0pa3h>

Top 1M Filtering

Before



After (<90% logs)



On the left is a bar graph of DNS logs from 8:30 p.m. to 10:30 p.m. on a given day. On the right is the same timeframe and logs, but filtering out anything with a tag of top1m. While this does not inherently find evil, it does shrink the amount of data you may need to analyze by almost 90%. This type of technique is fantastic for manual investigations or forensics. It is also useful for limiting intensive resource augmentation to only a subset of log data for which it is needed.

The top 1 million filtering is a tactical security decision and works under the assumption that the top 1 million sites are secure. Assuming the top 1 million sites are benign is not always true. Also, this does not account for corporate policy, as many sites are likely to be unauthorized by policy. However, it does help to filter and find events of interest tactically. Filtering out the top 1 million sites can be a starting point during an investigation. Then, if this does not find anything, the filter can be removed.

Threat Intel Feeds

Common fields included in feeds

- IP address
- Domain
- URL
- Filename
- File hash
- Email (sender, domain)
- Others

The SIEM industry is pushing the concept of threat intel feeds with passion. This is very similar to how, originally, a firewall was just a stateless inspection device, only capable of performing basic filtering. Then came all the UTM (Unified Threat Management) functionality, such as antivirus, network intrusion prevention, etc. While having a threat intel feed is obviously better than not having one, the concept can be overrated.

The question is, how much do you trust your threat intelligence providers and the associated feeds that you or they maintain?

A lot of the objects contained on the lists are ever-changing. For example, IP address X is considered malicious, so you block it, and then 6 months later, it belongs to a prospective client who can't email you to reach out and collaborate.

It's great to have intelligence at hand, but you need to ensure you have appropriate information to act on it.

Open Threat Exchange

Developed by AlienVault

- Over 20 million threat indicators added daily
- Has an easy-to-use threat indicator wizard for custom IOCs
- Natively integrates into AlienVault

OTX Endpoint Security scans your endpoints for IOCs

- Install the OTX agent (Windows or Linux)
- Run scan

AlienVault¹ sponsors the Open Threat Exchange. This is a free threat feed in use by over 200,000 participants in numerous countries. To integrate, sign up for a free account and get an API key. Then, subscribe to data feeds. After that, follow one of the integration guides, such as for Zeek or Suricata, to start using the feed.

You can also use OTX Endpoint Security, which is a free threat scanning service that scans your endpoints to check if any OTX-known IOC is present on them, which indicates a potential compromise.

1. <https://sec555.com/z2tfr>

Malware Information Sharing Platform (MISP)

Malware Information Sharing Platform

- A free, open-source, analyst favorite
- Capability of high-volume indicator storage
- Great web UI and REST API interface
- Classification and sharing functionality
- Flexible indicator storage
- Easy import/export

One of the most feature-rich and trending threat intelligence sharing platforms available is the Malware Information Sharing Platform. MISP, by default, integrates with multiple free threat intelligence feeds, but it also natively supports custom feeds and sharing. For example, organizations can build their own list of indicators and then correlate them internally to find repeat offenders or adversaries changing tactics over time.

The sharing capabilities of MISP are a key feature. Companies can choose which organizations they wish to push or pull feeds with, as well as selectively share their own intelligence.

For example, an organization can record indicators it identifies and then share them only with partnering organizations. Even then, sharing does not have to mean full access, as MISP can granularly control who can see what and which information is shared.

MISP has been around for some time, and because it's well-known, a lot of SIEM tools already have integrations for it to pull data. A lot of incident and case management tools, like TheHive, also integrate seamlessly with MISP to obtain indicators and telemetry.

Export formats include CSV, JSON, and more, in addition to exporting in supported formats for tools like Suricata, Snort, and Zeek

Reference:

- <https://www.misp-project.org>

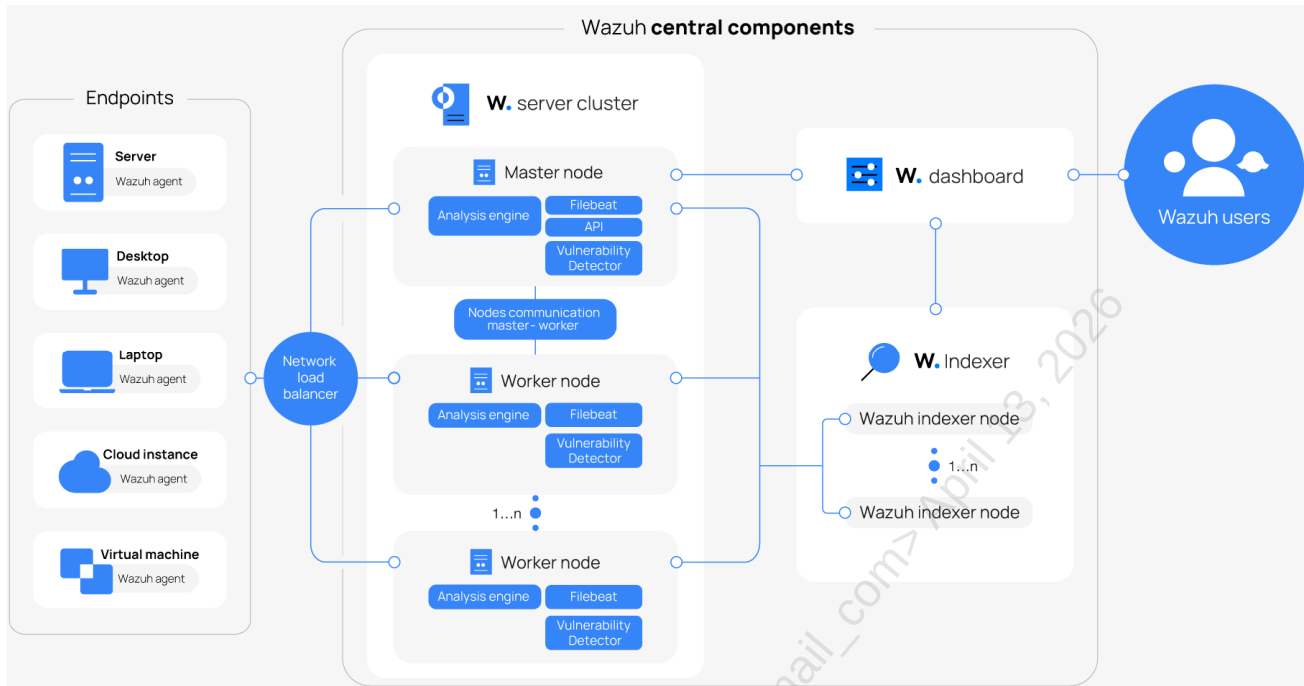
Case Study

wazuh.

Image reference:

- <https://sec555.com/15ihw>

Wazuh Architecture



We will be using Wazuh as our main tool throughout various labs. Wazuh was created as an open-source fork of OSSEC in 2015, but has come a long way since then. It supports malware detection, vulnerability detection, log analysis, File Integrity Monitoring, regulatory compliance, and numerous other items.

Let's briefly look at its architecture, which is based on monitoring endpoints with the use of agents that forward security data to a server. Devices such as routers, switches, and firewalls are supported and can send telemetry using Syslog, SSH, or the API. Information from all these devices is passed to the server for decoding and analysis, and the results are sent to the Wazuh indexer for indexing and storage.

The Wazuh indexer cluster consists of one or more nodes for scaling, performance, and resiliency. Small deployments, with small amounts of data, can utilize a single-node cluster (which is exactly what your lab infrastructure has configured). However, when the volume increases, multi-node clusters are recommended to cope with the additional load, as they all communicate and handle read/write operations.

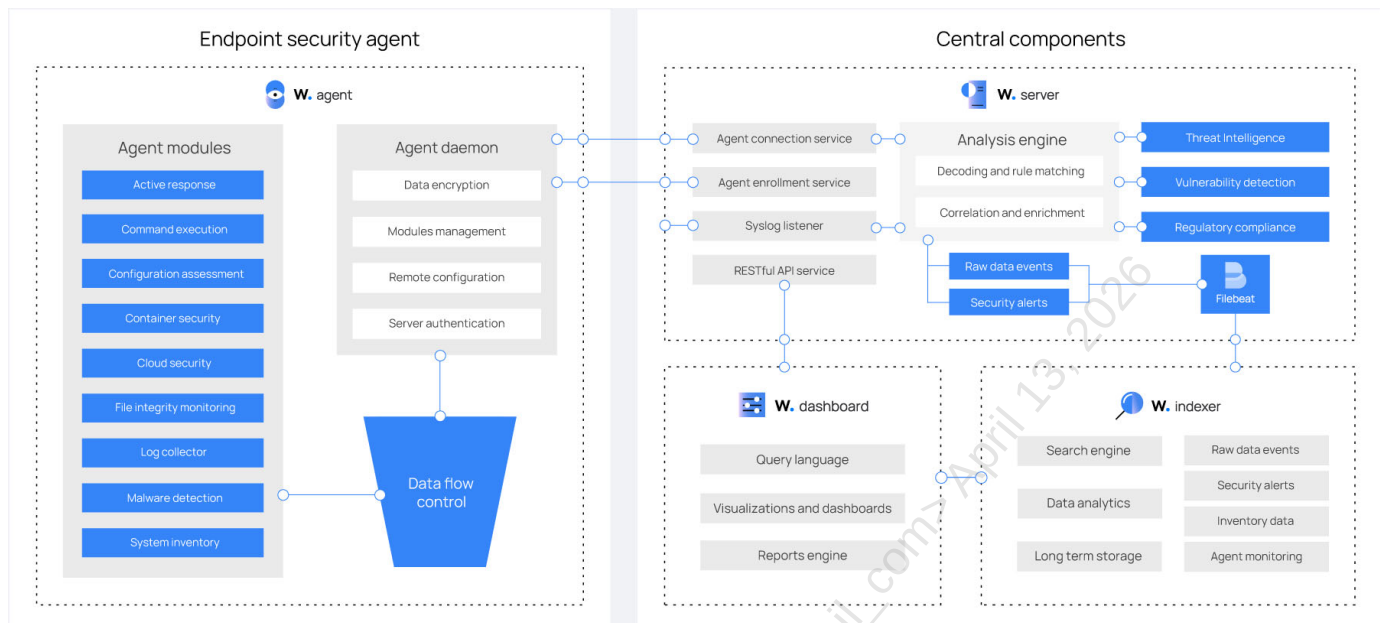
When the Wazuh server and indexer are deployed on different hosts, Filebeat is used to send Wazuh alerts and archived events to the Wazuh indexer cluster, using TLS encryption.

The server listens for agent events on TCP 1514, and once it receives them, it decodes them and applies its rules, using the analysis engine. In order for events to be sent from the server to the indexer, Filebeat is used, sending events over a TLS-encrypted connection to the indexer's TCP port 9200. After indexing has taken place, the events are available in the Wazuh dashboard.

Image reference:

- <https://sec555.com/mnj1c>

Wazuh Components



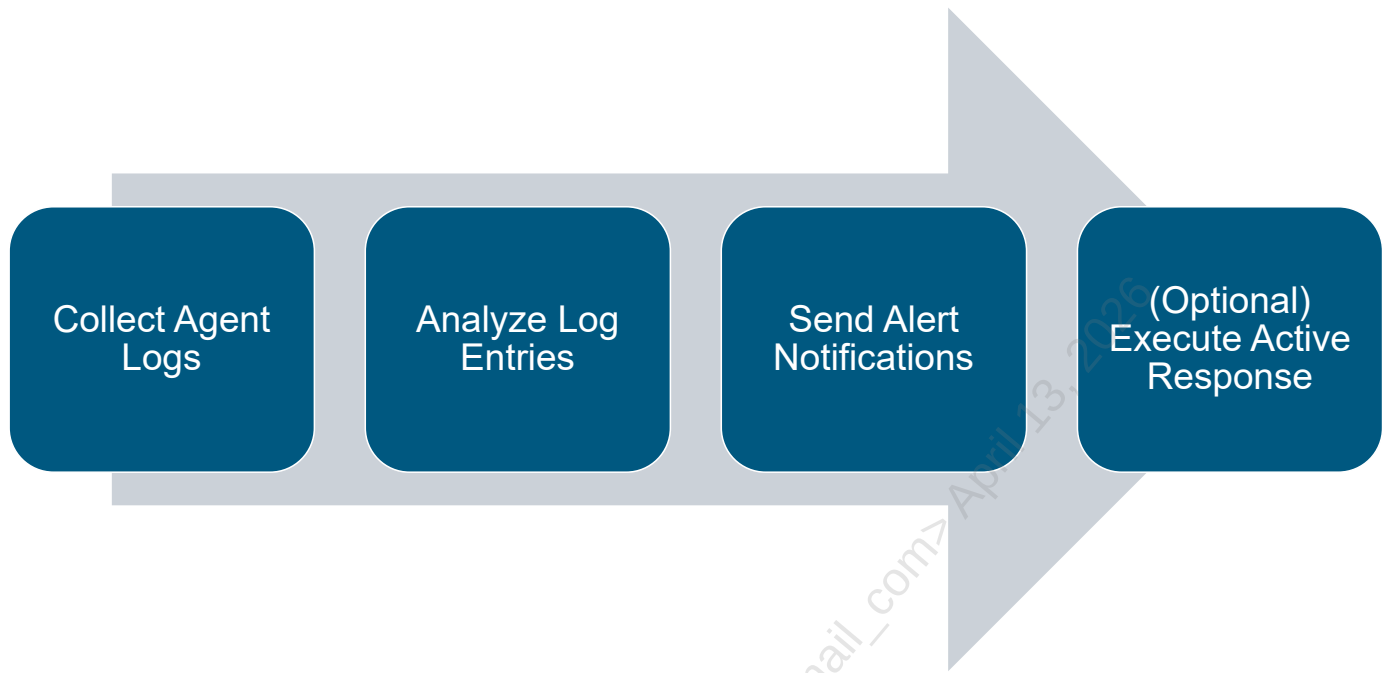
The following are Wazuh's main components, with a brief description of their functions:

- **Wazuh agents:** Agents are used to relay telemetry from your various devices (servers, endpoints, desktops, virtual machines, and more), which in the simplest case is done by installing the Wazuh agent on them. There's massive support for various operating systems, which include Windows, Linux, BSD, MacOS, Solaris, and AIX.
- **Wazuh server:** Performs analysis of the data provided by the agents by passing that through decoders and various rules. Also used to perform alert management, configuration, and upgrading. How does that happen? The server has two main elements: the Wazuh manager and Filebeat. The manager component is responsible for the heavy lifting and performs tasks like adding/deleting new agents, aggregating events, decoding logs, and evaluating alert rules. Filebeat is there to take the alerts and events processed by the Wazuh manager and send them to the indexer for storage. Note that these events are shipped in real time.
- **Wazuh indexer:** The indexer indexes and stores any alerts that the Wazuh server generates.
- **Wazuh dashboard:** Wazuh's dashboard is a customized version of OpenSearch. This is the visualization element, offering a great way for you to visualize and contextualize alert data and pivot to analytical items.

Image reference:

- <https://sec555.com/95uqh>

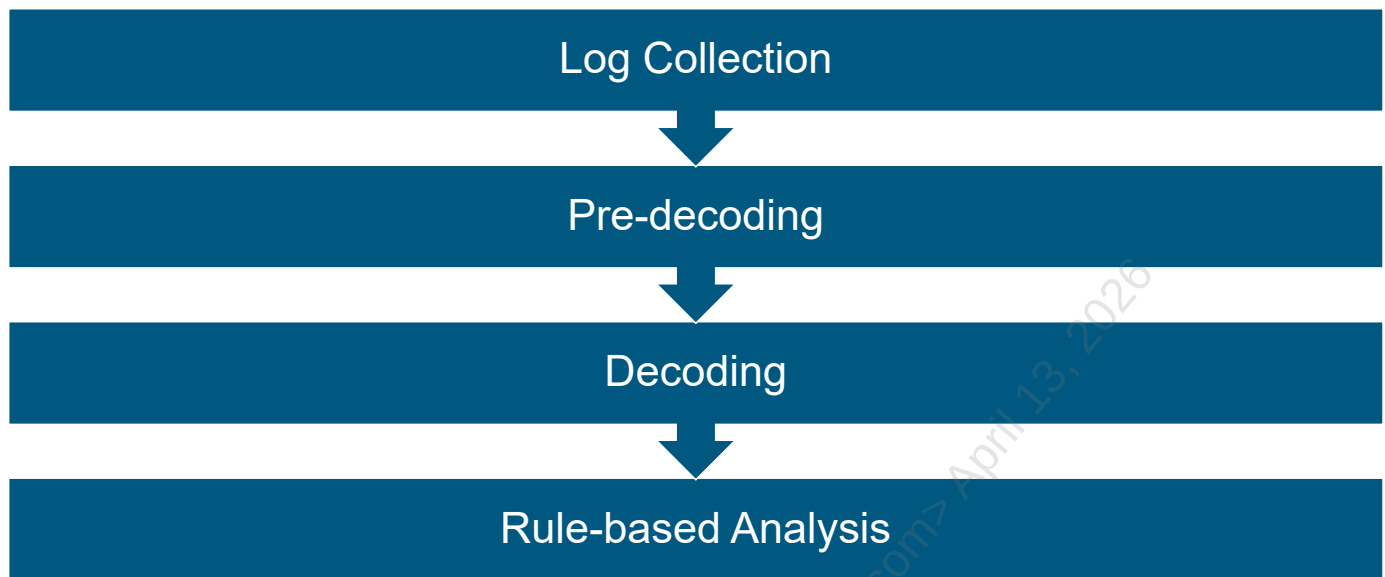
Wazuh Log Collection



The process for performing log collection in Wazuh is as follows:

1. **Collect agent logs:** A program called **wazuh-logcollector** is present on the agent and is used to collect all the necessary logs.
2. **Analyze log entries:** On the manager side, a daemon called **wazuh-analysis** is used to analyze the log entries provided by the client agent.
3. **Send Alert Notifications:** A daemon called **wazuh-maild** is used to send alert notifications via email.
4. **Execute active response:** If any active response tasks have been configured to take place so automatic actions are performed, the **wazuh-execd** daemon is used to do that.

Wazuh Log Analysis Process



1. **Log collection:** The first thing that we need to do is collect logs. To do so, the Wazuh agent configuration files can be used to define which files we require to be collected. **Ossec.conf** is in XML format. As such, a simple example of a configuration addition collecting the Windows Application log looks like the below:

```
<localfile>
  <location>Application</location>
  <log_format>eventchannel</log_format>
</localfile>
```

That declaration instructs the agent to collect the standard Windows Application log file. The log format tag is used to define the format of the log. Common Windows channel logs include Application, Security, and System, which Wazuh collects by default.

2. **Pre-decoding:** Uses the previously stated log_format, to extract basic log fields: **Timestamp**, **hostname**, and **program name**. For example, consider the following SSH log entry:
Jan 22 18:30:22 SSH-Server-03 sshd[20457]: Failed password for root from 3.43.213.12 port 53100 ssh2

After pre-decoding is completed, the following fields are extracted:

```
timestamp: 'Jan 22 18:30:22'
hostname: 'SSH-Server-03'
program_name: 'sshd'
```

3. **Decoding:** Performs extraction of the specific fields of the application in question (identified here as sshd). As such, those would be specific SSH-related fields, since the traffic is hitting the SSH decoder. Most SIEMs (including Wazuh) give you the option to write your own custom decoders, to match any specific pattern not covered by the built-in they have available. After the above log entry passes through the Wazuh decoder, this is what you get:

```
name: 'sshd'
parent: 'sshd'
dstuser: 'root'
srcip: '3.43.213.12'
srcport: '53100'
```

4. **Rule-based analysis:** Performed to check if there are any specific rules that match the decoded fields. An example of the above log matching a rule for failed SSH authentication follows:

```
id: '100002'
level: '10'
description: 'sshd: Authentication failed from a public IP address
3.43.213.12.'
groups: '["local", "syslog", "sshd", "authentication_failed"]'
firedtimes: '1'
```

Summary

Choose the appropriate log collection method for your environment, bearing in mind that you might need to combine approaches. The main ones include agent-based and agentless, combined with scripts and cloud-native options. To ensure your SIEM gives you the best insight, consider adding threat intelligence on top of it using a threat intelligence platform like MISP.

This area is intentionally left blank.

Introduction to the SIEM Components

Refer to the lab workbook for instructions.

This area is intentionally left blank.

Course Roadmap

Section 1: Detection Engineering and SIEM Architecture

Section 2: Network and Endpoint Analysis

Section 3: Asset Discovery, Baselines, and UEBA

Section 4: Cloud Logging and Monitoring

Section 5: Alerting and Detection Engineering Pipelines

- SIEM Introduction
 - ☐ Lab 1.0: Lab Setup
- Detection Engineering Life Cycle and SIEM Planning
 - ☐ Lab 1.1: DeTT&CT & Data Source Gap Analysis
- Creating a Detection Lab
 - ☐ Lab 1.2: Luring the Attacker with a Honeypot
- Log Collection and Enrichment
 - ☐ Lab 1.3: Introduction to the SIEM Components
- Log Aggregation, Parsing, and Analysis
 - ☐ Lab 1.4: Using AbuseIPDB for Data Enrichment

This area is intentionally left blank.

Module Objectives



After collecting logs, we will now dive into how to aggregate and parse data, fueling actionable alerts and further analysis.

This area is intentionally left blank.

From Logs to Alerts



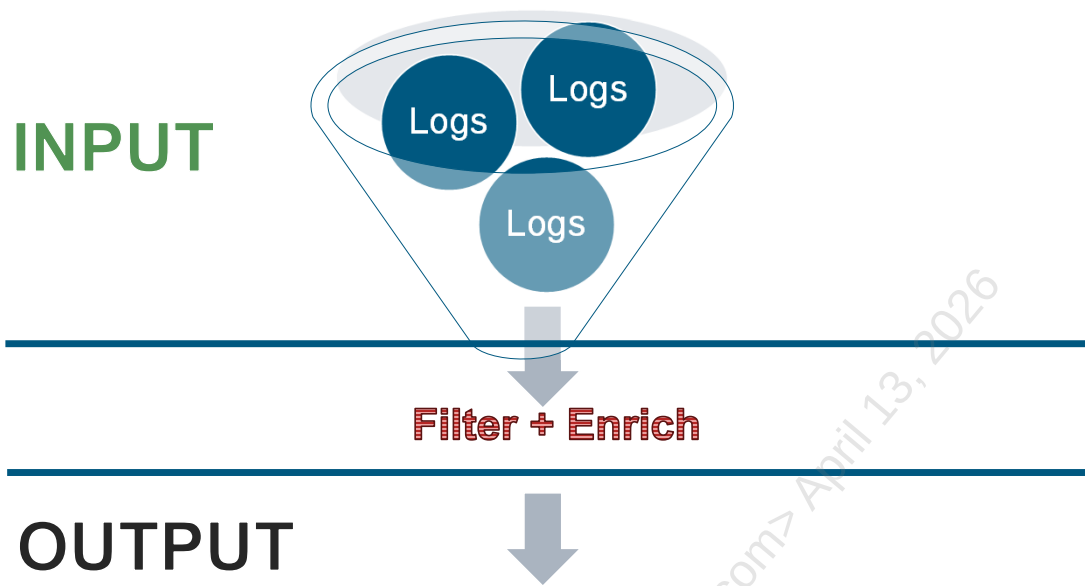
As discussed during the previous module surrounding collection, logs must reach us somehow, so additional correlation and analysis can take place. So, what happens after the logs reach us? Aggregation needs to happen, so we pull information together. Storage will follow, so we can store the data relating to alerts or perhaps compliance and regulatory obligations. Lastly, now that has been done, we can perform composite searches and display useful alerts around what matters.

Log Aggregation



This area is intentionally left blank.

Log Aggregator



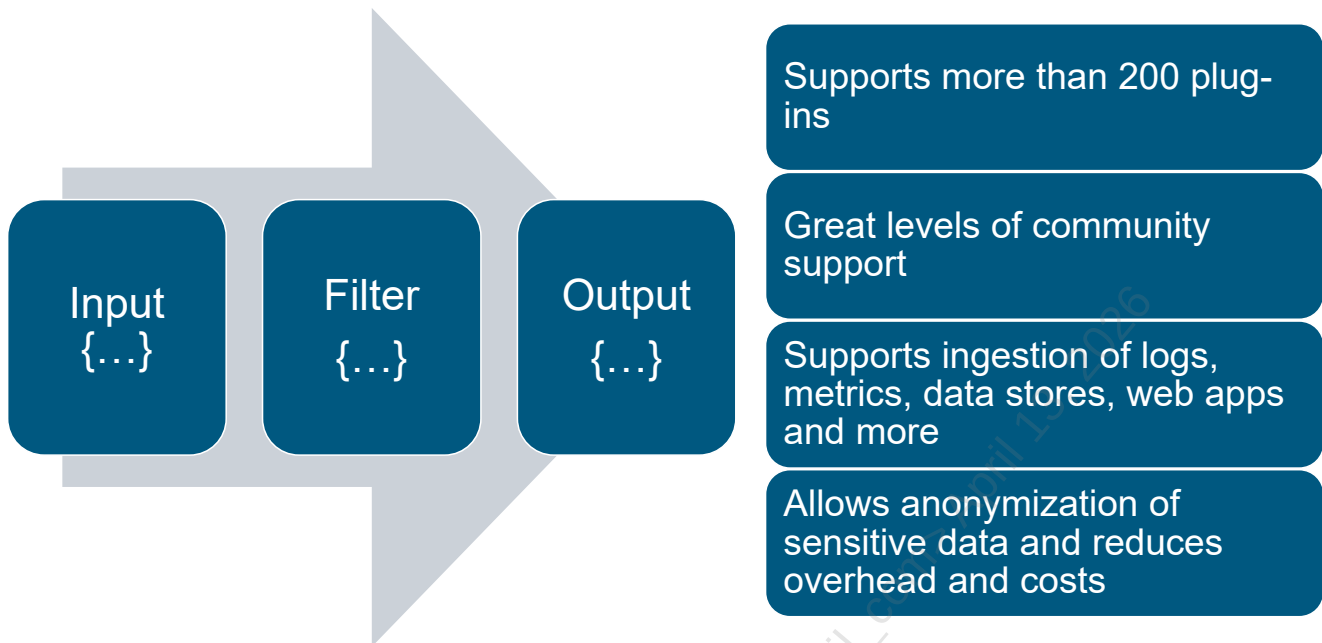
The aggregator pipeline is simple in nature.

To begin with, logs are accepted in some fashion. Then, they are parsed and modified, and finally, sent out to their next destination or destinations.

For example, a single log gets accepted in the input stage, then it is optionally parsed or enriched, and then it is sent to one or more final destinations.

Most of the heavy lifting is done during parsing and modification. However, it is possible that the inbound logs came from an agent pre-parsed and did not need modifications. In this case, the log is collected and then forwarded on.

Example Open-Source Aggregator: Logstash



One of the most common open-source log aggregators today is Logstash. It is actively developed by Elastic and contains over 200 built-in plug-ins. If the built-in plug-ins are not enough, there are multiple community-provided plug-ins as well as a framework to develop your own.

A key piece of Logstash is that community support is vast. If you are having issues or simply need help parsing something, usually a quick search will give you the answer. Also, there are many GitHub repositories containing pre-built configurations with comments explaining what they do.

If community support is not sufficient, commercial support is available. Keep in mind that Logstash can be used to accept logs and convert them into expected formats that commercial products use. This is a common deployment to keep costs down as well as to increase functionality. For example, logs could be sent to Logstash, modified, and then converted to the Common Event Format (CEF), which products such as ArcSight need to store.

The diagram shows the steps taken as logs go through Logstash.

The { .. } means some configuration options are specified in between the brackets. As logs come in, they first get accepted through an input plugin such as tcp.

Once accepted, the log moves into the filter section. Here, one or more plug-ins parse and modify the logs.

The output module then sends the log on to the next destination, such as Elasticsearch.

Note that **plug-ins are lowercase, so even though the protocol TCP is capitalized, the plug-in tcp is not.**

Reference:

- <https://sec555.com/vmbei>

Tags

What if you want to categorize on multiple things?

Tags are a method for setting unlimited categories

- Powerful for searching, filtering, alerting, etc.
- Can be used to route logs
- Can mark logs according to compliance requirements

Important for data retention

Tags provide an enormous amount of flexibility, and they can have an unlimited set of values. This makes them more dynamic and usable for handling logs. Tags can be applied at input time and can also be set within the filter section.

The use cases for applying tags go on and on. Some examples follow:

- If a company had 10 subnets based on departments, and 192.168.0.0/24 was the HR department, they could tag any log with an IP address in this range with a tag of HR Department and a tag of Workstation. The HR Department tag allows for quickly searching any logs dealing with the HR Department. The Workstation tag can be used to search for lateral movement.
- A company dealing with PCI is required to retain in-scope system logs according to PCI standards. Again, using IP addresses, they could tag any system or subnet with a tag of PCI. This can then be used to show auditors all PCI logs easily, and also to route logs to a long-term storage location.
- Some logs are related. For example, Zeek has many log files, but you may want a tag of 'zeek' to show all of them.

Regex

Custom log formats require manual parsing rules

- Typically done using regex

Regex or regular expressions are used for pattern matching

- Might also be called manual parsing ninja sauce
- Seems complex (can be, but usually not too bad)
- Often hard to read
- Computationally expensive

Important to learn and valuable to use

The power of regex, also referred to as regular expressions, is immense. Given enough time, you will be able to pull out any kind of conditional patterns. However, because these pattern matches can be complex, they become computationally expensive.

In security, regular expressions can go a long way in various functions. Doesn't matter if you are an engineer, security analyst, or incident handler. You will use regex at some point in life to make things easier.

When a custom or proprietary log format comes in, regex is used to extract data and map it to fields. Regex, or regular expressions, are used to perform pattern matching and extraction. Regex can be intimidating as it looks complex and, quite frankly, it is difficult to read. Fortunately, there are books, online documentation, and online regex builders to help.

Two online regex builders that double as online documentation are below:

- Regular Expressions 101¹
- RegExr²

1. <https://sec555.com/6y9jh>
2. <https://sec555.com/joqkf>

Regex Rules

- `.` matches any single character
- `\d` matches any digit
[0-9]
- `\w` matches a word character
[a-zA-Z0-9_]
- `\s` matches whitespace (any one space) [`\r\n\t\f`]
- Capital equivalent means not
`\D \W \S`
- `*` matches zero or more of specified character
- `^` means start of line
- `$` means end of line
- `[]` looks for anything within brackets
[a-cz] only matches a,b,c,z
- `{#}` used to repeat character # times
- `\` is an escape for special characters

This page represents some of the common regex patterns used.

Assume you had a log file containing a date in the following format: **2025-03-23**.

1. That's a group of 4 digits: `\d{4}`
2. A dash: `-`
3. A group of 2 digits: `\d{2}`
4. A dash: `-`
5. A final group of 2 digits: `\d{2}`

Final expression: `\d{4}-\d{2}-\d{2}`

Remember that `d` matches on digits 0-9.

How about if it was a date and time you were after? The format is: **2025-03-23 12:23:34**

So, in addition to the earlier regex, you need to add:

1. A whitespace: `\s`
2. 2 digits: `\d{2}`
3. The colon character (`:`)
4. 2 digits: `\d{2}`
5. The colon character (`:`)
6. A final group of 2 digits: `\d{2}`

Final expression: `\s\d{2}:\d{2}:\d{2}`

And if you combine the two you get: `\d{4}-\d{2}-\d{2}\s\d{2}:\d{2}:\d{2}`

Log Storage



The student will understand the methods and challenges of storing data (after it has been collected).

This area is intentionally left blank.

Storage

Log storage is important.

- Be careful not to end up with a big data warehouse.
- You might need to separate compliance from tactical logs.

Also, must handle:

- Indexing
- Search queries
- Redundancy
- Performance requirements

Big Data Challenge

Apache Hadoop

Microsoft Azure Lake

Amazon AWS Lake

Google Cloud Storage

Snowflake

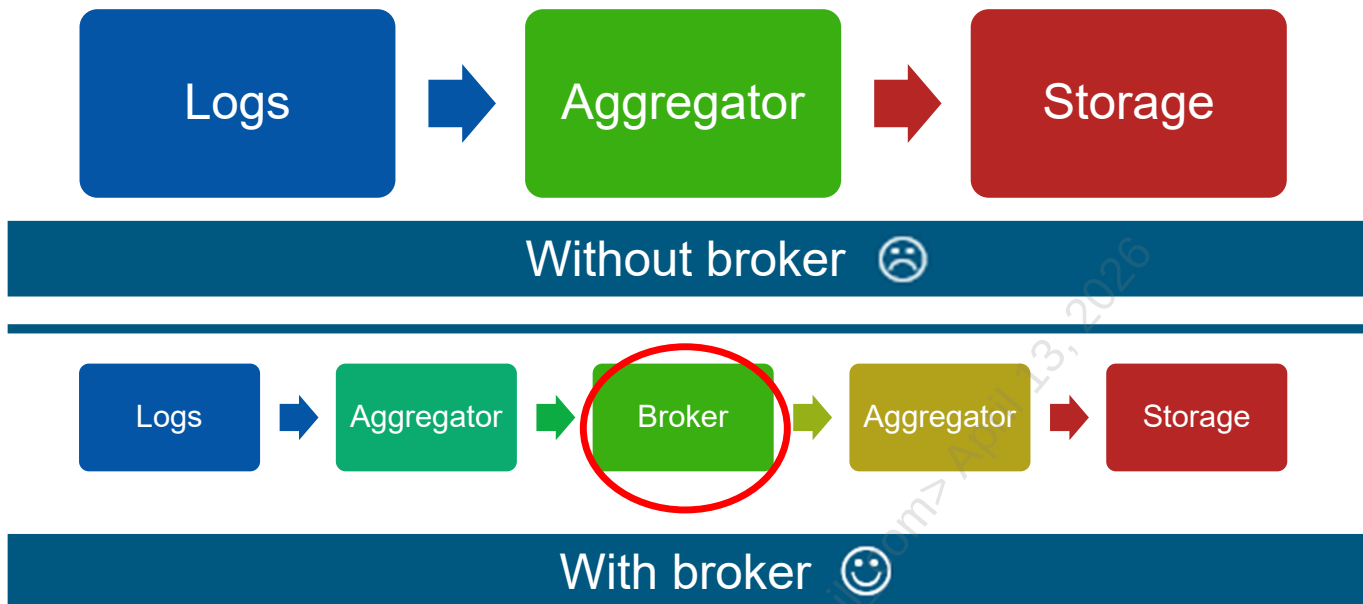
Need data for 20 years???

The SIEM focus leans toward being able to ingest massive amounts of logs and having the ability to store them. The reason for collecting logs is to use them, and you cannot use them if the storage system lacks the performance or architecture to perform quick searching. Consider:

- **Indexing:** A logical collection of data that allows your tool to be able to search and retrieve what you need.
- **Search queries:** An engineer or analyst would commonly use search queries to be able to dig into the data and obtain information.
- **Redundancy:** When storing data, there's no excuse for not being able to access it in a critical time. As such, redundancy needs to be accounted for, so that if your primary storage solution fails, there's an alternative to it.
- **Performance:** A common challenge when searching for information is retrieval speed. For example, if you submit a standard search query and it takes you 30 minutes to get a result, while tackling an incident or testing something, that will be way too long. You might find you started quite efficiently, taking only 5 seconds. But then, 5 seconds becomes 30 seconds. This, then, ends up being minutes and then hours. As the SIEM continues to decrease in search speed, so does the passion of its analysts. Should performance be an issue, consider separating compliance logs and tactical logs to either separate storage servers or at least separate storage partitions. This allows fast searches for certain logs, yet allows processing less important logs to slower disks.

Another item to think about is how much data you need to store and for how long. A lot of options exist in the market that offer storage for tons of data. You might need to review some of those if you have concerns (e.g., for storing data for 10 or 20 years, whatever the underlying reason may be).

Message Broker: Before and After



Before broker (upper part of diagram):

1. Logs are sent from agents or other log transport mechanisms.
2. Aggregator accepts logs, filters, and sends to storage.
3. Storage accepts the logs.

However, that has multiple design weaknesses:

- If the aggregator is sent too many logs, it may crash or drop logs.
- If the backend storage needs to be taken offline, the aggregator will backlog and crash.
- If the backend storage is getting overloaded with search queries, log ingestion slows down, and the log aggregator will backlog and crash.

After broker is added (lower part of the diagram):

When adding a message broker, you should also add another aggregator. This is because the initial aggregator should only accept logs and send them into the message broker. From there, the backend aggregator retrieves logs from the broker, modifies as needed, and then places the logs in storage.

This architecture has some inherent wins:

- The backend log aggregator will only retrieve logs from the broker when it is ready to do so.
- If the storage system starts to get overloaded, the backend aggregator will hold off on delivering logs until the storage system is back to normal performance. Since the aggregator only retrieves logs from a broker when it is ready for more, it can hold the currently retrieved logs in memory, rather than being force-fed logs like it would when not behind a broker.

To Broker or Not to Broker

Each aggregator can only handle so many logs

- More parsing means less EPS throughput
- More enrichment means less EPS throughput

Effective throughput could be half or even a quarter of original EPS

- Clogs the pipes, stops the aggregator

Storage must process searches and accept logs at the same time

- A lot like juggling

Storage is not an infinite resource

- Can become bottlenecked and then logs drop

A message broker primarily acts as a lifeguard for log aggregators and storage systems. It helps log aggregators due to most log aggregators crashing, or, at a minimum, dropping logs when they get overwhelmed.

Without any parsing or manipulation, a log aggregator can handle tremendous amounts of logs.

Once you start to add in parsing rules and log modifications, the EPS tends to fall to half or even a quarter of what it started out as. This makes sense as the more you do, the more processing power and memory is required. You may start with 20K EPS, but after adding in all your configurations, you may fall down to 5K EPS per aggregator.

With this, you either need to guarantee enough aggregators to handle peak EPS, or you insert a broker and move parsing and enrichment to backend aggregators.

Storage Problem

Storage systems are designed to store logs. More importantly, they are designed to index logs, accept logs, and process search queries. But what happens when there are intense search queries, and the system gets bogged down? Logs are always coming in, but what happens in this situation? Usually, searches will start to fail, and log ingestion will as well. If you are lucky, you are on a storage system that will send a message stating that the log was not accepted due to system overload. Yet, even if that is the case, at some point, typically within minutes or seconds, an aggregator will get overloaded.

A message broker is just as important to account for overload or outages of backend storage as it is in handling peaks in EPS. It provides a safe pause to allow systems to get back to normal conditions. Once operations are back to normal, log processing will kick back off.

Open-Source Brokers

Multiple open-source brokers, but most common are:

- RabbitMQ
- Apache Kafka

The concept is the same, but each differs in:

- Ease of setup (RabbitMQ is simpler)
- Management overhead (RabbitMQ provides ease of management)
- Performance (Kafka is usually able to achieve higher throughput)

Initial Logstash instance should not parse/enrich

- Allows for maximum EPS
- Only drops logs into the broker

Backend instance retrieves logs, parses, and augments

- Will rate limit based on the performance of broker and storage systems

The two most common message brokers are probably RabbitMQ¹ and Kafka.² If you think of these as different types of cars, they are different products that, under the hood, have different engines, but each allows the car to move. Where things primarily differ is in the amount of horsepower, how easy each is to repair, and how hard the engines are to install in the first place.

RabbitMQ tends to be simpler to configure and manage, while Kafka is a bit more complicated. However, from a performance standpoint, Kafka is usually able to provide increased throughput, which is a significant advantage.

Logstash is able to work with various message brokers, but if you go with that option, you will need two Logstash instances:

- Initial instance doesn't do any parsing or enrichment, but rather is only used to send the logs to the broker. That will ensure overhead is small and performance is high.
- The backend Logstash instance does the heavy lifting and performs log retrieval, parsing, and enrichment. That allows you to take advantage of the pre-mentioned architecture (including a broker) to ensure you have maximum performance.

1. <https://sec555.com/tjgok>
2. <https://sec555.com/epbyg>

No Broker Necessary?

Many organizations broker everything.

- Might be overkill

Modern agents and custom applications broker themselves.

- Thus, sending to a broker is wasting resources

Message brokers are intended for systems that need help.

- Syslog devices
- Log agents without a feature to self-regulate, such as store and forward

While a broker comes highly recommended, you should not blindly send logs into it. Many custom applications and newer log agents natively have built-in capabilities to buffer logs in memory or to disk (such as a flat file or a database). In this situation, logs will not be sent unless the remote system is online and functioning properly. **However, you need to verify how this works.**

For example, some log agents will make sure the remote system is online and receiving packets. If so, logs are sent, and if not, logs are buffered. However, simply checking if the destination is responding to packets does not mean the destination system is not being overwhelmed. Other log agents make sure a connection is able to be established and that the remote destination is able to keep up with the number of logs being sent. In this case, there is no reason to send the logs to a broker as the agent is acting as its own safety net.

A message broker is intended for systems that cannot check if logs were successfully sent and accepted. **This applies to most network devices, as syslog simply sends the log on with no verification of receipt.**

This also applies to most agents. Again, in many cases, logs from these devices will go into a central log aggregator whose sole purpose is to accept remote logs and then push them into a log broker. Then, a separate log aggregator will pull from the log broker and do any parsing and log enrichment.

Key recommendation: If you find trying to configure an agent or application to self-broker is too complicated, then send the logs to a message broker.

Tools for Log Storage and More

Wazuh

ELK
(Elasticsearch,
Logstash,
Kibana)

EFK (similar to
ELK but uses
Fluentd for log
collection)

OpenSearch

Graylog

OSSEC

Splunk

Qradar

LogRhythm

ArcSight

Sentinel

Various tools are available in the market, including open source, that can perform all the previous tasks, such as collection of logs, storage, aggregation, enrichment, alerting, etc. Some common examples include:

- Wazuh
- ELK
- EFK
- OpenSearch
- Graylog
- OSSEC
- Splunk
- Qradar
- LogRhythm
- ArcSight
- Sentinel

Searching and Alerting



The student will gain insight into the challenges of searching and alerting upon collecting data.

This area is intentionally left blank.

Search Requirements

Struggle for many organizations is how to search

- SIEM searching is not the same as using a search engine

Requirements

- Actionable log data ingested
- Proper parsing, field names, and field types
- Quick storage system
- Understanding of your environment

Knowing attacker methods helps as well

The main reason most organizations struggle with using their SIEM is twofold:

1. **The system and logs were not properly set up:** This is not due to insufficient hardware resources or a problem with the software installation, but refers to critical components such as ingesting proper data, properly parsing fields, and performing log enrichment.
2. **Organizations simply struggle to know their environment:** This goes back to people and processes being the least mature parts of organizations. The two items are intertwined. For example, if you do not have an understanding of your environment and do not have the training to know what tactical logs are, then how can you properly plan a SIEM?

Knowing how attackers work may also help in identifying search patterns.

For example, if you were to attack your own systems within a lab, you could search for what logs existed before the attack and what occurred after. This helps identify events to search and alert on in the future. That makes another argument about the importance of both having a detection lab and a detection engineering function in your environment. These can be used to set the SOC for success.

Searching and Alerting Techniques

Multiple search techniques exist

- Allow lists
- Deny lists
- Long tail analysis
- Anomaly detection

Discovery is best with the repetition of multiple methods

- Can be combined with alerting
- Techniques apply to manual and automated searches

Conceptually, analysis is done by repeating various techniques. The following is a generalized list of techniques:

- **Allow lists:** Ignoring known good (which are the items you have on the allow list) and searching and alerting on everything else your search comes back with. This poses a different challenge as you need to ensure that each legitimate corporate item and activity is included there. The upside is that anything not included (being considered bad) will end up alerting, and you might be able to catch a zero day. The downside is maintenance. For example, each time a new application is introduced to the environment, it needs to be vetted and included on the allow list, so it doesn't end up in an alert.
- **Deny lists:** Searching for known bad. This can be very helpful; however, you always need to know what "bad" looks like. Also, if you are alerting upon this search, exclusions need to be made. For example, you can have Metasploit on the deny list, but how are penetration testers going to be able to use it, without alerting?
You just need to do some housekeeping to allow this to work.
- **Long tail analysis:** Identify events of least occurrence, as they are likely to be of interest. Allows you to identify outliers that may be indicative of malicious activity.
- **Anomaly detection:** Identify events that are not normal. Mostly using a baseline of the environment, you are then able to trigger on what deviates from that known baseline.

A healthy combination of techniques tends to work best. Upon understanding these techniques, use cases can be developed to take search criteria and generate actionable alerts.

Allow Lists

Ignore what you know about, alert on everything else

- Requires knowledge of environment and systems

Pros

- Catches known bad and unknown bad
- High fidelity

Cons

- High maintenance
- Does not apply well to all logs

Simple in concept, allow lists involve knowing and only allowing everything that should be in your environment. This works extremely well, but the maintenance is higher than other techniques. This is due to all changes requiring an investigation—benign or otherwise. Imagine someone installing Notepad++ (a text editor) and not being in an allowed list. It would most likely fire an alert, which then needs to be investigated and a determination needs to be made.

In the logging world, this could be targeted to specific use cases. For example, it could include looking for all new Windows service creation events, or it could be general, such as "show me all new Windows event IDs never previously seen before." However, this technique has some limitations. For example, looking for connections made from a generic desktop to new internet-based IP addresses may be an exercise in futility. This is not from a failure of the allow list technique, but would be due to a misunderstanding of how networking works. Due to content delivery networks, DNS changes, and things such as load balancers, IP addresses on the internet are constantly changing. The point is that this is one of the most effective techniques, but it should be applied to things that can be controlled and monitored.

Do not discard this technique. It is highly effective. If you find it is too much maintenance, then be more selective in its use.

Deny Lists

Most common is to look for known bad

- Can be modified to look for known unexpected

Pros

- Low maintenance and setup
- Useful for honeypot techniques

Cons

- Easy to bypass
- Cannot catch new attacks

Often dubbed the "whack-a-mole" approach, deny lists simply look for a known bad indicator. This could be something as simple as IP addresses being checked against a threat intelligence feed. If the IP address is on the naughty list, it gets marked as an unauthorized IP. This ends up being an easy-to-maintain search technique. Taking deny list IP addresses, for example, could be used to see who is talking to a given IP, as well as what security devices failed to block.

However, deny lists tend to be easily bypassed. For example, if an IP address shows up as an unauthorized IP address and an organization turns around and prevents communication to that IP, then the attacker quickly becomes aware that they are being blocked. This ultimately leads to a change in attacker behavior and a likelihood of an unknown attack.

Another consideration is the potential accidental block due to inaccurate information. Your external threat intelligence provider just sent you a list of 100 IP addresses, and most of them get reused after six months and are benign. You have to be careful because these could block legitimate traffic originating from them.

Long Tail Analysis

Look for least frequent occurrences in datasets

- Assumes high-frequency events are normal conditions

Pros

- Works with large datasets
- Easy to apply

Cons

- Manual analysis
- Does not work well with small datasets

A lot of individuals become overwhelmed when looking at large datasets. This is understandable as humans are not capable of processing numbers exceeding thousands, with any sort of timeliness. The larger the data, the more stress it causes. Yet, there is one technique that tends to work better the more data you have. **This is long tail analysis.**

Long tail analysis takes a dataset and looks for **events of least occurrence**. This technique was originally developed for supply chain stores. Products that are popular continue to be sold, and products that tend to be purchased the least are reviewed to see if they should be pulled from the market.

In regard to logs, the same concept applies. The notion is that events that occur frequently are normal and can be ignored, but events of least occurrence should be investigated to find out why, in a large dataset, they only occur a few times. That is making the assumption that these high-frequency events are actually normal, though.

The more data you have, the better it is for this technique to work. In fact, its worst enemy is lack of data, translated into having small datasets to analyze. That won't work because you won't have enough telemetry to work with.

Anomaly Detection

Look for anything outside the ordinary

- Requires knowing what "normal" is

Pros

- Catches unknown bad
- Catches system misconfigurations and policy violations

Cons

- Requires an established baseline
- Best combined with manual analysis

Generically, anomaly detection is searching for anything that is not normal. For this to work, you have to possess a great sense of what is normal before you can identify what abnormal looks like. This ends up requiring a lot of work and, oftentimes, manual analysis. Many products have been sold, stating they provide anomaly detection without ever missing an attack. What this really means is tons of false positives and a system that generates so many alerts that you ignore them. Sometimes, these even go to the extent of using analyst power to learn. They will have different models, and they expect a SOC analyst to deem something as good or bad, so the tool learns and adapts as it goes along.

Application of this technique requires establishing a very good baseline. However, a baseline does not have to be a solid thing. For example, a chart showing top talkers to the internet provides a visual baseline. A dramatic shift in the chart provides a form of visual anomaly detection. Many times, this technique will uncover misconfigured systems and policy violations. However, it will also uncover the bad guys.

Wazuh Alert Management

```
<alerts>
  <log_alert_level>5</log_alert_level>
  <email_alert_level>13</email_alert_level>
</alerts>
```

If 5 or above, trigger alert (which is stored in the logs)

If 13 or above, trigger email notification for the alert

```
<syslog_output>
  <level>11</level>
  <server>10.1.1.1</server>
</syslog_output>
```

Forward alerts to a syslog server

Store alerts in .json format in alerts.json

```
<jsonout_output>yes</jsonout_output>
<alerts_log>yes</alerts_log>
<logall>no</logall>
<logall_json>no</logall_json>
```

Store alerts in plain format in alerts.log

If yes, log all events in archives.log (doesn't matter if a rule matches)

If yes, log all events in archives.json (doesn't matter if a rule matches)

Alert configuration can be managed by altering the configuration in `/var/ossec/etc/ossec.conf`. Alerts are stored in two files: A .log file at `/var/ossec/logs/alerts/alerts.log` and a .json file at `/var/ossec/logs/alerts/alerts.json`.

Alerts need to meet a threshold in order to be stored in the above log files. In the below sample configuration, that is 5. The email alert threshold, however, is 13, meaning an email will go out to a designated list of recipients for any alerts from level 13 to 15 (which is the maximum).

```
<alerts>
  <log_alert_level>5</log_alert_level>
  <email_alert_level>13</email_alert_level>
</alerts>
```

The Wazuh manager can also forward alerts to other systems, with syslog being a common example:

```
<syslog_output>
  <level>11</level>
  <server>10.1.1.1</server>
</syslog_output>
```

Here's a useful portion of the global parameters of `ossec.conf`:

```
<jsonout_output>yes</jsonout_output>
<alerts_log>yes</alerts_log>
<logall>no</logall>
<logall_json>no</logall_json>
```

It allows you to specify if you need your alerts to be stored in plaintext format or .json, and if you set the `logall` parameter to yes, it allows you to store all log entries without necessarily matching an alert.

© SANS Institute 2025

That can be very useful if you need to monitor some key data as part of a compliance program, but it can also be very resource intensive, not to mention consume a lot of disk space.

It can also be very useful if you have the intention of performing big data analysis, pattern identification, and retrospective searches on large timeframes.

Summary

Crafting a careful architecture for efficient log collection and storage is instrumental to success. Consider combining log aggregators and brokers to achieve operational efficiency. After events are stored, apply searching and alerting using a combination of allow/deny lists, long tail analysis, and anomaly detection.

This area is intentionally left blank.

Using AbuseIPDB for Data Enrichment

Refer to the lab workbook for instructions.

This area is intentionally left blank.

Contacts and Resources

AUTHOR

Nick Mitropoulos

nick.mitropoulos@scarlet-dragonfly.com

@NickMitropoulos

www.linkedin.com/in/nickmitropoulos

Nick is the CEO of Scarlet Dragonfly, a company that handles a range of security services like SOC, incident handling, and vulnerability management, to name a few. He has over 16 years of experience in various industries, including consulting, education, telecommunications, healthcare, investment banking, financial, energy, oil and gas, insurance, pharmaceutical, law, military, and news. His breadth of experience, combined with his love for teaching, is crucial in helping his students better grasp the various facets of security.

Nick started collecting hacking newspaper articles back in the 80s when security was just starting to grow, and he was immediately hooked. He is a certified ISC2 instructor and a GIAC advisory board member, and he has an MSc (with distinction) in Advanced Security and Digital Forensics from Edinburgh Napier University and a BSc (with distinction and the highest held graduation grade of the department) from the Technological Educational Institute of Thessaly. He is also a faculty member of the SANS Technology Institute, an NSA Center of Academic Excellence in Cyber Defense, and a multiple winner of the National Cyber League competition. Nick has a great passion for teaching and has trained many individuals in a variety of security topics, mainly focusing on SIEM, security operation centers, incident response, and security certification courses.

Nick has worked for a variety of companies (including the Greek Ministry of Education, AT&T, F5 Networks, JP Morgan Chase, KPMG, and Deloitte) and has provided critical advice to many clients that want to improve their current security posture by creating new security operation centers and protocols, developing vulnerability management programs, managing third parties and security vendors, testing incident handling and forensic teams, redesigning perimeter security solutions, and developing custom-tailored training courses for company staff and specialized security teams. One of the greatest challenges for most security professionals is ensuring they have an in-depth understanding of all fundamental concepts of security. Nick loves teaching classes that help students obtain the knowledge required to secure their environments and enhance their personal security posture to protect themselves in an ever-growing digital arena.